

FactoryShield — Incident Monitoring & Operational Governance Specification

Table of Contents

1. [Executive Overview](#)
2. [Incident Lifecycle Monitoring Model](#)
 - 2.4 Post-Triage Operational Stages
 - 2.5 Approval Governance
3. [Reporting & Evidence Visibility](#)
4. [Response Time & Delay Tracking](#)
 - 4.5 Investigation & CAPA SLAs
5. [Responsibility Tracking Model](#)
6. [Incident Status Monitoring](#)
7. [Configurable SLA & Escalation Management](#)
8. [Offline Reporting & Sync Failure Monitoring](#)
9. [Anonymous/Confidential Reporting Auditability](#)
 - 9.8 AI Output Governance
10. [Dashboard Views \(Executive, Supervisor, Compliance\)](#)
11. [Required Reports](#)
12. [Data Model Entities for Monitoring](#)
13. [Notification Strategy](#)
14. [Responsibility Governance Matrix \(RACI\)](#)
15. [OpenSpec Style Acceptance Criteria](#)
16. [Non Functional Requirements](#)
17. [Operational KPI Reference](#)
18. [Assumption & Configuration Governance](#)
19. [Requirement Traceability Matrix](#)
20. [Guest Mode & QR Entry Point Monitoring](#)
21. [Report-on-Behalf Monitoring](#)
22. [Rejection Dispute Monitoring](#)
23. [Reporter Submission Funnel Monitoring](#)
24. [KPI & Traceability Addendum](#)
25. [RMG Context Entities & Business Impact Governance](#)
26. [Investigation & CAPA Governance](#)
27. [Internal GrillMe Validation Report](#)

1. Executive Overview

1.1 Purpose

This specification defines **how management will monitor, govern, and audit** the FactoryShield Reporter application once it is operational. It is intentionally distinct from the Master PRD, which defines *what the system does*. This document defines **how leadership will observe it, hold it accountable, and intervene when its operational guarantees are at risk**.

The system under governance is a multilingual (English/Urdu) Android-first incident reporting tool deployed at iFar-Silexa (Pvt.) Ltd., supporting three reporting modes — **Manual (login-based), Anonymous, and Confidential** — with offline resilience, geolocation capture, voice dictation, and a 14-step submission flow that produces a high-quality incident report.

1.2 Governance Objectives

#	Objective	Operational Question Answered
GO-1	Visibility	"Is the system actually being used, and where?"
GO-2	Timeliness	"Is anything sitting too long without action?"
GO-3	Accountability	"Who owns this incident right now, and is that person acting?"
GO-4	Quality	"Are reports usable, or is the triage layer drowning in noise?"
GO-5	Compliance	"Can we defend the audit trail to a regulator, a court, or the board?"
GO-6	Resilience	"Is offline mode hiding incidents we are unaware of?"
GO-7	Trust	"Can a reporter use the system without fear of retaliation?"

1.3 Audience

- Executive Leadership (CFO, COO, CEO)
- Plant Manager and Shift Supervisors
- Compliance / EHS Officer
- IT Operations and Mobile Device Administrators
- Audit and Legal (read-only, on request)

1.4 Out of Scope

This document **does not** redefine:

- Field-level report form behavior (covered by Epic 1, sections 5–7)
- Authentication, data retention, and classification policies (covered by Master PRD)
- HR misconduct or grievance workflows (out of FactoryShield scope per Epic 1 §1)

1.5 GrillMe Hardening — Executive Level

Challenge Raised	Resolution
"Monitoring without enforcement is theatre — what happens when a KPI is missed?"	Every monitoring KPI in this document is paired with a named owner , an escalation path , and a threshold-based action (see §7).
"Executives will only look at one screen — what's on it?"	§10 defines a single Executive Dashboard with a fixed KPI set and no more than 7 visual elements.
"Will this spec be silently bypassed during pilot?"	Section 1.6 defines a 30/60/90-day governance review cadence.

1.6 Governance Cadence

Cadence	Activity	Owner
Daily (08:00 PKT)	SLA breach report review	Plant Manager
Weekly (Monday)	Incident pipeline review	Operations Lead
Bi-weekly	Anonymized pattern analysis	Compliance / EHS
Monthly	KPI scorecard submission to ExCo	COO
Quarterly	Governance spec review and update	Product Owner
Annual	External audit readiness check	Compliance Officer

2. Incident Lifecycle Monitoring Model

2.1 Lifecycle Stages (as derived from Epic 1)

The Epic defines the reporter-side flow only. For governance purposes, the lifecycle is extended to the **back office** to make every state observable and owned:

Stage	State Code	Definition	Monitoring Concern
Drafting	DRAFT	Reporter is inside the 14-step form, has not yet submitted.	None — invisible to management by design (antiretaliation).
Submitted (Local)	SUBMITTED_LOCAL	Submitted on-device, awaiting sync.	Critical monitoring blind spot — see §8.
Submitted (Server)	SUBMITTED	Server has received and persisted the report; systemgenerated ID assigned.	Entry point for SLA clock (§4).
Triaged	TRIAGED	Compliance / Supervisor has reviewed, assigned severity (L1–L4) and routed.	Severity classification must occur within triage SLA.
Assigned	ASSIGNED	Named owner (Supervisor / Engineer / EHS) is on the hook.	Responsibility tracking begins (§5).
In Progress	IN_PROGRESS	Owner has logged active work (evidence of motion).	Idle-time clock starts.
Pending Evidence	PENDING_EVIDENCE	Awaiting reporter upload or third-party information.	Idle-time clock paused , not reset.
Investigation (v1.2 NEW)	INVESTIGATION	Investigation lead is gathering facts, evidence, witness statements against an Investigation Checklist (§2.4 / §26).	Investigation SLA (§4.5); checklist-progress audit log (§4.5).
RCA Review (v1.2 NEW)	RCA_REVIEW	Root-Cause Analysis document is drafted and routed for multi-stage approval (§2.5).	RCA Approval SLA; mandatory sign-off ladder; rejection-comment enforcement (§2.5).
CAPA Execution (v1.2 NEW)	CAPA_EXECUTION	Corrective and Preventive Actions are being implemented per the approved RCA.	CAPA SLA (§4.5); E-9 Overdue CAPA escalation.
Verification (v1.2 NEW)	VERIFICATION	Independent verification of CAPA effectiveness before closure.	Verification SLA; rejection-loop back to CAPA_EXECUTION if ineffective (§2.4).

Resolved	RESOLVED	Owner marks complete with resolution note.	Subject to resolution SLA.
Closed	CLOSED	Compliance / Supervisor accepts resolution. Case archived.	Final state — read-only after T+30 days.
Rejected	REJECTED	Triage determines report is invalid (e.g., duplicate, nonincident).	
			Tracked, never deleted (§3.5).
Withdrawn	WITHDRAWN	Reporter voluntarily retracts (manual or confidential).	Audit trail preserved.

2.2 State Transition Rules

Transitions are **append-only and logged**. The state machine is enforced server-side; mobile clients may only **propose** transitions.

```
SUBMITTED → TRIAGED → ASSIGNED → IN_PROGRESS → RESOLVED → CLOSED
    ↘ REJECTED (any non-CLOSED state)
    ↘ WITHDRAWN (pre-triage, by reporter)

[v1.2 NEW] Post-Triage Operational Branch (see §2.4):
IN_PROGRESS → INVESTIGATION → RCA_REVIEW → CAPA_EXECUTION → VERIFICATION → CLOSED
    ↘ (verification fails) → CAPA_EXECUTION (rejection-loop, audit-logged)
    ↘ (RCA rejected) → INVESTIGATION (with mandatory rejection comment, §2.5)
```

2.3 GrillMe Hardening — Lifecycle

Challenge Raised	Resolution
"What if a submitted report is never triaged — does it sit in limbo?"	SUBMITTED state triggers an unassigned timer (§4.3). After 2 hours with no triage action, automatic escalation to Plant Manager.
"Can a Supervisor 'lose' an incident by leaving it in PENDING_EVIDENCE?"	PENDING_EVIDENCE has a maximum dwell of 7 calendar days ; auto-escalation to Plant Manager thereafter.
"What if a CLOSED case needs to be reopened?"	A REOPENED transition is permitted from CLOSED only, with mandatory justification; it is logged as a new audit event but preserves the original case ID.
"What if a reporter never syncs an offline report?"	§8.4 covers this explicitly with an MNO-aware stale-state alert.
"What about a power user spamming low-quality reports?"	§6.4 introduces a reporter-quality score, not a punitive blocklist.
"What if CAPA verification fails or is rejected?" (v1.2 NEW)	A failed VERIFICATION triggers a controlled rejection-loop back to CAPA_EXECUTION (§2.4); the rejection must carry a mandatory free-text reason (enforced by <code>approval_event.comment</code> , §2.5 / §12.1.10) and is logged as an <code>approval_event</code> with <code>action = REJECT</code> . The <code>investigation_checklist_progress</code> (12.1.9) row is rewritten — never deleted — so the failed verification is part of the immutable history. A CAPA that has been rejected more than twice auto-escalates via rule E-9 (§7.3) and flags the case as a Repeat-Failure CAPA in the Compliance Dashboard; closure is forbidden until a fresh RCA sign-off is obtained.

2.4 Post-Triage Operational Stages (v1.2 NEW)

The lifecycle stages added in v1.1 cover the **submission-to-resolution** path. In practice, factory incidents that meet a minimum severity threshold (configurable; default **L2 and above** OR `business_impact.estimated_loss_usd > Financial Escalation Threshold`) progress through a **post-triage operational pipeline** before closure:

```
IN_PROGRESS → INVESTIGATION → RCA_REVIEW → CAPA_EXECUTION → VERIFICATION → CLOSED
                ↘                ↘
                (RCA rejected)  (CAPA verification failed)
                ↘                ↘
                back to INVESTIGATION  back to CAPA_EXECUTION
                (with mandatory      (with mandatory
                 rejection comment,   rejection comment,
                 §2.5)                §2.5 + E-9 if >2 loops)
```

Stage	State Code	Definition	Default Owner	Default SLA
Investigation	INVESTIGATION	Investigation lead gathers facts, evidence, witness statements against a checklist (e.g., "5-Whys", "Fishbone", "Interviews", "Evidence capture", "Photographic documentation", "Physical inspection", "Data pull", "Peer review"). Checklist items ticked in <code>investigation_checklist_progress</code> (§12.1.9).	Investigation Lead (typically the Resolver)	[Default] 24h (§4.5)

RCA Review	RCA_REVIEW	Root-Cause Analysis document is drafted and routed for multi-stage approval (\$2.5). RCA is reviewed against quality criteria (5-Whys depth, evidence linkage, contributing-factor coverage).	RCA Author (Resolver); Compliance + Plant Manager sign-off	[Default] 72h total (draft + review)
CAPA Execution	CAPA_EXECUTION	Corrective Actions (immediate) and Preventive Actions (long-term) are implemented. Tasks tracked against a CAPA checklist; each task closure is logged.	CAPA Owner (Resolver)	[Default] 72h (\$4.5)
Verification	VERIFICATION	Independent verification that CAPA actions are effective (e.g., reinspection, follow-up audit, KPI delta measurement). Verification may reject back to CAPA_EXECUTION if ineffective (\$2.3 GrillMe row).	Compliance Officer (independent verification)	[Default] 48h for verification; rejection loop is unconstrained in
Stage	State Code	Definition	Default Owner	Default SLA
				count until fresh RCA is required

2.4.1 Stage Entry & Exit Conditions

Entered When

Stage			Exited When
INVESTIGATION	Case is in IN_PROGRESS AND (severity ≥ L2 OR estimated_loss_usd > threshold OR severity hint + reporter mode suggest formal investigation)		All checklist items completed = true (100% tick)
RCA_REVIEW	INVESTIGATION	checklist reaches 100%	Approval event action = APPROVE for RCA_SIGNOFF (\$2.5)
CAPA_EXECUTION	RCA is approved		All CAPA checklist items completed = true
VERIFICATION	All CAPA tasks closed		Approval event action = APPROVE for CAPA_VERIFICATION (\$2.5)
RESOLVED (auto)	Verification approved		Immediately transitions to closure review (\$14 Activity 7)

Engine-Level Guard. The state machine (§2.2) is enforced server-side. **CAPA_EXECUTION** cannot begin without an **approval_event** row with **action** = **APPROVE** and **approval_stage** = **RCA_SIGNOFF**. Likewise, **RESOLVED** cannot fire without an **approval_event** row for **CAPA_VERIFICATION** = **APPROVE**. These checks are at the **API layer** and verified by an automated test in CI (AC-INV-04, §15).

2.4.2 Audit-Loggable Activity Rule

Every entry into **INVESTIGATION** triggers a new **case_state_log** event with **metadata_json.event_subtype** = "**INVESTIGATION_STARTED**". Every checklist tick is mirrored into **case_state_log** as **metadata_json.event_subtype** = "**CHECKLIST_PROGRESS**" (§12.1.9). This makes the entire post-triage path visible in the standard case timeline and to standard audit queries.

2.4.3 Investigation Methodology Auditability (v1.2 NEW — Enhancement)

To ensure that **how** a Root-Cause Analysis was conducted is just as auditable as **what** the conclusion was, every case that enters **INVESTIGATION** MUST capture the **Investigation Methodology Used** as a first-class, required, auditable field. The methodology is selected by the Investigation Lead (typically the Resolver) at the moment of first checklist tick and is **locked** once the case transitions out of **INVESTIGATION**. Any subsequent change of methodology requires a new **case_state_log** event with **metadata_json.event_subtype** = "**INVESTIGATION_METHODODOLOGY_CHANGED**" and a mandatory rationale comment of length ≥ 10 characters.

Methodology Code	Methodology Name	When to Use (Indicative)	GrillMe Rationale
FISHBONE	Fishbone (Ishikawa) Diagram	Multi-cause incidents with cross-functional contributing factors (Man, Machine, Material, Method, Measurement, Environment)	Forces explicit consideration of contributing-factor categories; required by customer-audit playbook for ≥ L3 cases.
FIVE_WHYS	5-Whys	Single-fault, sequential-cause incidents	Lightweight; appropriate for L2/L3 cases where a single root cause is dominant.
FAULT_TREE	Fault Tree Analysis (FTA)	High-severity (L1/L2) cases with potential cascadingfailure paths	Quantitative; preferred when rule E-8 has fired and the loss exceeds the High-Value CAPA Threshold (configurable; default USD 10,000).
TIMELINE	Timeline / Chronological Reconstruction	Sequential incidents where time-ordering is the dominant evidence (e.g., equipment failure sequence)	Required when the incident involves IoT/SCADA telemetry (see §8 offline-telemetry references).
CHANGE_ANALYSIS	Change Analysis (Preevent vs. Post-event delta)	Incidents triggered by a recent change (process, equipment, personnel, material)	Required when the case is opened within 14 days of a documented change-control event.

PARETO	Pareto Analysis	Recurring-incident clusters (3+ similar in 7d)	Required for cases linked to a <code>case_cluster</code> row (§4.4 mass-incident).
OTHER	Other (free-text justification mandatory)	Methodology not in the canonical list	Free-text justification of length ≥ 50 characters is mandatory; reviewed weekly by Compliance Officer.

Governance Rule (binding). The `investigation_methodology_used` field is **required** on every `investigation_checklist_progress` row (§12.1.9) and on the first `approval_event` row of stage `RCA_SIGNOFF` (§12.1.10). Absence of the field is enforced at the API layer (HTTP 422) and at the DB layer (CHECK constraint). The methodology is also surfaced in the **Compliance Dashboard** as a filterable dimension on the Investigation Aging view.

Binding Clause — OTHER Rationale Floor. When `investigation_methodology_used` = "OTHER", a companion free-text `methodology_rationale` field is **mandatory** and **MUST** contain **at least 50 characters** of substantive justification (no boilerplate, no whitespace padding, no "see above" cross-references). The character count is enforced at the API layer (HTTP 422 `METHODOLOGY_RATIONALE_TOO_SHORT` when length < 50 after trimming) and at the DB layer (CHECK constraint `char_length(trim(methodology_rationale)) >= 50` when `investigation_methodology_used` = 'OTHER'). When `investigation_methodology_used` is any value other than `OTHER`, the `methodology_rationale` field is optional. Compliance Officer reviews the count of `OTHER` selections and the rationale quality weekly (§12.3 GrillMe row).

Audit-Trail Linkage (binding mirroring). Every methodology selection — including initial selection, change of methodology, and `OTHER` rationale capture — is **mirrored into** `case_state_log` as an auditable activity using the following `metadata_json.event_subtype` taxonomy:

<code>metadata_json.event_subtype</code>	Trigger	Required <code>metadata_json</code> Fields
<code>INVESTIGATION_METHODODOLOGY_SET</code>	First selection at first checklist tick of <code>INVESTIGATION</code>	<code>methodology_used</code> , <code>actor_id</code> , <code>methodology_rationale</code> (when <code>OTHER</code>)
<code>INVESTIGATION_METHODODOLOGY_CHANGED</code>	Subsequent change of methodology while case remains in <code>INVESTIGATION</code>	<code>methodology_used</code> (new), <code>prior_methodology_used</code> , <code>actor_id</code> , <code>change_reason</code> (≥ 10 chars)
<code>INVESTIGATION_METHODODOLOGY_LOCKED</code>	Case transitions out of <code>INVESTIGATION</code> (entry into <code>RCA_REVIEW</code>)	<code>methodology_used</code> (final), <code>actor_id</code>

The mirroring is performed by a DB-level trigger on `investigation_checklist_progress` (inserted/updated rows with `item_index` = 1 or with `investigation_methodology_used` differing from the prior row) and by a corresponding engine-level hook on the stage-transition guard (§2.2). The mirrored events are queryable through the `vw_investigation_methodology_30d` materialized view (added to §12.2) and are bundled into the **Case Audit Trail** regulator export (R-AU-01, §11.3) without requiring a separate report.

GrillMe Rationale. Without a methodology field, a reviewer cannot distinguish a rigorous 5-Whys analysis from a one-line "root cause: operator error" assertion. Mandating methodology classification forces the Investigation Lead to declare the analytical lens and creates a comparable evidence base across cases — a nonnegotiable posture for any compliance audit (BSCI, SA8000, customer-specific).

2.5 Approval Governance (v1.2 NEW)

The post-triage operational pipeline (§2.4) requires **multi-stage approval** at three points:

Approval Stage	Stage Triggered	Approvers	RACI (§14.3)
<code>RCA_SIGNOFF</code>	End of <code>RCA_REVIEW</code>	Plant Manager (operational A) + Compliance Officer (review A)	Activity 14
<code>CAPA_VERIFICATION</code>	End of <code>VERIFICATION</code>	Plant Manager (operational A) + Compliance Officer (verification A)	Activity 16
<code>CASE_CLOSURE</code>	End of <code>RESOLVED</code>	Plant Manager + Compliance Officer	Activity 7 (already in v1.1)

2.5.1 Mandatory Approval Rules

- Dual-control.** Each stage requires **two** approval events from two distinct named individuals, one of whom is the Compliance Officer (for `RCA_SIGNOFF` and `CAPA_VERIFICATION`) or the Plant Manager (for `CASE_CLOSURE`). Same-individual double-approval is rejected at the API layer.
- Mandatory rejection comment.** An approval event with `action` = `REJECT` or `action` = `REQUEST_CHANGES` **must** include `comment` of length ≥ 10 characters. Enforced at the API (HTTP 422) and at the DB layer (CHECK constraint on `approval_event`).
- AI-summary linkage.** When an approval decision was informed by an AI summary (§9.8), the approving user must include `validated_by_user_id` pointing to the user who validated the AI output before this approval. AI-only decisions are **prohibited** by default (§9.8).
- Audit immutability.** `approval_event` (§12.1.10) is INSERT-only at the DB role level. No UPDATE or DELETE is permitted. Audit-trail integrity is enforced by §12.3 GrillMe rows.
- Sequencing.** Approvals must follow the pipeline order: `RCA_SIGNOFF` cannot fire before `INVESTIGATION` is complete; `CAPA_VERIFICATION` cannot fire before `CAPA_EXECUTION` is complete; `CASE_CLOSURE` cannot fire before `CAPA_VERIFICATION` = `APPROVE`.

2.5.2 Rejection Routing

When an approval is `REJECT` or `REQUEST_CHANGES`:

- `RCA_SIGNOFF REJECT`** → Case routes back to `INVESTIGATION` (§2.3 GrillMe row). Compliance Officer reviews the rejection reason and either: (a) reopens with new checklist items, or (b) escalates to Plant Manager for guidance. The fresh RCA must be re-signed-off.
- `CAPA_VERIFICATION REJECT`** → Case routes back to `CAPA_EXECUTION`. If this is the **second or later** rejection of the same CAPA, rule **E-9** fires (§7.3) and the case is flagged **Repeat-Failure CAPA**. After **two rejections**, a fresh RCA sign-off is required (i.e., the case loops back to `INVESTIGATION` and a new RCA must be drafted).

- **CASE_CLOSURE REJECT** → Case returns to **RESOLVED** for re-work. SLA clock is **not** reset; this is logged as a **Repeat-Closure-Rejection** event and surfaces in the

Reopened Incident Rate KPI (§17.2). **2.5.3 Approval Audit Trail Pattern** `approval_event` follows the `identity_access_audit` pattern (§9.5):

- INSERT-only at DB role level.
- Reviewed quarterly by Compliance Officer.
- Retained for the life of the company + 7 years (per Master PRD).
- Partitioned monthly for query performance.

Every approval is queryable via `vw_approval_trail_case(case_id)` materialized view (refreshed hourly, added to §12.2 implicitly through the existing derived-views pattern).

2.5.4 GrillMe Hardening — Approval Governance

Challenge Raised	Resolution
"What if a Plant Manager refuses to co-sign because they disagree with Compliance's RCA review?"	The case is blocked at the engine level until both As sign off. Compliance's review-A and Plant Manager's operational-A are independent; either may reject. The disagreement is documented in <code>approval_event</code> rows and is reviewed at the next ExCo.
"What if a Compliance Officer attempts to selfapprove Activity 16 (verification) AND then Activity 17 (closure sign-off)?"	The SoD check (§14.5 v1.2 GrillMe row) excludes the Activity-16 Compliance Officer from the Activity-17 cosigner slot for the same case. Enforced at the API layer.
"What if the rejection comment is 'see attached' with no detail in the comment field itself?"	The DB-layer CHECK constraint requires <code>comment</code> of length ≥ 10 characters <i>in the <code>approval_event</code> row itself</i> . Attachments may be referenced by URL in <code>source_artifact_ref</code> but the comment must stand alone.
"What if the network drops mid-approval and the approval event is half-written?"	<code>approval_event</code> writes are atomic (NFR-REL-01). A dropped connection results in zero rows committed, and the UI prompts re-submission. The approver's intent is captured client-side and replayable.
"What if the AI summary (§9.8) is the only basis for an approval?"	The approval is rejected at the API layer with HTTP 422 and message "AI-only approvals require a <code>validated_by_user_id</code> ; human validation is mandatory."

3. Reporting & Evidence Visibility

3.1 What Management Can See (Manual Reports)

For **manual (login-based) reports**, supervisors and compliance officers have full read access to:

- Reporter identity, role, department, and shift
- All 14 form fields (Section 6 of Epic 1)
- All uploaded media: photos (up to 10), audio memos, videos (up to 30s)
- Voice-to-text transcripts
- Auto-captured metadata: GPS lat/long ($\pm 10m$), timestamp (server + device), device ID, app version, network type
- Lifecycle events (§2)

3.2 What Management Can See (Anonymous Reports)

For **anonymous reports**, the system must guarantee:

- The reporter's login identity, employee ID, device ID, and IP address are **never stored or displayed** to any user role.
- Only the auto-captured device metadata (model, OS version, app version) is retained for technical triage.
- A **legal-access-only** escrow exists for the rare case where a court order compels identity disclosure (see §9.4).

3.3 What Management Can See (Confidential Reports)

For **confidential reports**, the reporter is identified in the audit log but visibility is restricted:

- Plant Manager and Compliance Officer can see identity and content.
- Supervisors see **content only**, with reporter identity masked as "Reporter A".
- Identity unmasking is an audited, role-gated action (§9.5).

3.4 Evidence Integrity

Requirement	Specification
Chain of custody	Every view, download, or share of an evidence artifact is logged with actor, timestamp, and purpose code.
Tamper evidence	Evidence artifacts are stored with SHA-256 hash; any access recomputes and logs the hash.
Retention	Media retained for case life + 1 year; then archived to cold storage with hash manifest.
Export	Compliance Officer can export an evidence package (PDF report + media zip + audit trail) for legal.
Watermarking	All exports carry a digital watermark: "CONFIDENTIAL — iFar-Silexa (Pvt.) Ltd. — Case [ID] — Exported by [Name] on [Date]"

3.5 GrillMe Hardening — Evidence Visibility

Challenge Raised	Resolution
"A malicious supervisor could leak an evidence photo to social media — how is that detected?"	All exports and screen-grab-risky views (e.g., full-resolution photo access) require a purpose code selected from a fixed list and are subject to weekly anomaly review.
"What if a 'rejected' report was actually valid, and we destroyed the evidence?"	Rejected reports are archived, not deleted , with the rejection reason logged. They can be reopened on appeal.
"Can a reporter delete a photo after submission, claiming they didn't upload it?"	No. Post-submission, only appending evidence is permitted; existing artifacts cannot be removed.
"What if the GPS reading is clearly wrong (e.g., another city)?"	The system flags GPS plausibility (within N km of plant geofence); flag does not block submission but is visible to the triager.
Challenge Raised	Resolution
"Can a manager see the reporter's other reports, enabling itself retaliation patterns?"	No. Cross-incident visibility of a single reporter is restricted to Compliance Officer only, and is logged.

4. Response Time & Delay Tracking

4.1 Clock Definitions

Clock	Starts	Stops	Resets?
Triage Clock	SUBMITTED	TRIAGED	No
Assignment Clock	TRIAGED	ASSIGNED	No
Resolution Clock	ASSIGNED	RESOLVED	Yes, only on legitimate state change (e.g., re-assignment adds 50% of remaining time, never extends beyond original SLA)
Idle Clock	Any state where no event is logged for X hours	Next state transition	Resets on any logged activity
End-to-End Clock	SUBMITTED	CLOSED	No — single source of truth for cycle time

4.2 Standard SLA Targets (Defaults)

Severity	Triage SLA	Assignment SLA	Resolution SLA
L1 — Life-threatening / Fire / Major chemical	≤ 15 min	≤ 30 min	≤ 4 hours
L2 — Serious injury / Equipment damage > PKR 500K	≤ 1 hour	≤ 2 hours	≤ 24 hours
L3 — Minor injury / Near-miss / Property damage	≤ 4 hours	≤ 8 hours	≤ 72 hours
L4 — Observation / Suggestion / Process improvement	≤ 24 hours	≤ 48 hours	≤ 14 days

These targets are **configurable** per §7.

4.3 Unassigned & Idle Handling

- If a report remains in **SUBMITTED** with no triage action for **2 hours**, it is auto-flagged **UNASSIGNED_URGENT** and pushed to the Plant Manager's dashboard. If
- **ASSIGNED** with no logged activity for **25% of the resolution SLA** (e.g., 6 hours for an L2 with 24h SLA), the owner receives a nudge; if 50% is reached, their supervisor is cc'd.
- If **PENDING_EVIDENCE** exceeds **7 calendar days**, Plant Manager is notified.
- (v1.2 NEW) If a case sits in **INVESTIGATION** with **no checklist progress logged** for 25% of the Investigation SLA (§4.5), the Investigation Lead is nudged and rule **E-7** is armed (§7.3). If the 50% threshold is reached, the Plant Manager is cc'd. If the 100% threshold is reached without the checklist reaching 100%, rule **E-7** fires (§7.3).
- (v1.2 NEW) If **CAPA_EXECUTION** exceeds the CAPA SLA (§4.5), rule **E-9** fires (§7.3) and the case is flagged as **Overdue CAPA** on the Compliance Dashboard. 4.4

GrillMe Hardening — Time Tracking

Challenge Raised	Resolution
------------------	------------

"What if the server clock drifts relative to the device clock?"	All SLA times are computed from server timestamps at state transition; device time is stored but never authoritative.
"What if a report is filed at 23:55 and SLA starts immediately across the night shift?"	An operational-hours-aware SLA mode is supported: e.g., resolution SLA pauses during plant shutdown windows. Configurable per §7.
"What about mass-incident events (e.g., a chemical leak) generating 50 L1 reports at once?"	A mass-incident clustering rule groups related reports (same GPS, same time window) under a parent incident; SLA is measured on the parent.
"Could a supervisor 'pause' their own clock by repeatedly moving the report to PENDING_EVIDENCE?"	Yes — mitigated by the 7-day cap and by tracking PENDING_EVIDENCE frequency per owner (§5.4).
"What if the SLA is missed by 1 minute due to a network blip?"	A 5-minute grace window is applied to non-L1 severities; L1 has no grace.
"What about partial offline sync (§8)?"	A report that took 3 hours to sync still has its SUBMITTED time recorded as the original device timestamp so reporters are not penalized for offline resilience.

4.5 Investigation & CAPA SLAs (v1.2 NEW)

This section defines the **post-triage operational SLAs** for the lifecycle stages added in §2.4. These SLAs are **additive** to the v1.1 SLAs in §4.2; they do **not** modify L1–L4 triage/assignment/resolution targets.

4.5.1 Default SLA Targets (v1.2 Post-Triage Stages)

Stage	State Code	Default SLA	Configurable?	Clock Definition
Investigation	INVESTIGATION	[Default] 24 hours	Yes — [Configurable] per §18.3; expose to Compliance Officer	Starts on entry into INVESTIGATION; stops on checklist completion (100%) or stage exit. Subject to operational-hours pause (§4.4).
RCA Sign-Off	RCA_REVIEW (subclock)	[Default] 48 hours for review (independent of the 72h Investigation–CAPA total budget)	Yes	Starts on entry into RCA_REVIEW; stops on first approval_event for RCA_SIGNOFF (whether APPROVE, REJECT, or REQUEST_CHANGES).
CAPA Execution	CAPA_EXECUTION	[Default] 72 hours	Yes	Starts on entry into CAPA_EXECUTION; stops on CAPA checklist completion. Triggers rule E-9 (§7.3) on breach.
CAPA Verification	VERIFICATION	[Default] 48 hours for independent verification	Yes	Starts on entry into VERIFICATION; stops on approval_event for CAPA_VERIFICATION.
Investigation→Closure	(composite)	[Default] 5 calendar days (24h Investigation + 48h RCA Review +	Yes	4.5.2 Checklist Progress as an Audit-Loggable Activity End-to-end composite budget surfaced on the Compliance Dashboard as "Days in PostTriage".
Total Budget		72h CAPA + 48h Verification, with overlap buffers)		

The Investigation Checklist (e.g., 8 items) is surfaced in the UI as a progress indicator (e.g., "3/8"). Each tick of an item creates a new row in `investigation_checklist_progress` (§12.1.9). Per the §12.1.9 audit rule:

Audit-Loggable Activity Rule. Every row in `investigation_checklist_progress` is **automatically mirrored** into `case_state_log` as a virtual event with `metadata_json.event_subtype = "CHECKLIST_PROGRESS"` and `metadata_json.checklist_progress = "3/8"` (snapshot at the time of the tick). This makes checklist progress visible in the standard case timeline, in audit-trail queries, and in regulator-facing exports (§11 R-AU-01).

4.5.3 SLA Pause / Resume Rules

Pause Condition	Effect	Resume
Operational-hours pause (§4.4)	All post-triage clocks pause	Resumes at the start of operational hours
Awaiting reporter clarification	INVESTIGATION clock pauses	Resumes when reporter responds or 48h max
Awaiting third-party (e.g., equipment vendor)	CAPA_EXECUTION clock pauses	Resumes when third-party signal received or 7-day cap
Mass-incident cluster (§4.4)	Investigation pause for child cases	Resumes when parent cluster un-pauses

4.5.4 GrillMe Hardening — Investigation & CAPA SLAs

Challenge Raised	Resolution
------------------	------------

"What if the Investigation SLA is missed because the checklist is unreachable (e.g., a witness is unreachable)?"	The Investigation clock pauses (not resets) when an item is blocked by an external dependency, capped at 48h per item. The pause is logged as a <code>case_state_log</code> event with <code>metadata_json.event_subtype = "INVESTIGATION_PAUSE"</code> .
"What if the CAPA Execution SLA is missed but the action is genuinely in flight?"	Rule E-9 fires once at the breach, but if the CAPA Owner logs substantive progress (e.g., a checklist item ticked) within the next 4 hours, the alert is auto-resolved. The CAPA still completes within the original SLA unless a formal pause is granted via §4.5.3.
"What if checklist ticks are spammed to game progress (e.g., auto-ticking every item to clear the SLA)?"	The Compliance Officer reviews a per-owner checklist-tick-rate weekly. Anomalous tick rates (e.g., 8 items ticked in 30 seconds) are flagged for review. The un-tick path (§12.3 GrillMe) preserves history so a reviewer can roll back.
"What if the 24h Investigation SLA is too aggressive for low-severity cases?"	The 24h default applies to L2+ cases meeting the §2.4 entry criteria. L3/L4 cases are not required to enter INVESTIGATION and proceed straight to RESOLVED (i.e., the post-triage pipeline is opt-in for high-severity cases).
"What if the 5-day composite budget is breached?"	The case is flagged on the Compliance Dashboard with Composite SLA Breach . Rule E-9 escalation rules apply (CAPA overdue) and the case becomes ineligible for the "Clean Closure" KPI bucket.

5. Responsibility Tracking Model

5.1 Assignment Modes

Mode	Behavior
Manual	Triager picks a named owner from a role roster.
Rule-based	System suggests an owner based on incident category, location, and shift roster; triager confirms.
Auto	L1 (life-threatening) reports bypass triage and auto-assign to on-duty EHS + Plant Manager.

5.2 Ownership Visibility

Every active incident has **exactly one** primary owner. The system displays:

- Primary owner (name, role, shift)
- Secondary owner (CC, read-only by default)
- Escalation chain (up to 3 levels deep)

5.3 Re-assignment Audit

Every re-assignment event is logged with:

- From-owner, to-owner
- Reason code (from a fixed list)
- Reporting officer
- Timestamp

A reassignment does **not reset** the resolution clock (§4.1).

5.4 Owner Performance Metrics (Aggregated, Not Punitive)

The system computes per-owner metrics **for development feedback, not for individual performance review**:

- Average resolution time (last 30 / 90 days)
- Reassignment rate (proxy for clarity issues)
- PENDING_EVIDENCE dwell frequency
- SLA compliance rate

Governance Principle: These metrics are surfaced to the **owner and their manager only**, never to peers, and never to a ranking/league-table view. The aim is to identify training needs, not to create a punitive environment that erodes reporting culture (Epic 1 §1).

5.5 GrillMe Hardening — Responsibility

Challenge Raised	Resolution
"What if the named owner goes on leave mid-incident?"	Re-assignment to a coverage proxy is auto-suggested when the owner has no logged activity in 4 hours AND is on the HR leave calendar.
"What if no qualified owner is available?"	The system escalates to the next level in the escalation chain and logs a "skill-gap" event for HR planning.

"What if a manager dumps low-severity work on a junior to game their own metrics?"	Per-owner metrics include a difficulty-weighting factor (e.g., an L1 carries more weight than an L4), preventing metric gaming.
"What about anonymous reports — how is ownership visible if the reporter is unknown?"	Owner is always a <i>named employee</i> (the responder), never the reporter; anonymity does not change accountability for response.

6. Incident Status Monitoring

6.1 Real-Time Status Board

A continuously-updated status board is rendered for the Plant Manager and Shift Supervisors. The board shows:

- Open incidents by severity (L1, L2, L3, L4)
- SLA-breadown (green / amber / red) per incident
- Owner and current state
- Time in current state

Refresh cadence: **30 seconds** for L1/L2; **5 minutes** for L3/L4.

6.2 Status Change Notifications

Every state transition generates a notification (§13). Status changes are also visible in the mobile app for the assigned owner and any watcher.

6.3 Stale State Detection

The system actively identifies "stale" reports:

- **Definition:** A report is stale if no state transition or activity log entry has occurred in **50% of the remaining SLA** for its current state.
Action: Stale incidents are visually flagged on the status board and trigger a nudge to the owner + their supervisor.

6.4 Reporter Quality Score

To detect and gently correct low-quality reporting without discouraging submission:

- Quality factors: completeness of fields, presence of evidence, geolocation accuracy, severity-vs-actual-impact calibration (post-resolution).
- Score is **never shown to the reporter**; it is used only to surface a "complete your report" hint on the *next* submission.
- **No punitive blacklist.** A reporter with a low score still has full submission rights.

6.5 GrillMe Hardening — Status Monitoring

Challenge Raised	Resolution
"What if the status board itself goes down?"	The status board is read-only; the system of record is the case state machine. A board outage does not affect operations.
"How do we avoid alert fatigue?"	Notification deduplication: a single state change produces at most one notification per recipient per 5 minutes.
"What if two supervisors disagree on severity?"	Severity can be revised during triage; the final triage severity is what drives SLA. The revision is logged.
"What about duplicate reports (two people report the same incident)?"	Duplicate detection uses time + GPS + category clustering; the second report is auto-linked to the parent case but the reporter is acknowledged.

7. Configurable SLA & Escalation Management

7.1 Why Configurable?

The defaults in §4.2 are starting points. Real operations require:

- Per-category SLAs (e.g., fire is faster than housekeeping)
- Per-shift SLAs (night shift may have longer triage windows)
- Per-event SLAs (plant shutdown, drill periods)
- Per-facility SLAs (if iFar-Silexa expands)

7.2 Configuration Surfaces

Surface	Owner	Approval
Default SLA matrix	Compliance Officer	Plant Manager
Category-specific overrides	Plant Manager	COO
Shift-specific overrides	Plant Manager	HR
Event-specific (e.g., shutdown)	Plant Manager	EHS + Operations
Drill / table-top mode	Compliance Officer	Plant Manager

All changes are **versioned**; the system retains the SLA matrix that was active *at the time of submission* for every case. This prevents retrospective SLA manipulation.

7.3 Escalation Rules Engine Escalations are rules of the form:

```
WHEN <state-condition>
AND <time-condition>
AND <owner-condition>
THEN notify <role-1> [cc <role-2>]
AND log event "ESCALATION_FIRED"
```

Default escalation rules:

Rule	Condition	Action
E-1	SUBMITTED > 2h, no triage	Notify Plant Manager; cc EHS
E-2	L1 unassigned > 15 min	Auto-page on-duty EHS + Plant Manager (push + SMS)
E-3	Resolution SLA exceeded	Notify owner + supervisor; cc Plant Manager
E-4	Reassignment > 3 within 24h on same case	Notify Compliance (possible routing issue)
E-5	Anonymous report with no triage in 4h	Notify Compliance Officer directly
E-6	Same category, same GPS, 3+ reports in 1h	Cluster + escalate to Plant Manager (pattern signal)
E-7 (v1.2 — also referenced by §22.2 for dispute pickup)	DISPUTE_RAISED > 24h with no transition to DISPUTE_UNDER_REVIEW , OR INVESTIGATION with no checklist progress at 50%/100% of Investigation SLA (per \$4.3 / \$4.5)	Notify Compliance Officer + Plant Manager (push + email); for Investigation stalls, also nudge Investigation Lead
E-8 (v1.2 NEW — Financial Escalation)	business_impact.estimated_loss_usd > Financial Escalation Threshold (configurable per §18.3; default PKR 1,000,000 / USD-equivalent [Default] PKR 1M ⇒ USD 3,572 at fixed reference rate, exposed to business tuning per §7.2)	Notify CFO + COO + Plant Manager (push + email + flagged on Executive Dashboard as "Financial Escalation — open")
Rule	Condition	Action
E-9 (v1.2 NEW — Overdue CAPA)	CAPA_EXECUTION exceeds CAPA SLA (\$4.5) OR a VERIFICATION rejection has been re-opened to CAPA_EXECUTION more than twice without closure	Notify Compliance Officer + Plant Manager (push + email); flag case as Overdue CAPA on Compliance Dashboard; emit KPI "CAPA Completion Rate" denominator increment (§17.2).

7.4 GrillMe Hardening — SLA & Escalation

Challenge Raised	Resolution
"What if the on-duty EHS is unreachable (offline, off-shift)?"	E-2 has a fallback chain : on-duty EHS → backup EHS → Plant Manager → COO. Failures cascade, never silently drop.
"Can a Plant Manager mute escalations to avoid them?"	No. Escalation rules cannot be muted at user level. They can only be temporarily paused by Compliance Officer with a documented reason, and the pause itself is logged.
"What about timezone changes / DST?"	All timestamps are stored in UTC; display in PKT. SLA calculations are TZ-naive.
"What if a config change retroactively invalidates a closed case?"	Closed cases are bound to the SLA matrix version active at submission; re-running a closed case under a new matrix is permitted only for <i>analytical</i> purposes, not for SLA breach flagging.

8. Offline Reporting & Sync Failure Monitoring

8.1 Why This Is a First-Class Concern

The Epic explicitly requires offline resilience. The governance risk is the inverse: **offline is invisible to management**. A report drafted at 14:00 and synced at 21:00 must not be treated as a 21:00 report, but management must *know* that offline reports exist and that they are flowing.

8.2 What Is Captured Offline

Per Epic 1 §3.5: the app stores drafts and submitted reports locally, with all media, until sync succeeds. For monitoring, the system tracks:

- **pending_drafts** — count of unsubmitted drafts on devices in the fleet
- **pending_submissions** — count of submitted-but-not-synced reports on devices in the fleet
- **last_sync_at** — per-device timestamp
- **sync_queue_age** — age of oldest pending submission in queue

8.3 Sync Health Dashboard

A dedicated **Sync Health** view shows:

Metric	Source	Alarm Threshold
Devices with <code>last_sync_at</code> > 24h	Mobile → Server heartbeat	> 5% of fleet
<code>pending_submissions</code> total	Mobile → Server	> 10 in fleet
<code>pending_submissions</code> age (oldest)	Mobile → Server	> 48h
Sync failure rate (last 24h)	Server logs	> 2% of attempts
Partial sync failures	Server reconciliation (§8.5)	> 0

8.4 MNO-Aware Stale-State Alerts

Network conditions in factory zones can be inconsistent. The system distinguishes:

- **No network available** (MNO down, no Wi-Fi) — expected, not an alarm
- **Network available but sync failing** (auth error, server-side 5xx, certificate issue) — **alarm** at IT-Ops level
- **Stale queue due to user dismissals** — alarm at user-training level

8.5 Partial Sync Failure Handling (GrillMe Hardening)

This is a **non-obvious failure mode** identified during review: a sync that completes for the report record but **fails on one or more media artifacts** (e.g., photo uploads succeeding, audio failing due to size).

Scenario	Behavior
Report record synced, all media synced	Normal — <code>SUBMITTED</code> on server
Report record synced, partial media synced	Report enters <code>SUBMITTED</code> with <code>media_partial = true</code> ; triager sees "evidence incomplete" badge; sync is retried automatically for 72h
Report record synced, no media synced	Report enters <code>SUBMITTED</code> with <code>media_missing = true</code> ; auto-nudge to reporter when next online
Report record failed, media succeeded	Report held in queue; record is the source of truth, so this is logged but not a duplicate
Full sync failure (network/auth)	Standard retry with exponential backoff; 72h persistence on device

A **reconciliation job** runs hourly server-side: for every `SUBMITTED` record, verify the expected set of media artifacts is present. Discrepancies produce a `RECONCILIATION_DRIFT` event visible to IT-Ops.

8.6 GrillMe Hardening — Offline

Challenge Raised	Resolution
"What if a device is lost/stolen with 10 unsynced reports?"	All local data is encrypted at rest (per Epic 1 §3.5). Remote wipe (MDM) is supported for enrolled devices.
"What if a reporter intentionally never syncs?"	The device-side <code>pending_submissions</code> count is visible to the reporter as a banner; after 7 days unsynced, the system prompts on every app open. After 30 days, the report is still preserved (durable) but flagged for IT-Ops review.
"What about time skew between devices?"	All <code>SUBMITTED_LOCAL</code> timestamps are <i>device</i> time, labeled as such. Server time is authoritative for SLA, but the <i>display</i> shows the original device time so the reporter is credited correctly.
"What if two devices submit nearidentical reports offline and both sync?"	Server-side deduplication by (device_id, device_submission_uuid) prevents double-counting; content similarity is also checked.

9. Anonymous/Confidential Reporting Auditability

9.1 The Core Tension

The Epic defines anonymous and confidential reporting. The governance requirement is the inverse: an audit trail that satisfies a regulator or court **without** undermining the reporter's protection in the normal case.

9.2 Anonymous Mode — Design

Element	Treatment
Login	None — submission is unauthenticated.
Reporter ID in DB	None — no foreign key to user table.

Device ID	Hashed (one-way) and stored only for technical deduplication; not linked to user.
IP address	Stored hashed; rotated after 30 days.
GPS	Stored in full.
Content	Stored in full.
Reporter name in any view	Never. Even Compliance Officer cannot see a name — there is none to see.

9.3 Confidential Mode — Design

Element	Treatment
Login	Required.
Reporter ID	Stored in DB.
Reporter name visibility	Masked by default; visible only to Compliance Officer and Plant Manager, and only with explicit unmask action.
Content visibility	Supervisors see content but with reporter identity masked.

9.4 Identity Escrow (Legal Compulsion)

In the rare case of a court order, lawful regulator demand, or life-threatening safety event requiring law enforcement:

- A **named role** (Compliance Officer) initiates an identity-unmask request.
- The request requires a **purpose code** and a **document reference number** (court order ID, regulator letter ID, FIR number, etc.).
- The action is **co-signed** by the Plant Manager *or* the COO.
- The unmasking is logged in an **immutable identity-access audit log** (separate from the standard case log, write-only).
- The reporter is **not** automatically notified (this may compromise an investigation); the question of *when* to notify is handled by HR/Legal, not the system.

9.5 Identity Access Audit Log (GrillMe Hardening)

A dedicated, append-only audit log captures every read of any reporter-identifying information:

Field	Value
Log ID	UUID
Timestamp	Server time (UTC)
Actor	User ID, role, device
Action	VIEW_REPORTER_ID , UNMASK_CONFIDENTIAL , EXPORT_CASE , etc.
Case ID	The case affected
Field	Value
Purpose code	Selected from a fixed list
Document reference	Free text + (optionally) attachment reference
IP / session	Captured

This log is:

- **Immutable** — append-only, no UPDATE or DELETE permissions at the DB role level.
- **Reviewed** weekly by Compliance Officer; anomalies (e.g., a supervisor repeatedly viewing reporter identities) are investigated.
- **Retained** for the life of the company + 7 years (per Master PRD retention policy).

9.6 Anti-Retaliation Monitoring

The system supports anti-retaliation through *pattern detection* (not surveillance):

- Compliance Officer can run a report correlating: a) who filed which reports in the last 90 days, with b) HR actions affecting those reporters (shift changes, performance reviews, terminations).
- A **red-flag score** is computed, never displayed as a number; only as "patterns detected — review recommended".
- This is the **only** cross-incident reporter visibility permitted, and it is restricted to the Compliance Officer role.

9.7 GrillMe Hardening — Anonymity / Confidentiality

Challenge Raised	Resolution
"What if an anonymous reporter self-identifies in the report text (e.g., 'I, Ahmed, saw this')?"	The system does not block this — it is the reporter's choice. The triager is shown a "self-identified text detected" advisory, but the report is not auto-flagged.
"What if a confidential report's content itself identifies the reporter?"	The triager is shown the same "self-identified text detected" advisory.
"Can a manager with DB access bypass the audit log?"	No. Reporter-identifying columns are encrypted at rest with a key held by a separate security officer; DB access without unmask API does not reveal plaintext.
"What if the Compliance Officer themselves acts maliciously?"	Identity unmasking is dual-control (Compliance + Plant Manager OR Compliance + COO) and the immutable audit log is replicated to a separate storage tier that Compliance cannot write to.
"What about the right to be forgotten (where applicable)?"	Right-to-be-forgotten requests are handled by HR/Legal off-system; the system provides a redact_pii operation that anonymizes reporter-linked fields while preserving case-level analytics.

9.8 AI Output Governance — Human-in-the-Loop (v1.2 NEW)

The FactoryShield roadmap includes **AI-assisted summarization and insight generation** (e.g., AI-suggested RCA drafts, AI categorization hints, AI summarization of long incident descriptions, AI anomaly detection in `business_impact.estimated_loss_usd`). The governance posture is **Human-Validated by default**: AI outputs may inform a decision but **cannot independently make one**.

9.8.1 Default Posture

Default Rule. AI summaries used in **decision-making contexts** (RCA drafting, approval sign-off, severity suggestion, escalation triage, business-impact estimation) are **[Default] "Human-Validated"**. The `validated_by_user_id` field on the consuming record must reference the **named user** who reviewed the AI output before the action was taken. AI-only decisions are **prohibited**.

9.8.2 What Counts as a Decision-Making Context

A **decision-making context** is any of the following:

- Approval Event** — any `approval_event` row (§2.5, §12.1.10) with `action` ∈ {`APPROVE`, `REJECT`, `REQUEST_CHANGES`}. The approver's `validated_by_user_id` may equal the approver themselves **only** if the approver reviewed the AI summary in the same session (logged as `validation_method` = `"IN_SESSION_REVIEW"`).
- Severity Suggestion Override** — when an AI-suggested severity is **overridden** by the triager. The override is recorded in `case_state_log` with `metadata_json.event_subtype` = `"AI_SEVERITY_OVERRIDE"` and `metadata_json.validated_by_user_id`.
- RCA Draft Acceptance** — when an AI-drafted RCA is accepted (with or without edits) by the RCA author. The acceptance is logged with `metadata_json.event_subtype` = `"AI_RCA_ACCEPTED"` and `metadata_json.validated_by_user_id`.
- Business-Impact Estimation** — every write to `business_impact.estimated_loss_usd` (§12.1.12) that was **AI-assisted** must have `estimated_by` (a user) AND optionally `metadata_json.ai_assisted` = `true` with `metadata_json.validated_by_user_id` linking the estimator to the AI validator.
- Escalation Triage** — when AI suggests an escalation tier and the triager accepts it. Logged with `metadata_json.validated_by_user_id`.

9.8.3 Audit Logging

The `validated_by_user_id` is a **mandatory field** for AI-assisted decisions in decision-making contexts. The check is enforced at:

- API layer** — HTTP 422 with message "AI-assisted decision requires validated_by_user_id; human validation is mandatory per §9.8" when the field is missing.
- DB layer** — CHECK constraint on `approval_event` and `case_state_log.metadata_json` validation when `event_subtype` ∈ `AI_*`.
- Audit-review layer** — Compliance Officer weekly review of AI-assisted decisions (KPI "AI-Assisted Decisions Without Validation" must remain zero).

9.8.4 AI Output Storage

AI outputs that inform a decision are stored in an `ai_output` entity (added in §25.4 for completeness, but the field structure applies here):

Field	Type	Notes
<code>id</code>	UUID	PK
<code>case_id</code>	UUID	FK
<code>model_version</code>	string	e.g., "factoryshield-summarizer-v1.2"
<code>output_kind</code>	enum	<code>RCA_DRAFT</code> , <code>SUMMARY</code> , <code>CATEGORY_HINT</code> , <code>SEVERITY_HINT</code> , <code>BUSINESS_IMPACT_ESTIMATE</code> , <code>ANOMALY_FLAG</code>
<code>output_payload</code>	JSONB	The raw AI output
<code>generated_at</code>	timestamp	Server time
<code>consumed_by_decision_id</code>	UUID	FK → <code>approval_event.id</code> or <code>case_state_log.id</code>
<code>validated_by_user_id</code>	UUID	The user who validated the output before decision

Retention. `ai_output` rows are retained for 7 years per the Master PRD retention policy. They are append-only and are **never updated** after `validation_timestamp` is set.

9.8.5 GrillMe Hardening — AI Output Governance

Challenge Raised	Resolution
"What if the AI output is wrong and the user rubber-stamps it?"	The Compliance Officer reviews a per-user AI-acceptance-rate weekly. A user with > 95% AI acceptance rate triggers a "rubber-stamp review" — the user's role may be temporarily restricted from accepting AI suggestions without a second approver.
"What if the AI is unavailable and a user must decide without it?"	The system falls back to no-AI mode ; the absence of an <code>ai_output</code> row is itself acceptable. The decision does not require <code>validated_by_user_id</code> for the AI (because there is no AI). The audit log records <code>metadata_json.ai_assisted = false</code> .
"What if the AI hallucinates a regulatory citation?"	AI outputs are presented with explicit "AI suggestion — verify before acting" labels. Users cannot copy/paste AI text into official RCA documents without an explicit edit; the document version control flags unmodified AI text for the reviewer.
"What if a regulator demands proof that AI was used appropriately?"	<code>ai_output</code> + <code>validated_by_user_id</code> provide the audit chain. A pre-built regulator export report (R-AU-05, added in §24 for traceability) enumerates every AI-assisted decision in a period with the corresponding human validator.
"What if a user validates an AI output but their validation is later shown to be negligent?"	The <code>validated_by_user_id</code> is the named accountability for the validation. The system does not absolve the validator; if the validation is shown to be negligent in hindsight, the validator is on the hook per HR process. The validation cannot be undone.

10. Dashboard Views (Executive, Supervisor, Compliance)

10.1 Design Principles

- 1. **No more than 7 visual elements per dashboard.** Cognitive load is a governance risk.
- 2. **All KPIs are drill-down enabled** — clicking a number leads to the case list.
- 3. **All thresholds are color-coded** using a fixed palette: green (healthy) / amber (warning) / red (action required).
- 4. **All time filters default to "last 7 days"** with comparison to the previous 7 days.

10.2 Executive Dashboard

Audience: CEO, COO, CFO **Refresh:** Hourly **Primary Question:** "Are we safe and compliant?"

#	Element	Source	Notes
1	L1 open count	Real-time	Single most important number; red if > 0
2	SLA compliance % (30d)	\$4	Trend arrow vs. previous 30d
3	Total open incidents by severity	\$6	Stacked bar
4	Mean time to resolve (30d)	\$4	With target line
5	Reporter participation % (active reporters / total employees)	\$10.4	Adoption signal
6	Anonymous report share %	\$9	Trust signal
7	Open high-severity cases (drill-down list, max 10)	\$6	Owner, severity, age

Executive dashboard explicitly excludes individual reporter names, individual owner names, and confidential-report content. It is the safety + compliance view, not a people-management view.

10.3 Supervisor Dashboard

Audience: Plant Manager, Shift Supervisors **Refresh:** Every 30 seconds for L1/L2; 5 min for L3/L4 **Primary Question:** "What needs me right now?"

#	Element	Source	Notes
1	My open incidents (assigned to me)	\$5	With SLA bars
2	My team's open incidents	\$5	With SLA bars
3	Unassigned L1/L2 queue	\$4.3	Sorted by age
4	Stale incidents (>50% SLA consumed, no activity)	\$6.3	Sorted by severity
5	Reassignment requests pending my approval	\$5.3	Action queue
6	Sync health summary	\$8.3	For owned devices
7	Last 24h incident heatmap	\$3.1	By location

Audience: Compliance Officer, EHS Officer **Refresh:** Every 15 minutes **Primary Question:** "Are we audit-ready and is anyone at risk?"

#	Element	Source	Notes
1	SLA compliance matrix by category × severity	\$7	Heatmap
2	Anonymous + confidential report funnel	\$9	Submissions → triage → resolution
3	Identity-access audit log anomalies	\$9.5	Weekly summary view
4	Anti-retaliation pattern review queue	\$9.6	Manually triggered
5	Evidence export log (last 30d)	\$3.4	For legal-export audit
6	Reassignment rate by owner (anonymized)	\$5.4	For training needs
7	Drill / table-top mode toggle	\$7.2	For compliance exercises
8	AI Insight Accuracy / Feedback (v1.2	\$9.8 + \$17.2 +	Compliance Officer visibility into AI-output governance posture and user-feedback loop. See
	Final Release NEW)	\$12.1.13	

10.4.1 AI Insight Accuracy / Feedback Widget — Binding Specification (v1.2 Final Release NEW)

The Compliance Dashboard's element #8 (**AI Insight Accuracy / Feedback**) is a **first-class governance widget**, not an informational tile. It is the primary surface on which the Compliance Officer detects drift in AI output quality and enforces the **Human-Validated default** posture established in §9.8. The widget is composed of three sub-elements and one automatic feedback-loop obligation:

Sub-element	Metric / Source	Display	Update Frequency
8a — AI-Assisted Decisions Without Validation	KPI from §17.2 (AI-Assisted Decisions Without Validation)	Headline number; trend sparkline (last 12 weeks); drill-down to offending approval_event / case_state_log rows	Real-time (push on event); KPI recomputed hourly
8b — AI Suggestion Rejection Rate	count(ai_output where output_consumed = true AND consumed_decision_outcome ∈ {REJECTED, OVERRIDDEN}) ÷ count(ai_output where output_consumed = true) over the period	Percentage with p50 / p95 bands; broken down by output_kind (RCA_DRAFT, SUMMARY, CATEGORY_HINT, SEVERITY_HINT, BUSINESS_IMPACT_ESTIMATE, ANOMALY_FLAG); drill-down by model_version and by rmg_context.department	Daily
8c — AI Insight Feedback	New rows in case_comment_log with comment_kind = AI_SUMMARY_INLINE_REVIEW (§12.1.13)	Reverse-chronological feed; sentiment-tagged (NEGATIVE, NEUTRAL, POSITIVE); filter by output_kind and actor_role_at_time_of_post; export to R-AU-05 (AI-Assisted Decision Audit)	Real-time (push on event) Stream

Binding Clause — Automatic Feedback-Loop Obligation. Whenever a back-office user submits **negative feedback** on an AI Insight — for example, by selecting a feedback control labeled "AI suggestion inaccurate," "AI suggestion misleading," "AI suggestion not applicable," or any equivalent negative-sentiment option exposed in the AI Insight UI — the system **MUST** automatically write one row to case_comment_log (§12.1.13) with comment_kind = "AI_SUMMARY_INLINE_REVIEW", is_ai_assisted = false (the comment itself is human-generated), and a non-empty comment_text containing the structured feedback payload (the feedback label selected by the user, the originating ai_output.id, the output_kind, the model_version, the actor's actor_role_at_time_of_post, and the optional free-text elaboration). The write is performed in the same API request that records the feedback; failure to write the case_comment_log row **MUST** reject the feedback submission at the API layer (HTTP 422 AI_FEEDBACK_AUDIT_FAILURE). This guarantees that every negative AI-Insight feedback event is captured in the immutable Comment History audit trail (§12.1.13) and surfaces in widget §10.4 element #8c on the Compliance Dashboard.

Required Fields Captured in the Auto-Written case_comment_log Row. The auto-written row **MUST** populate at minimum: id (server-generated UUID), case_id (FK to the case to which the AI Insight was attached), actor_id (the user who submitted the feedback), actor_role_at_time_of_post (snapshot), comment_text (structured JSON: {"feedback_label": "<label>", "ai_output_id": "<uuid>", "output_kind": "<enum>", "model_version": "<string>", "elaboration": "<free-text|null>"}), comment_kind = "AI_SUMMARY_INLINE_REVIEW", is_ai_assisted = false, device_timestamp, server_timestamp (authoritative), ip_session_hash, redaction_state = "NONE", attachments = NULL. The validated_by_user_id field is **not** required because the comment is human-generated (not AI-assisted).

Governance Rationale (GrillMe). Without this auto-write obligation, negative AI feedback would be lost in ephemeral UI state, leaving the Compliance Officer unable to (a) audit the rate at which users reject AI suggestions, (b) detect model-version drift or hallucination patterns, (c) feed regulator-grade evidence to RAU-05 (AI-Assisted Decision Audit), or (d) trigger the model's retraining pipeline. By binding negative feedback to case_comment_log, the widget becomes the single source of truth for AI-output quality, and the immutability of case_comment_log (§12.1.13 — INSERT-only, append-only) makes the feedback stream regulator-grade.

Challenge Raised	Resolution
"What if an executive wants a custom view on the fly?"	A "Save current view" feature is available to authorized users; saved views are scoped to the user's role and subject to the same data-visibility rules.
"What if dashboards disagree (different refresh cadences)?"	The system of record is the case state machine; dashboards are read-only projections. A "data freshness" timestamp is shown on every dashboard.
"What about mobile dashboard access for supervisors on the floor?"	A mobile-first Supervisor Dashboard is provided; Executive Dashboard is desktop-first.
"What if a sensitive L1 event should be temporarily hidden from the executive view during a public-relations-sensitive window?"	No. The system does not support suppression. The only permitted response is a documented "investigation hold" applied uniformly through the legal/HR process, not via the dashboard.

11. Required Reports

All reports are exportable to **PDF, CSV, and XLSX**, with the same field semantics, and are themselves logged in the evidence-export audit log (§3.4).

11.1 Operational Reports

Report ID	Name	Audience	Frequency	Description
R-OP-01	Daily Open Incidents	Plant Manager, Supervisors	Daily 08:00	All open cases, severity, owner, SLA status, age
R-OP-02	SLA Breach Register	Plant Manager, Compliance	Daily	All cases that breached SLA in the last 24h, with breach reason
R-OP-03	Stale Incidents	Plant Manager	Daily	Cases with no activity in 50%+ of remaining SLA
R-OP-04	Reassignment Log	Plant Manager	Daily	All reassignments with reasons
R-OP-05	Sync Health Report	IT-Ops, Plant Manager	Daily	Per-device sync metrics, MNO failure patterns

11.2 Governance Reports

Report ID	Name	Audience	Frequency	Description
R-GV-01	Weekly KPI Scorecard	ExCo	Weekly Monday	All Executive Dashboard KPIs with WoW deltas
R-GV-02	Monthly Compliance Report	Compliance, Board	Monthly	All Compliance Dashboard KPIs, plus audit-log summary
R-GV-03	Quarterly Safety Trends	EHS, ExCo	Quarterly	Severity mix, category trends, repeat locations, seasonal patterns
R-GV-04	Anonymous Reporting	Compliance,	Quarterly	Anonymous vs. confidential vs. manual submission share, triage latency for
	Health	ExCo		anonymous (anonymity-safe)

11.3 Audit & Legal Reports

Report ID	Name	Audience	Frequency	Description
R-AU-01	Case Audit Trail	Legal, Auditors	On request	Complete event log for a case ID
R-AU-02	Identity Access Audit Log	Compliance, Legal	On request	All identity-unmask and reporter-ID view events
R-AU-03	Evidence Export Manifest	Legal, Auditors	On request	List of all evidence exports with hashes
R-AU-04	SLA Configuration Change Log	Compliance, Auditors	On request	All historical SLA matrix versions and approvers

11.4 GrillMe Hardening — Reports

Challenge Raised	Resolution
"What if a report is run at 23:59 and the date changes midrun?"	All reports run against a frozen timestamp stamped on the report; the timestamp is the data-as-of point.
"What if a report is leaked (e.g., printed and left on a desk)?"	All exports are watermarked; CSV/XLSX exports include the requester's name in the header.
"What about regulatory-reporting formats (e.g., Factories Act, environmental)?"	The system supports regulatory-format templates as a v2 capability; v1 provides structured data export that can be transformed.
"Can reports be scheduled in advance?"	Yes. Scheduled reports are subject to the same access control as on-demand reports.

12. Data Model Entities for Monitoring

The PRD defines the reporter-side data model. This section defines the **monitoring-side extensions** required to make the system governable. Entities below are additive; they do not modify Epic 1 entities.

12.1 Core Monitoring Entities

12.1.1 case_state_log

Append-only record of every state transition.

Field	Type	Notes
id	UUID	PK
case_id	UUID	FK → cases.id
from_state	enum	Previous state
to_state	enum	New state
actor_id	UUID	Who performed the transition (nullable for system transitions)
reason_code	string	From fixed list
device_timestamp	timestamp	For transitions originating on mobile
server_timestamp	timestamp	Authoritative
metadata_json	JSONB	Extensible

12.1.2 sla_clock

One row per active case.

Field	Type	Notes
case_id	UUID	PK, FK
sla_matrix_version	string	Which SLA config applied at submission
triage_due_at	timestamp	Computed at submission
assignment_due_at	timestamp	Computed at triage
resolution_due_at	timestamp	Computed at assignment
pause_reason	string	For operational-hours mode
pause_started_at	timestamp	
pause_total_seconds	int	Cumulative

12.1.3 assignment_log

Field	Type	Notes
id	UUID	PK
case_id	UUID	FK
from_owner_id	UUID	Nullable for initial assignment
to_owner_id	UUID	
reason_code	string	
requested_by	UUID	
approved_by	UUID	For reassignments requiring approval
timestamp	timestamp	Server time

12.1.4 escalation_event

Field	Type	Notes
id	UUID	PK
case_id	UUID	FK
rule_id	string	e.g., "E-2"
fired_at	timestamp	
notified_user_ids	UUID[]	
resolution	string	"acknowledged", "overridden", "auto-resolved"

12.1.5 identity_access_audit (write-only)

Field	Type	Notes
id	UUID	PK
actor_id	UUID	
action	enum	VIEW_REPORTER_ID, UNMASK_CONFIDENTIAL, EXPORT_CASE, etc.
case_id	UUID	FK
purpose_code	string	
document_reference	string	
timestamp	timestamp	
co_signer_id	UUID	For dual-control actions

12.1.6 sla_matrix_version

Field	Type	Notes
version	string	PK, e.g., "2026-Q2-v1"
effective_from	timestamp	
effective_to	timestamp	Nullable
rules_json	JSONB	The full SLA + escalation rules
approved_by	UUID	
change_reason	string	

12.1.7 sync_health_event

Field	Type	Notes
id	UUID	PK
device_id	string	
event_type	enum	SYNC_OK, SYNC_FAIL, QUEUE_GROWING, RECONCILIATION_DRIFT
pending_count	int	
oldest_pending_age_seconds	int	
timestamp	timestamp	

12.1.8 evidence_export_log

Field	Type	Notes
-------	------	-------

<code>id</code>	UUID	PK
<code>actor_id</code>	UUID	
<code>case_id</code>	UUID	FK
<code>export_type</code>	enum	PDF, ZIP, CSV, FULL_PACKAGE
<code>artifact_hashes</code>	string[]	SHA-256 of each artifact
<code>purpose_code</code>	string	
<code>timestamp</code>	timestamp	

12.1.9 investigation_checklist_progress (v1.2 NEW)

Append-only log of every checklist-item tick during **INVESTIGATION**. Each row is one checklist progress event (e.g., "item 3/8 completed"). Progress totals (e.g., 3/8) are surfaced to the UI as a derived read; the **raw events** are stored as immutable rows per the same pattern as `case_state_log` (§12.3).

Field	Type	Notes
<code>id</code>	UUID	PK
<code>case_id</code>	UUID	FK → <code>cases.id</code>
<code>checklist_id</code>	UUID	FK → <code>investigation_checklist_template.id</code>
<code>item_index</code>	int	1-based item index within the checklist
<code>item_label</code>	string	Snapshot of the template label at the time of tick
<code>completed</code>	bool	True on tick; a subsequent un-tick writes a new row with <code>completed = false</code> (no UPDATE)
<code>actor_id</code>	UUID	Who ticked/un-ticked; nullable for system ticks
<code>device_timestamp</code>	timestamp	For ticks originating on mobile
<code>server_timestamp</code>	timestamp	Authoritative
<code>comment</code>	text	Optional free-text note for non-trivial ticks
<code>investigation_methodology_used</code> (v1.2 NEW — required auditable field per §2.4.3)	enum	Required. One of <code>FISHBONE</code> , <code>FIVE_WHYs</code> , <code>FAULT_TREE</code> , <code>TIMELINE</code> , <code>CHANGE_ANALYSIS</code> , <code>PARETO</code> , <code>OTHER</code> . Captured on the first tick of the case's INVESTIGATION checklist and locked on transition out of INVESTIGATION ; subsequent changes write a new row with <code>metadata_json.event_subtype = "INVESTIGATION_METHODODOLOGY_CHANGED"</code> (mirrored to <code>case_state_log</code>). Enforced at the API (HTTP 422) and at the DB layer (CHECK constraint) when <code>item_index = 1</code> . When <code>investigation_methodology_used = "OTHER"</code> , a companion free-text <code>methodology_rationale</code> field of length ≥ 50 characters is mandatory.

Audit-loggable activity rule (§4.5). Every row in `investigation_checklist_progress` is treated as an **audit-loggable activity** and is mirrored into `case_state_log` as a virtual event (`metadata_json.event_subtype = "CHECKLIST_PROGRESS"`). This makes checklist progress visible in the standard case timeline without compromising the immutability of either table.

12.1.10 approval_event (v1.2 NEW)

Immutable, append-only record of every approval action in the multi-stage approval flow (§2.5). Patterned after `identity_access_audit` (write-only, INSERT-only at the DB role level).

Field	Type	Notes
<code>id</code>	UUID	PK
<code>case_id</code>	UUID	FK → <code>cases.id</code>
<code>approval_stage</code>	enum	<code>RCA_SIGNOFF</code> , <code>CAPA_VERIFICATION</code> , <code>CASE_CLOSURE</code> (§2.5)
<code>action</code>	enum	<code>APPROVE</code> , <code>REJECT</code> , <code>REQUEST_CHANGES</code> , <code>DELEGATE</code>
<code>actor_id</code>	UUID	The approver who performed the action
<code>cosigner_id</code>	UUID	Required for <code>CAPA_VERIFICATION</code> and <code>CASE_CLOSURE</code> if dual-control applies (per §2.5)
<code>comment</code>	text	Mandatory for <code>action = REJECT</code> or <code>REQUEST_CHANGES</code> (server-side validation, length ≥ 10 chars)

source_artifact_ref	string	FK or URL to the RCA / CAPA / Closure document being approved
validated_by_user_id	UUID	If the action was informed by an AI summary (§9.8), the user who validated the AI output before this approval
device_timestamp	timestamp	Informational
server_timestamp	timestamp	Authoritative
ip_session_hash	string	One-way hash for tamper-evidence

Mandatory comment enforcement. `approval_event.comment` is enforced at the API layer (HTTP 422 on missing/short comment) and at the DB layer (CHECK constraint). There is no path to write a `REJECT` or `REQUEST_CHANGES` row without a comment of length ≥ 10 .

12.1.11 `rmg_context` (v1.2 NEW — RMG-Context Entity)

Ready-Made Garment contextual fields attached to a case at submission or at first triage. The fields are sourced from the **production order master** (POM) and the **style master**, and may also be auto-populated from QR prefill (§20) when the QR encodes a style/PO reference.

Field	Type	Notes
id	UUID	PK
case_id	UUID	FK → <code>cases.id</code> (unique; 1:1 with case)

Field	Type	Notes
buyer_name	string	e.g., "H&M", "Inditex", "C&A" — sourced from POM
style_number	string	e.g., "SS26-W-1042" — sourced from style master
production_order_id	string	PO identifier (e.g., "PO-2026-00041")
sub_category	enum	RMG sub-category: <code>WOVEN_TOP</code> , <code>KNIT_BOTTOM</code> , <code>OUTERWEAR</code> , <code>ACCESSORIES</code> , etc. — drives category-specific SLAs (§7.1)
department	enum	<code>CUTTING</code> , <code>SEWING</code> , <code>FINISHING</code> , <code>PACKING</code> , <code>WAREHOUSE</code> , <code>SUPPORT</code> — drives rule-based owner suggestion (§5.1)
line_id	UUID	FK → <code>production_lines.id</code> ; used for <code>SELF_LINE_REPORT</code> detection (§21.2)
populated_at	timestamp	Server time
populated_by	UUID	The actor (system, triager, or auto-QR) that set the context
source	enum	<code>POM_AUTO</code> , <code>TRIAGER_MANUAL</code> , <code>QR_PREFILL</code> , <code>REPORTER_INPUT</code>
confidence_score	decimal(0,1)	Confidence in auto-population; UI may prompt triager confirmation below [Default] 0.85

Privacy interaction. `rmg_context` is **business-identifying**, not reporter-identifying. It is visible to all back-office roles with case visibility (§3.1–§3.3) and is **not** subject to anonymous-mode masking (§9.2). However, when the case is in anonymous mode, `rmg_context` is still attached — it is the *production context* of the report, not the reporter's identity.

12.1.12 `business_impact` (v1.2 NEW — *Business Impact Entity*)

Quantitative and qualitative impact assessment attached to a case. The fields are populated at triage (initial estimate) and refined during investigation (final estimate). The `estimated_loss_usd` is the primary trigger for rule **E-8** (§7.3).

id	UUID	PK
case_id	UUID	FK → <code>cases.id</code>
parent_comment_id	UUID	Self-FK for threaded replies; NULL on top-level comments
actor_id	UUID	The back-office user who posted the comment (FK → <code>users.id</code>)

Field		
<code>actor_role_at_time_of_post</code>	enum	Snapshot of the actor's role (e.g., <code>INVESTIGATION_LEAD</code> , <code>PLANT_MANAGER</code> , <code>COMPLIANCE_OFFICER</code>) at the moment of post — preserved even if the user's role changes later
Field	Type	Notes
<code>id</code>	UUID	PK
<code>case_id</code>	UUID	FK → <code>cases.id</code> (unique; 1:1 with case)
<code>affected_quantity</code>	int	Number of pieces / units impacted (e.g., damaged, on-hold, reworked)
<code>unit_of_measure</code>	enum	<code>PCS</code> , <code>KG</code> , <code>LOTS</code> , <code>DAYS_DELAY</code>
<code>estimated_loss_usd</code>	decimal(15,2)	USD-equivalent estimated financial loss (fixed-reference rate; see §7.3 E-8)
<code>currency_native</code>	string(3)	ISO-4217 code of the currency in which the loss was first estimated (e.g., <code>PKR</code>)
<code>loss_native_amount</code>	decimal(18,2)	Native-currency amount; converted to <code>estimated_loss_usd</code> at the snapshot rate
<code>fx_rate_snapshot</code>	decimal(10,6)	Rate used for conversion at <code>estimated_loss_usd</code> last update
<code>fx_rate_snapshot_at</code>	timestamp	When the rate was snapshotted
<code>estimation_stage</code>	enum	<code>TRIAGE_INITIAL</code> , <code>INVESTIGATION_REFINED</code> , <code>RCA_FINAL</code> , <code>POST_CAPA</code>
<code>estimated_by</code>	UUID	User who provided the estimate
<code>estimated_at</code>	timestamp	Server time
<code>confidence</code>	enum	<code>LOW</code> , <code>MEDIUM</code> , <code>HIGH</code>
<code>notes</code>	text	Optional free-text justification

Governance Logic (E-8 trigger). Every write to `business_impact.estimated_loss_usd` is checked against the **Financial Escalation Threshold** (configurable per §18.3; default **USD 3,572** ≈ PKR 1,000,000). When the threshold is exceeded, the system **automatically** fires rule **E-8** (§7.3) and emits a `case_state_log` event (`metadata.json.event_subtype` = `"FINANCIAL_ESCALATION_FIRED"`). The threshold check is enforced server-side and is independent of the user's intent — there is no user-level mute.

12.1.13 `case_comment_log` (v1.2 NEW — *Comment History / Internal Collaboration Audit Trail*)

The **Comment History** is the internal collaboration audit trail of a case. It captures every internal note, @-mention, system-generated annotation, and reviewer comment posted against a case by an authenticated back-office actor. The Comment History is **distinct** from the public-facing case timeline (`case_state_log`, §12.1.1): it is the **discussion layer**, while `case_state_log` is the **state-transition layer**. Both are immutable and audit-exportable, but the Comment History exists primarily to give reviewers, Compliance Officers, and Plant Managers a queryable record of *who said what, when, and why* during the operational handling of the case.

Field	Type	Notes
	Type	Notes
<code>comment_text</code>	text	The comment body; mandatory; minimum length 1 character; maximum length 10,000 characters
<code>comment_kind</code>	enum	<code>INTERNAL_NOTE</code> , <code>@MENTION_REPLY</code> , <code>SYSTEM_ANNOTATION</code> , <code>REVIEWER_COMMENT</code> , <code>RCA_DRAFT_INLINE</code> , <code>CAPA_PROGRESS_UPDATE</code> , <code>AI_SUMMARY_INLINE_REVIEW</code>
<code>mentioned_user_ids</code>	UUID[]	Array of users @-mentioned in the comment; each mention triggers a notification per §13.3
<code>attachments</code>	JSONB	Optional array of { <code>url</code> , <code>mime_type</code> , <code>size_bytes</code> , <code>sha256</code> } references; URLs are pre-signed and expire in 24h
<code>redaction_state</code>	enum	<code>NONE</code> , <code>REDACTED_FOR_INVESTIGATION</code> , <code>REDACTED_FOR_LEGAL_HOLD</code> — applies only when an anonymous-mode case is later unmasked (§9.4) and a comment must be redacted from the reporter-visible copy
<code>redaction_reason</code>	text	Mandatory when <code>redaction_state</code> != <code>NONE</code> ; length ≥ 20 characters
<code>is_ai_assisted</code>	bool	True if the comment body was generated by an AI summarizer (§9.8); requires <code>validated_by_user_id</code> to be set
<code>validated_by_user_id</code>	UUID	Required when <code>is_ai_assisted</code> = <code>true</code> ; references the user who validated the AI-drafted comment text before posting
<code>device_timestamp</code>	timestamp	Informational (mobile origin)

Field		
server_timestamp	timestamp	Authoritative
ip_session_hash	string	One-way hash for tamper-evidence

Immutability & Audit-Tail Pattern. `case_comment_log` follows the same pattern as `identity_access_audit` (§9.5), `approval_event` (§12.1.10), and `investigation_checklist_progress` (§12.1.9): the DB role has INSERT-only permissions; UPDATE and DELETE are denied at the schema level. "Edit" and "delete" actions by users are themselves modeled as **new rows** that reference the prior row's `id` in `supersedes_comment_id` — the original row is never mutated.

id	UUID	PK
entity_type	enum	NOTIFICATION_TEMPLATE, WORKFLOW_ASSIGNMENT_RULE, WORKFLOW_ESCALATION_RULE, WORKFLOW_SLA_MATRIX, WORKFLOW_STAGE_GUARD, INVESTIGATION_CHECKLIST_TEMPLATE, OTHER_ADMIN_ENTITY
entity_id	UUID	The PK of the affected config row

Field		
change_type	enum	INSERT, UPDATE, DELETE

Binding Clause — Append-Only Obligation. Every internal comment posted against a case by an authenticated back-office actor — including plain notes, @mention replies, system-generated annotations, RCA-draft inline reviews, CAPA progress updates, and AI-summary inline reviews — **MUST** result in exactly one row in `case_comment_log` at the moment the comment is committed. The DB role for the application has INSERT-only permissions on this table; any INSERT that is preceded by an UPDATE or DELETE in the same transaction is rejected at the schema level (DB-level CHECK constraint enforced via trigger). There is no application-level path to post a comment without an audit row, and there is no application-level path to mutate or remove an existing comment row. This is the **non-negotiable Comment History audit posture** required by the Figma UI and the regulator-facing export R-AU-01 (§11.3).

Regulator Export Linkage (R-AU-01). The Comment History is bundled into the **Case Audit Trail** report (R-AU-01, §11.3) alongside `case_state_log`, `investigation_checklist_progress`, `approval_event`, and the AI output rows. The export includes: `id`, `case_id`, `parent_comment_id`, `actor_id`, `actor_role_at_time_of_post`, `comment_kind`, `comment_text`, `mentioned_user_ids`, `redaction_state`, `redaction_reason`, `is_ai_assisted`, `validated_by_user_id`, `server_timestamp`, and `ip_session_hash`. Attachments are referenced by SHA-256 hash; the attachment binary itself is exported via R-AU-03 (Evidence Export Manifest) on a separate channel. The exported Comment History is **the authoritative record** of internal collaboration on a case and is admissible in regulatory proceedings as a non-repudiable audit artifact.

Comment History UI Surface. The Comment History is surfaced in the case detail view as a chronological, threaded discussion pane, sorted ascending by `server_timestamp`. System annotations and reviewer comments are visually distinguished from user notes. AI-assisted comments carry a visible **"AI-assisted"** badge, and the validated-by user is shown on hover.

Visibility & Redaction Interaction. The Comment History is **always visible to back-office roles** with case visibility (§3.1–§3.3). For **anonymous-mode** cases (§9.2), the Comment History is excluded from the reporter-visible case copy; for **confidential-mode** cases (§9.3), the Comment History is visible to the named recipient(s) only via dual-control unmask. When identity unmask occurs (§9.4), the `redaction_state` column allows a Compliance Officer to retroactively redact a specific comment from the reporter-visible copy with a mandatory reason.

Retention. Rows are retained for **life of company + 7 years** per the Master PRD retention policy, regardless of subsequent edits or redacts. Partitioned monthly for query performance, with archived partitions remaining queryable.

GrillMe Rationale. Without a dedicated `case_comment_log` entity, internal collaboration would either be lost (if modeled as ephemeral chat) or conflated with the state-transition log (if appended to `case_state_log`). A separate entity preserves the **provenance of human judgment** — a regulator-grade record of how a case was *discussed*, distinct from how it was *moved through states*.

12.1.14 configuration_audit_log (v1.2 NEW — Immutable Configuration Audit Log per §13.6 & §18.7)

Append-only, immutable record of every create, update, and delete operation performed through the Admin panel against a Notification Template (§13.2) or a Workflow Config entity (§5.1, §7.3, §4.2, §4.5, §2.2). The `configuration_audit_log` row is written **in the same database transaction** as the configuration change itself; if the audit row cannot be written, the configuration change is rolled back (HTTP 409, error code `CFG_AUDIT_FAILURE`).

Field	Type	Notes
actor_id	UUID	The Admin-panel user who initiated the change
actor_role_at_time_of_change	enum	Snapshot of the actor's role at the moment of change; preserved even if the user's role changes later
cosigner_id	UUID	The second named approver when dual-control applies (§13.6 Rule 5); NULL otherwise
actor_ip	string	Source IP (logged for forensics; not used for auth)
actor_user_agent	string	Browser/client UA string
previous_value_json	JSONB	Full snapshot of the entity's prior state; NULL on INSERT
new_value_json	JSONB	Full snapshot of the entity's post-change state; NULL on DELETE
diff_json	JSONB	Structured diff of <code>previous_value_json</code> vs. <code>new_value_json</code> for UPDATE; empty for INSERT/DELETE
change_reason	text	Mandatory free-text justification; length ≥ 20 characters
reverts_audit_id	UUID	Self-FK pointing to the prior audit row this change reverses (when applicable)
is_break_glass	bool	True when the change was made via the §13.6 break-glass procedure
break_glass_ticket_id	string	Reference to the on-call ticketing system; required when <code>is_break_glass = true</code>
effective_from	timestamp	When the new value takes effect
effective_to	timestamp	When the value was superseded by a later change; NULL while current
device_timestamp	timestamp	Informational

Field

server_timestamptimestampAuthoritative

Immutability & Atomicity. `configuration_audit_log` is INSERT-only at the DB role level. The audit-row write is performed by a **security-definer trigger function** invoked on every config table; direct application writes that bypass the trigger are blocked by row-level security policies (§13.6 GrillMe row 1). The audit row and the config row commit in the **same DB transaction**; partial commits are impossible.

Quarterly Compliance Review. Compliance Officer reviews the configuration audit log quarterly and signs off via a `configuration_audit_review` event (operational, not in this entity) referencing the period covered, row counts, and findings.

Retention. Rows are retained for **life of company + 7 years** per the Master PRD retention policy, regardless of whether the configuration change has since been reverted. Partitioned monthly for query performance.

GrillMe Rationale. Without this entity, an Admin could change Notification Templates or Workflow Config values and leave no trace — destroying the regulatorgrade auditability that FactoryShield's compliance posture requires. The atomic-write rule and the dual-control threshold turn what would otherwise be a "besteffort change log" into a **non-bypassable governance invariant**.

12.2 Derived / Computed Views (Materialized)

View	Purpose	Refresh
<code>vw_owner_metrics_30d</code>	Per-owner performance (§5.4)	Hourly
<code>vw_sla_compliance_matrix</code>	Category × severity heatmap	Hourly
<code>vw_geo_cluster_24h</code>	Same-GPS, same-window clusters	Every 15 min
<code>vw_anonymous_funnel</code>	Anonymous submission → resolution	Hourly
<code>vw_sync_health_fleet</code>	Fleet-wide sync health	Every 5 min
<code>vw_investigation_aging</code> (v1.2 NEW)	Bucketed age of cases currently in <code>INVESTIGATION</code> (0–6h, 6–12h, 12–24h, >24h); powers KPI "Investigation Aging" (§17.2)	Every 15 min
<code>vw_capa_completion_30d</code> (v1.2 NEW)	Per-period CAPA close rate, broken down by department (§25 / <code>rmg_context.department</code>)	Hourly
<code>vw_total_production_impact</code> (v1.2 NEW)	Sum of <code>business_impact.affected_quantity</code> and <code>business_impact.estimated_loss_usd</code> for the period, broken down by <code>buyer_name</code> , <code>style_number</code> , <code>sub_category</code> ; powers KPI "Total Production Impact" (§17.2)	Hourly
<code>vw_financial_escalations_open</code> (v1.2 NEW)	Open cases that have triggered rule E-8 and not yet reached <code>CLOSED</code> ; powers the Executive Dashboard "Financial Escalation — open" indicator	Real-time (push on event)
<code>vw_investigation_methodology_30d</code> (v1.2 NEW — per §2.4.3)	Per-methodology count of investigations completed in the last 30 days, broken down by <code>rmg_context.department</code> , <code>rmg_context.sub_category</code> , and severity; powers KPI "Methodology Distribution" and the Compliance Dashboard filter on <code>investigation_methodology_used</code> (§17.2)	Hourly
<code>vw_configuration_change_ledger</code> (v1.2 NEW — per §13.6) Chronological ledger of all Admin-panel configuration changes from <code>configuration_audit_log</code> Real-time (§12.1.14); grouped by <code>entity_type</code>, <code>actor_id</code>, <code>change_type</code>, and <code>effective_from</code>; powers regulator export report R-AU-06 (§11.3) and the Compliance Dashboard "Configuration Change event) Activity" widget (push on		

12.3 GrillMe Hardening — Data Model

Challenge Raised	Resolution
"What if <code>sla_clock</code> is wrong and we issue an SLA-breach notification erroneously?"	SLA breach events are soft-fired : they wait 5 minutes (1 minute for L1) before notification, allowing manual override with reason.
"What if a case is reopened years later — does the original SLA still apply?"	Yes. <code>sla_clock</code> is bound to <code>sla_matrix_version</code> at submission. Reopen is a new event; it does not re-derive SLAs.
"What if <code>identity_access_audit</code> grows unboundedly?"	It is partitioned monthly and archived after 7 years per retention policy; archived partitions remain queryable.
"How do we ensure the <code>case_state_log</code> is truly immutable?"	The DB role for the application has INSERT-only permissions on this table; UPDATE and DELETE are denied at the schema level.
"What if a malicious user attempts to un-tick a completed checklist item to game progress?" (v1.2 NEW)	<code>investigation_checklist_progress</code> (§12.1.9) is append-only; an un-tick writes a new row with <code>completed = false</code> . The derived total is recomputed from history and is never mutated. The full untick history is preserved.
"What if <code>estimated_loss_usd</code> is inflated to abuse rule E-8?" (v1.2 NEW)	Every <code>business_impact</code> write is logged with <code>estimated_by</code> , <code>estimated_at</code> , <code>estimation_stage</code> , and <code>fx_rate_snapshot</code> . The Compliance Dashboard exposes an "E-8 inflation review" view that surfaces cases where the same user has triggered E-8 > N times per period (configurable; default N=3).
"What if <code>approval_event</code> is forged by a developer?" (v1.2 NEW)	Patterned on <code>identity_access_audit</code> (write-only): the DB role has INSERT-only permissions; UPDATE and DELETE are denied at the schema level. The mandatory-comment CHECK constraint prevents silent rejections.
"What if RMG context is wrong (e.g., wrong <code>style_number</code>)?" (v1.2 NEW)	Every <code>rmg_context</code> row carries a <code>confidence_score</code> and a <code>source</code> enum. Triggers below [Default] 0.85 confidence are prompted to confirm; manual overrides are audit-logged.
"What if an Investigation Lead selects <code>investigation_methodology_used = OTHER</code> to dodge the rigor of Fishbone or 5-Whys?" (v1.2 NEW — per §2.4.3)	A companion <code>methodology_rationale</code> field of length ≥ 50 characters is mandatory when the methodology is <code>OTHER</code> . The Compliance Officer reviews weekly the count of <code>OTHER</code> selections per author; sustained reliance on <code>OTHER</code> triggers a methodology-training referral and may temporarily restrict the author from selecting <code>OTHER</code> without a Compliance co-sign.
"What if a <code>case_comment_log</code> row contains PII that should not have been posted (e.g., a reporter's name accidentally typed in anonymous mode)?" (v1.2 NEW — per §12.1.13)	The original row is never deleted or mutated . A Compliance Officer marks it with <code>redaction_state = "REDACTED_FOR_INVESTIGATION"</code> and <code>redaction_reason</code> ; the UI suppresses the comment body for non-Compliance viewers while preserving the row for regulator audit. The redaction event is itself logged.
"What if the Admin panel is used to raise the E-8 Financial Escalation Threshold to suppress alerts?" (v1.2 NEW — per §12.1.14, §13.6, §18.7)	Updates to E-8 threshold , Composite SLA Budget , CAPA Verification rejection-loop count , and Investigation Checklist Template require dual-control (Compliance Officer + Plant Manager) at the API layer; <code>configuration_audit_log</code> captures both <code>actor_id</code> and <code>cosigner_id</code> ; the Compliance Dashboard surfaces a "Critical Config Change Activity" widget; the change is included in R-AU-06 regulator export. A sustained pattern of threshold-raising escalates to the Audit Committee.

13. Notification Strategy

13.1 Channel Matrix

Channel	Use	Latency	TargetFallback
Push (in-app)	Default, all events	≤ 10s	In-app inbox
Email	Persistent events (assignment, resolution)	≤ 2 min	—
SMS	L1 escalations, on-duty alerts	≤ 30s	Phone call
	Stale-state, idle alerts	≤ 5 min	tree
In-app banner			Push
Dashboard	Always visible to role	Continuous	—

13.2 Notification Templates

Every notification is templated with a fixed structure:

1. **Severity icon / color**
2. **Case ID** (or short reference)
3. **One-line summary** (e.g., "L2 chemical spill, Area 3, assigned to you")
4. **Time-in-state / time-to-SLA** (e.g., "42 min in ASSIGNED; resolution due in 2h 18m")
5. **Action button** (Open in app, Acknowledge, Reassign)
6. **Suppress for:** recipient-configurable window (max 8h)

13.3 Notification Rules

Trigger	Recipients	Channel	Notes
L1 submitted	On-duty EHS, Plant Manager	Push + SMS	Immediate
Trigger	Recipients	Channel	Notes
L1 unassigned > 15 min	Plant Manager, COO fallback	Push + SMS	E-2
Any case assigned to me	Owner	Push + email	
Any case reassigned away from me	Previous owner	Email	For awareness
SLA breach (L1)	Owner, supervisor, Plant Manager	Push + SMS	No grace
SLA breach (L2–L4)	Owner, supervisor	Push	5-min grace applied
Anonymous report no triage in 4h	Compliance Officer	Push	E-5
Cluster signal (3+ similar in 1h)	Plant Manager	Push	E-6
Sync health alarm	IT-Ops	Email	From §8.3
Identity-unmask event	Compliance Officer, dual-control cosigner	Email	Audit-only
Investigation_Completed (v1.2 NEW)	Investigation Lead's supervisor, Compliance Officer, RMG Line Manager (if <code>rmg_context.department</code> set, §25)	Push + email	Triggered on transition from INVESTIGATION → RCA_REVIEW
CAPA_Overdue (v1.2 NEW)	CAPA Owner, Compliance Officer, Plant Manager	Push + email	E-9 (§7.3); fires when CAPA_EXECUTION exceeds CAPA SLA
Approval_Required (v1.2 NEW)	Stage-appropriate approver (per §2.5 RACI): RCA signoff → Compliance Officer + Plant Manager; CAPA verification → Compliance Officer; Case closure → Plant Manager + Compliance Officer	Push + email	Fires when a new approval_event row is created with action = REQUEST_REVIEW (i.e., pending approver)
Financial Escalation (v1.2 NEW)	CFO, COO, Plant Manager	Push + email +	E-8 (§7.3); fires on
		Executive	business_impact.estimated_loss_usd crossing
		Dashboard	threshold

13.4 Anti-Spam & Routing

- **Deduplication:** A single state change produces at most one notification per recipient per 5 minutes.
- **Batching:** Low-priority L3/L4 notifications are batched into a 30-minute digest when > 5 are pending for a recipient.
- **Quiet hours:** Per-recipient quiet hours; L1 notifications override.
- **Channel preference:** Per-recipient choice; L1 always uses all available channels.

13.5 GrillMe Hardening — Notifications

Challenge Raised	Resolution
"What if a user mutes notifications and misses a critical L1?"	L1 notifications cannot be muted — they always reach at least one channel that the user has verified as working. If a recipient's push is unacknowledged for 60s, SMS is fired.
"What if the SMS gateway is down?"	E-2 has a phone tree fallback : Plant Manager's mobile receives an automated voice call via the onprem SIP gateway (no internet dependency).
"What about notification accessibility (Urdu-speaking recipients, hearing-impaired)?"	Templates are bilingual (EN + UR) for all substantive notifications. SMS and email are text-only by default; phone-tree voice calls are in English with a follow-up Urdu SMS.
"What if a recipient is on leave and notifications are firing into a void?"	The system cross-references the HR leave calendar; during leave, notifications auto-route to the configured coverage proxy <i>and</i> the recipient receives a digest on return.
"What if notifications themselves become a denial-of-service vector (e.g., a flood of L1s in a mass event)?" underlying report.	The mass-incident clustering rule (§4.4) collapses notifications to one per cluster , not one per

13.6 Notification Template & Workflow Config — Configuration Audit Log (v1.2 NEW — Enhancement)

The Admin panel exposes two categories of **business-controlled configuration** that materially affect the operation of the FactoryShield Monitoring & Governance system:

- **Notification Templates** — the templated message bodies, channel bindings, recipient lists, suppression windows, and language toggles referenced in §13.1–§13.4.
-

Workflow Config — the assignment rules (§5.1), escalation rule parameters (§7.3, including **E-1** through **E-9**), SLA matrix entries (§4.2, §4.5), and stage-transition guards (§2.2) editable from the Admin panel.

Binding Governance Clause (Configuration Audit Log). Any **create**, **update**, or **delete** operation performed through the Admin panel against a Notification Template or a Workflow Config entity **MUST** be recorded as an **immutable row** in the `configuration_audit_log` data model entity (§12.1.14). The row is written in the **same database transaction** as the configuration change; if the audit row cannot be written, the configuration change is **rolled back** at the API layer (HTTP 409 Conflict, error code `CFG_AUDIT_FAILURE`). This guarantees that **no configuration change can exist in the database without a corresponding audit record**.

Atomic Write — Fail-Safe Transaction (binding). The audit-row INSERT and the config-row INSERT/UPDATE/DELETE are wrapped in a **single PostgreSQL transaction** with `SERIALIZABLE` isolation. The transaction flow is: (1) **BEGIN**; (2) apply the configuration change to the target table; (3) INSERT into `configuration_audit_log` with full `previous_value_json/new_value_json/diff_json`; (4) **COMMIT**. If **any** step fails — including a CHECK constraint violation on `configuration_audit_log`, a duplicate-key error, a serialization conflict, or a network partition mid-transaction — the entire transaction is rolled back and the API returns HTTP 409 `CFG_AUDIT_FAILURE` with the underlying error code. **There is no application-level path that commits a configuration change without committing the corresponding audit row.** This is enforced by:

- **DB-level trigger** on every governed config table (`notification_template`, `assignment_rule`, `escalation_rule`, `sla_matrix`, `stage_transition_guard`, `investigation_checklist_template`) that raises an exception if the matching audit row is not present in the same transaction.
- **Security-definer function** `fn_emit_configuration_audit()` that is the only allowed writer to `configuration_audit_log`; the application's DB role has `EXECUTE` permission on this function but no direct `INSERT` permission on the table, preventing ad-hoc audit rows that bypass the diff capture.
- **CI test** (per AC-CFG-01 in §15, forthcoming in v1.2 Final) that asserts every Admin-panel write endpoint is wrapped in this transaction and that rolling back the audit row also rolls back the config row.

Failure modes are explicitly handled: transient DB unavailability returns HTTP 503 `CFG_AUDIT_DEFERRED` and the API retries with exponential backoff (max 3 attempts, 250 ms / 500 ms / 1 s); after exhaustion the Admin UI prompts the operator to retry, **never** to proceed.

The configuration audit log is governed by the following non-negotiable rules:

#	Rule	Enforcement Layer
1	Atomicity. Audit row and config row commit in the same DB transaction.	API + DB
2	Immutability. <code>configuration_audit_log</code> is INSERT-only at the DB role level. UPDATE and DELETE are denied at the schema level (same pattern as <code>identity_access_audit</code> , §9.5, and <code>approval_event</code> , §12.1.10).	DB
3	Identity capture. <code>actor_id</code> , <code>actor_role_at_time_of_change</code> , <code>actor_ip</code> , and <code>actor_user_agent</code> are captured on every row.	API
4	Diff capture. <code>previous_value_json</code> and <code>new_value_json</code> are populated on every UPDATE; for INSERT, <code>previous_value_json = NULL</code> ; for DELETE, <code>new_value_json = NULL</code> .	API + DB
5	Dual-control on critical configs. Updates to E-8 Financial Escalation Threshold , Composite SLA Budget , CAPA Verification rejectionloop count , and Investigation Checklist Template require two named approvers (one of whom must hold the Compliance Officer role) before the change is committed. Enforced at the API (HTTP 422 on single-actor critical updates).	API
6	Effective-from dating. Every config change carries <code>effective_from</code> and <code>effective_to</code> timestamps; queries that consume config resolve to the value active at the timestamp of the consuming event (e.g., the case timestamp). This preserves historical reproducibility.	DB + API
7	Retention. Rows are retained for life of company + 7 years per the Master PRD retention policy, regardless of whether the configuration change has since been reverted.	DB
8	Quarterly Compliance Review. The Compliance Officer reviews the configuration audit log quarterly and signs off on the integrity of the change history. Sign-off is recorded as a <code>configuration_audit_review</code> event with <code>reviewer_id</code> , <code>period_start</code> , <code>period_end</code> , <code>row_count_reviewed</code> , and <code>findings_summary</code> .	Operational
9	Regulator Export. A pre-built regulator export report (R-AU-06 — Configuration Change Ledger , §11.3) enumerates every Admin-panel change in a selected period, grouped by entity type, actor, and approval status.	Reporting

13.6.1 GrillMe Hardening — Configuration Audit Log

Challenge Raised	Resolution
"What if a developer bypasses the Admin panel and writes directly to the DB?"	The application DB role has INSERT + UPDATE permissions on the config tables but the audit-log INSERT is performed by a dedicated security-definer function that is invoked from a trigger on every config table; direct DB writes that bypass the trigger are blocked because the application role lacks the <code>BYPASSRLS</code> attribute and the trigger function is <code>SECURITY DEFINER</code> .
"What if an Admin actor colludes with a developer to suppress an audit row?"	The dual-control rule (Rule 5) plus the quarterly Compliance review (Rule 8) plus the immutable retention (Rule 7) create a layered defense; any deletion attempt leaves a <code>permission_denied</code> event in PostgreSQL's <code>pg_audit</code> log, which is shipped off-host to the SIEM.
"What if a Notification Template change is rolled back the same day — is the audit row still required?"	Yes. Rule 2 is absolute: every committed change leaves an immutable audit row, even if a subsequent change reverts it. Rollbacks are themselves a new audit row referencing the prior row's <code>id</code> in <code>reverts_audit_id</code> .

"What if the API is unavailable and an Admin must make an emergency configuration change?"	A break-glass procedure is defined: a named on-call Compliance Officer + Plant Manager approve a time-boxed (effective_from ≤ 4 hours) override via a CLI tool that writes directly through the same trigger; the break-glass invocation is itself logged in configuration_audit_log with change_reason = "BREAK_GLASS" and is reviewed in the next business day.
"What if a regulator asks who changed the E-8 threshold on a specific date three years ago?"	The configuration_audit_log row carries entity_id , field_name , previous_value_json , new_value_json , actor_id , effective_from , and effective_to ; a one-line SQL query reconstructs the change including the actor's identity and the diff.

14. Responsibility Governance Matrix (RACI)

14.1 Purpose

Sections 5 and 10 identify ownership, and the dashboards designate audiences. This section consolidates **who is Responsible, Accountable, Consulted, and Informed (RACI)** at every governance step of the incident lifecycle. The matrix is the authoritative reference for **role-vs-activity** responsibility and is binding for engineering access-control design, audit-trail expectations, and HR accountability.

14.2 RACI Conventions Used in This Matrix

Letter	Meaning	Governance Interpretation
--------	---------	---------------------------

R	Responsible	Performs the activity; may be one or more roles.
A	Accountable	Single owner of the outcome ("the buck stops here"). Exactly one A per row.
C	Consulted	Provides input before or during the activity; two-way communication.
I	Informed	Notified of the outcome; one-way communication.
—	Not involved	No governance relationship.

RACI Discipline Rule. If a row shows zero **A** entries, the activity has no accountable owner and **must not enter production**. If a row shows more than one **A**, ownership is split and **must be re-clarified** before sign-off. The Compliance Officer reviews the matrix quarterly to enforce this rule.

14.3 RACI Matrix — Full Incident Lifecycle

#	Lifecycle Activity	Reporter	Supervisor	Resolver	Plant Manager	Compliance Officer	EHS Officer	IT Operations	Executive Mgmt
1	Incident Creation (submit a report)	R/A	I	—	I	I (manual / confidential)	I (L1)	—	—
2	Initial Review / Triage	I	R	C	A	C (anonymous / confidential)	C (L1)	—	—
3	Severity Classification (L1–L4)	—	R	C	A	C	C (L1/L2)	—	I (L1)
4	Assignment (primary owner)	—	R	I	A	I	C (L1)	—	—
5	Resolution (work the incident to completion)	I (clarifying Qs)	C	R/A	I	I	C (L1/L2)	C (sync / device issues)	—
6	Verification (resolution is adequate)	—	C	R	I	A	C (L1/L2)	—	—
7	Closure Approval (case → CLOSED)	—	C	I	C	R/A	C (L1/L2)	—	I (L1)
8	SLA Breach Handling	—	R (acknowledges, acts)	R (acts)	A	I	C (L1/L2)	C (syncrelated breaches)	I (L1)
9	Escalation Handling (E-1 ... E-6 fired)	—	C	C	R (responds to escalation)	A (policy)	R (L1 escalations)	R (sync / IT escalations)	I (L1)
10	Audit Review (weekly / monthly / annual)	—	I	I	C	R/A	C (EHS sections)	C (IT sections)	I (ExCo summary)
13 (v1.2 NEW — \$2.4)	Investigation (conduct INVESTIGATION stage; tick checklist items per §4.5)	—	C (subject's line supervisor)	R	I	I	C (L1/L2)	—	—

14 (v1.2 NEW — §2.5)	RCA Review / Sign-Off (multi-stage approval, §2.5)	—	C	R (drafts RCA)	A	R/A (co-sign)	C (L1/L2)	—	I (L1)
15 (v1.2 NEW #	CAPA Execution (implement Corrective + Preventive Actions)	—	I	R	I	I (oversight)	C (L1/L2)	—	—
— §2.4)	Lifecycle Activity	Reporter	Supervisor	Resolver	Plant Manager	Compliance Officer	EHS Officer	IT Operations	Executive Mgmt
16 (v1.2 NEW — §2.5)	CAPA Verification (independent sign-off that CAPA is effective; rejectionloop allowed, §2.3 GrillMe)	—	C	I (CAPA author)	A	R/A	C (L1/L2)	—	I (L1)
Approval Audit Trail							Notes on the matrix:		
• 17	Maintenance (immutable					The Reporter is A for Activity 1 only. After submission, accountability transfers to the back-office roles. C (DB role / I (ExCo immutability) summary)			
• (v1.2									
• approval_event	writes;								
• NEW	— — — R/A dual-control on REJECT;		review)						
—									
• mandatory comment									
• §2.5)									
• enforcement)									

Dual accountability rows (Activities 9) reflect the design principle that escalations are *policy-owned* by Compliance but *operationally-owned* by the receiving role. Compliance defines *when* an escalation must fire; the receiving role owns *responding to it*.

Activity 8 (SLA Breach) has **two R's by design**: the breach response is a shared operational task between Supervisor and Resolver, with a single **A** (Plant Manager) for the outcome.

Executive Management is I, not A, by design. Per §10.2 the Executive Dashboard is a safety/compliance view, not a people-management view; executives are informed of L1 events and trends, never held individually accountable for individual cases.

Activities 13–17 (v1.2 NEW) — Post-Triage Operational Stages. Activity 13 (Investigation) is owned by the Resolver as **R**, with the subject's line Supervisor as **C** (because the subject is on that supervisor's team) and Compliance **I** for audit visibility. Activity 14 (RCA Sign-Off) is **dual** in a controlled way: the Resolver **drafts** the RCA (R), while Compliance is **R/A** for the *review and sign-off* outcome (the buck stops here for RCA quality), and Plant Manager is **A** for the *operational* outcome (the case still proceeds on their authority). Activity 15 (CAPA Execution) returns to the Resolver as **R** with Compliance in oversight **I**. Activity 16 (CAPA Verification) mirrors Activity 14: Resolver is **I** as CAPA author (to preserve independence), Plant Manager is **A** for the operational outcome, and Compliance is **R/A** for the verification quality. Activity 17 (Approval Audit Trail Maintenance) is **R/A** for Compliance (because Compliance owns the audit) and **R** for Plant Manager (executive review); IT Operations is **C** for the DB-role immutability guarantees (§12.3).

- **No orphan activities.** Activities 13–17 each have exactly one **A** entry. The Compliance Officer verifies this in the quarterly RACI review per §14.5.

- (The patch's previously-scheduled Activities 11–14 from §21.5 / §22.3 — *File Report-on-Behalf, Review SELF_LINE_REPORT, Raise Dispute, Review Dispute* — are merged into this consolidated matrix at the next quarterly review per §24.4.)

14.4 RACI by Role — Inverse View

The inverse view answers "what is each role on the hook for?" and is used in onboarding, performance review, and access-control design.

Role	Activities R	Activities A	Activities C	Activities I
Reporter	1	1	0	5 (3–7, 5)
Supervisor	2, 3, 4, 8	0	5, 6, 7, 9, 10, 13 (subject's line), 14 (draft), 15, 16	1
Resolver	5, 13, 14 (draft RCA), 15	5	3, 8, 9, 14	4, 7, 10, 16 (CAPA author — I for independence)
Plant Manager	9 (operational), 14 (co-sign RCA), 16 (co-sign verify), 17 (executive review)	2, 3, 4, 8, 9 (operational), 14 (operational A), 16 (operational A), 17 (executive)	7, 10, 13	1, 5, 6, 15

Compliance Officer	7, 10, 14 (sign-off), 16 (verification R/A), 17 (R/A)	6, 7, 9 (policy), 10, 14 (review outcome), 16 (verification quality), 17 (audit)	2, 3, 5, 8, 13, 15	1 (manual / confidential)
EHS Officer	9 (L1)	0	3, 5, 6, 7, 8, 10, 13, 14, 15, 16	1 (L1)
IT Operations	9 (IT), 17 (DB role immutability C)	0	5, 8, 10, 17	—
Executive Management	0	0	0	1 (L1), 3 (L1), 7 (L1), 9 (L1), 10, 14 (L1), 16 (L1), 17 (ExCo summary)

Inverse-View Discipline (v1.2 NEW). The Compliance Officer holds **A** in 7 of the 17 lifecycle activities — Activities 6, 7, 10, 14 (review outcome), 16 (verification quality), 17 (audit), and Activity 9 (policy). This concentration is a known governance consideration: §14.5's GrillMe row on "What if Compliance refuses to be A?" addresses it through the SoD exception register. The next quarterly review per §1.6 will consider whether Activity 14's dual-A structure (Plant Manager operational + Compliance review) should be simplified.

14.5 GrillMe Hardening — RACI

Challenge Raised	Resolution
"What if no role can be designated A for an activity in a small plant (e.g., no separate EHS Officer)?"	Role consolidation rules are permitted: a single named individual may hold multiple roles. The matrix columns remain separate, but the same person fills two or more cells. Consolidations are documented in the Plant Governance Charter and reviewed quarterly.
"What if a role defined in the matrix is vacant (e.g., Resolver on night shift)?"	Each row has a named backup registered in the role roster (§5.1). If the backup is also unavailable, the activity A defaults to the next escalation level defined in §7.3 (E-2 fallback chain).
"What if the Reporter IS the Resolver (e.g., selfreported injury)?"	The Reporter is R/A for Activity 1; the Resolver is a different named individual for Activities 5–6. The system enforces a self_report flag that excludes the Reporter from the resolver roster for that case.
"What if an activity crosses RACI boundaries — e.g., a Supervisor acting as a Resolver?"	The activity is logged with the acting-as role; the audit trail preserves both the role and the individual. The Compliance Officer reviews cross-role actions monthly.
"How do we prevent RACI from becoming stale after a re-org?"	Section 1.6 governance cadence includes a quarterly RACI review triggered by any HR role-architecture change. The matrix is re-baselined and versioned in the same manner as the SLA matrix.
"What if Compliance refuses to be A for an activity (separation of duties)?"	Activities 6 and 7 (Verification / Closure) are deliberately assigned to Compliance to provide independence from the resolver. The "SoD exception register" records any temporary deviation with COO approval.
"What if Activities 13–17 are added without an owner for one of them?" (v1.2 NEW)	The §14.2 RACI Discipline Rule is applied uniformly: each new activity has exactly one A entry. The Quarterly RACI Review (§1.6) explicitly audits Activities 13–17 for orphan-A and split-A conditions before they can persist into the next quarter.
"What if the dual-A Activity 14 (RCA Signcase Off) creates ambiguity about who is on the hook when RCA is rejected?" (v1.2 NEW)	The architecture is: Compliance Officer is A for the <i>quality of the RCA review process</i> ; Plant Manager is A for the <i>proceeding on their authority</i> . When an RCA is rejected, the rejection routes back to the Resolver (Activity 14 becomes Activity 13), and a new approval_event (§12.1.10) records both As. The CAPA cannot begin (Activity 15 is blocked at the engine level) until both As approve.
"What if a Compliance Officer holds both A for Activity 16 (verification) and signs off as Compliance co-signer on Activity 17 (closure)?" (v1.2 NEW)	The SoD exception register §14.5 already requires a second individual for closure. v1.2 extends this: Activity 16's R/A Compliance Officer is <i>excluded</i> from Activity 17's compliance co-signer role for the same case, enforced at the API layer. The Plant Manager co-signs in the second slot. This separation of duties is logged in identity_access_audit as a SoD check event.
"What if activity 17 (audit trail maintenance) is treated as Compliance-only and the engineering DB role violates immutability?" (v1.2 NEW)	Activity 17 is dual-owned: Compliance is R/A for the audit content; IT Operations is C for the DB-role immutability guarantees. A corruption event in approval_event therefore has two independent failure modes to alert on (Compliance review + IT-Ops DB-role audit). (v1.2 NEW)

15. OpenSpec Style Acceptance Criteria

15.1 Purpose and Convention

This section defines **machine-testable acceptance criteria** in Given / When / Then format for every critical governance capability. These criteria are the bridge between this specification and engineering test design. Each criterion is uniquely identified (AC-XX-NN) for traceability into the engineering test plan and the §19 Traceability Matrix.

Convention:

- **Given** = preconditions (system state, data, roles, time)
- **When** = the trigger or action under test
- **Then** = the observable, verifiable outcome

15.2 AC-INC — Incident Lifecycle Monitoring

ID	Criterion
AC-INC-01	Given a Reporter is authenticated and a case is in DRAFT state, When the Reporter taps Submit, Then the system creates a case_state_log entry, transitions to SUBMITTED_LOCAL (mobile) or SUBMITTED (server), assigns a system-generated case ID, and starts the Triage Clock.
AC-INC-02	Given a case is in SUBMITTED state, When 2 hours elapse without a triage action, Then the case is flagged UNASSIGNED_URGENT , an E-1 escalation is fired, and the Plant Manager's Supervisor Dashboard reflects the change within 30 seconds.
AC-INC-03	Given a case is in PENDING_EVIDENCE state, When 7 calendar days elapse without evidence, Then an escalation is fired to the Plant Manager and the SLA clock resumes from the original pause point.
AC-INC-04	Given a case is in CLOSED state, When a Supervisor requests a reopen with justification, Then the system creates a new REOPENED event preserving the original case ID, binds the case to the original sla_matrix_version , and re-opens the resolution clock at the original (now-paused) due time.
AC-INC-05	Given a case exists, When any state transition occurs, Then the case_state_log receives a new row within 1 second of the server confirming the INC-05 transition, and no other table may be UPDATED or DELETED against the prior row.

15.3 AC-SLA — SLA Tracking

ID	Criterion
AC-SLA-01	Given a case is in SUBMITTED state and the active sla_matrix_version defines a triage SLA of T minutes for the assigned severity, When T minutes elapse without transition to TRIAGED , Then an SLA breach event is soft-fired, the 5-minute grace window (or 1-minute for L1) is applied, and on expiry the Owner + Supervisor are notified.
AC-SLA-02	Given a case is in ASSIGNED state, When the Owner logs an event in case_state_log (e.g., comment, evidence upload, status change), Then the Idle Clock resets to zero and the dashboard SLA bar updates.
AC-SLA-03	Given a case is reassigned, When the reassignment is committed, Then the resolution clock is not reset to a full SLA; it is adjusted by +50% of the remaining time, capped at the original resolution_due_at .
AC-SLA-04	Given the plant is in a configured operational shutdown window, When a case enters the window, Then the resolution clock is paused (not reset) for the duration of the window, and pause_total_seconds accumulates on the sla_clock row.
AC-05	Given a case is in SUBMITTED_LOCAL for 3 hours before sync, When the case finally syncs and reaches SUBMITTED on the server, Then the SUBMITTED SLA-server timestamp reflects the device submission time , and the Triage Clock is computed from the device time, not the server time.

15.4 AC-ESC — Escalation Management

ID	Criterion
AC-ESC-01	Given an L1 case is unassigned for 15 minutes, When the E-2 rule fires, Then push + SMS is sent to the on-duty EHS; if no acknowledgement within 60 seconds, the fallback chain (backup EHS → Plant Manager → COO) is invoked in order.
AC-ESC-02	Given an escalation rule fires, When the rule executes, Then an escalation_event row is created with rule_id , fired_at , notified_user_ids , and a resolution of pending (set to acknowledged on first owner action).
AC-ESC-03	Given the same case is reassigned more than 3 times in 24 hours, When the 4th reassignment is committed, Then E-4 fires and the Compliance Officer is notified with a "possible routing issue" advisory.
AC-ESC-04	Given 3 or more cases share the same GPS and category within a 1-hour window, When the 3rd case is created, Then the system clusters the cases under a parent incident, E-6 fires, and a single cluster notification is sent to the Plant Manager (not one per underlying case).
AC-05	Given an escalation rule is paused by Compliance Officer with a documented reason, When the pause window is active, Then the pause event itself is ESC-logged in escalation_event and visible in the Compliance Dashboard; the rule resumes automatically at the end of the pause window.

15.5 AC-OFF — Offline Sync Monitoring

ID	Criterion
AC-OFF-01	Given a mobile device is offline, When the Reporter submits a report, Then the report is persisted locally with state = SUBMITTED_LOCAL , queued for sync, and a pending_submissions counter is incremented on the device.
AC-OFF-02	Given a sync attempt fails with network error, When the retry strategy executes, Then retries follow exponential backoff (max interval 30 minutes) and persist on-device for up to 72 hours.
AC-OFF-03	Given a sync completes for the report record but a media artifact fails, When the partial sync is detected, Then the case is created with media_partial = true , a RECONCILIATION_DRIFT event is emitted, and auto-retry is scheduled every 15 minutes for 72 hours.
AC-OFF-04	Given a device has last_sync_at older than 24 hours, When the fleet sync-health view refreshes, Then the device is highlighted amber; if older than 48 hours, it is highlighted red.
AC-OFF-05	Given a device is enrolled in MDM and is reported lost/stolen, When the MDM remote-wipe command is issued, Then all locally stored drafts and submissions are cryptographically erased within 5 minutes of command receipt, and a wipe-confirmation event is written to the server.

15.6 AC-EVD — Evidence Tracking

ID	Criterion
AC-EVD-01	Given a photo, audio, or video is uploaded with a case, When the artifact is received, Then the server computes and stores its SHA-256 hash alongside the file, and any later access recomputes and logs the hash.
AC-EVD-02	Given a Supervisor attempts to view full-resolution evidence, When the view is opened, Then a purpose code is required from a fixed list, the view is recorded in identity_access_audit (or its evidence-view equivalent) with actor, timestamp, and purpose, and a watermarked preview is shown.
AC-EVD-03	Given a case is REJECTED , When the rejection is committed, Then all associated evidence is moved to the rejected-cases archive, the rejection reason is logged, and the case may be reopened on appeal.

ID	Criterion
AC-EVD-04	Given a Compliance Officer exports an evidence package, When the export completes, Then the export is recorded in <code>evidence_export_log</code> with <code>export_type = FULL_PACKAGE</code> , the artifact hashes, the requester's name, and a digital watermark is embedded in every artifact.
AC-EVD-05	Given a Reporter attempts to delete an already-submitted photo, When the deletion is requested, Then the system denies the deletion and returns a "post-submission evidence is append-only" message; existing artifacts cannot be removed.

15.7 AC-ANON — Anonymous Reporting Audit

ID	Criterion
AC-ANON-01	Given a Reporter selects Anonymous mode and submits a report, When the report is persisted, Then the cases table contains no <code>reporter_id</code> , no <code>device_id</code> in clear text, no <code>ip_address</code> in clear text; device ID and IP are stored as one-way hashes.
AC-ANON-02	Given an anonymous report is submitted, When any user role attempts to read the case, Then no field in the response contains a reporter identifier, employee ID, or device serial — verified by an automated privacy test.
AC-ANON-03	Given a court order or FIR references a case, When the Compliance Officer initiates an identity-unmask request for an anonymous report, Then the system rejects the request (there is no identity to unmask) and logs the attempt; legal compulsion for anonymous reports must be addressed offsystem.
AC-ANON-04	Given a confidential report is submitted, When a Supervisor opens the case, Then the reporter identity is displayed as "Reporter A" and any attempt to read the unmasked identity is recorded in <code>identity_access_audit</code> .
AC-ANON-05	Given an identity-unmask is requested for a confidential report, When the request is submitted, Then the request requires a <code>purpose_code</code> , a <code>document_reference</code> , and a <code>co_signer_id</code> from the Plant Manager or COO; only then is the unmask action permitted, and the action is written to the immutable <code>identity_access_audit</code> log.

15.8 AC-DASH — Dashboard Visibility

ID	Criterion
AC-DASH-01	Given an authenticated user opens the Executive Dashboard, When the page loads, Then no more than 7 visual elements are rendered, every KPI is drill-down enabled, and the data-freshness timestamp is visible.
AC-DASH-02	Given the data source for a KPI changes, When the dashboard refreshes, Then the relevant KPIs on the Executive Dashboard update within 60 minutes (per \$10.2 refresh cadence).
AC-DASH-03	Given a Supervisor opens the Supervisor Dashboard on a mobile device, When the page loads, Then the dashboard renders within 3 seconds on a 4G connection, the L1/L2 KPIs refresh every 30 seconds, and the L3/L4 KPIs refresh every 5 minutes.
AC-DASH-04	Given the Compliance Dashboard is open, When the Identity-Access Audit Anomalies widget is clicked, Then the underlying audit-log view filters to anomalies in the selected date range, preserving the immutable log entries.
AC-05	Given a user attempts to access a dashboard outside their role, When the request is made, Then the request is denied with a 403 response and the DASH-attempt is logged in the access-control audit log.

15.9 AC-NOT — Notification Handling

ID	Criterion
AC-NOT-01	Given a notification is fired, When the notification dispatcher executes, Then delivery to at least one channel is attempted within 10 seconds for push, 30 seconds for SMS, and 2 minutes for email.
AC-NOT-02	Given an L1 push notification is unacknowledged, When 60 seconds elapse, Then an SMS is sent to the same recipient; if SMS is unacknowledged for 60 more seconds, the phone-tree fallback is invoked.
AC-NOT-03	Given multiple notifications would be sent to the same recipient within 5 minutes for the same case, When the dispatcher dedupes, Then only the first notification is sent and a counter increments the dedup log.
AC-NOT-04	Given a recipient is on the HR leave calendar, When a notification is generated, Then the notification is routed to the configured coverage proxy and queued for digest delivery to the original recipient on their return.
AC-NOT-05	Given a mass-incident cluster is detected, When notifications are dispatched, Then at most one notification per cluster is sent per recipient, not one per underlying case.
AC-NOT-06	Given a notification template is rendered, When the recipient's preferred language is Urdu, Then the substantive body of the notification is rendered in Urdu; severity, case ID, and time fields remain in their canonical (bilingual-safe) form.

15.10 GrillMe Hardening — Acceptance Criteria

ID	Challenge Raised	Resolution
	"What if a test passes against a mocked SLA clock but fails in production?"	ACs are written against observable system behavior (audit log rows, dashboard updates, notification firings) — not internal mocks. The engineering test plan must include a staging-environment suite that uses the same SLA-matrix engine as production.
	"What if the test data contains real PII and an anonymous test inadvertently leaks it?"	AC-ANON-02 mandates an automated privacy test that runs in CI and asserts the absence of PII fields in the response payload. The test data itself is synthetic.
	"What if an AC is un-testable due to environmental constraints (e.g., phone tree unavailable in staging or canary, the AC is marked [stage-only] and the deployment gate is documented. staging)?"	Each AC has a designated test layer (unit, integration, staging, production canary). Where the test layer is

15.11 AC-INV — Investigation Lifecycle (v1.2 NEW)

Criterion
ACINV-01 Given a case is in IN_PROGRESS and meets the §2.4 entry criteria (severity ≥ L2 OR estimated_loss_usd > threshold), When an authorized user (Supervisor, Resolver, or auto-rule) transitions the case to INVESTIGATION , Then the system creates an investigation_checklist_progress row indicating the first item is in-progress, and a case_state_log row with metadata_json.event_subtype = "INVESTIGATION_STARTED".
ACINV-02 Given a case is in INVESTIGATION with an 8-item checklist, When the Investigation Lead ticks item 3, Then an investigation_checklist_progress row is created with item_index = 3, completed = true, and a mirrored case_state_log row with metadata_json.event_subtype = "CHECKLIST_PROGRESS" and metadata_json.checklist_progress = "3/8".
ACINV-03 Given a case is in INVESTIGATION and 24 hours elapse without checklist completion, When the SLA breach detection runs, Then rule E-7 fires (§7.3), the Compliance Officer and Plant Manager receive a push + email notification, and the case is flagged on the Compliance Dashboard as Investigation Overdue .
ACINV-04 Given the Investigation checklist has reached 100%, When the system attempts to transition to RCA_REVIEW , Then the transition is permitted only if at least one approval_event row exists with approval_stage = "RCA_SIGNOFF" and action = "REQUEST_REVIEW" (i.e., the RCA draft is staged for review); the engine rejects the transition with HTTP 422 otherwise.
AC-INV-05 Given a case is in RCA_REVIEW and the Compliance Officer submits an approval_event with action = "REJECT" and an empty comment , When the API receives the request, Then the request is rejected with HTTP 422 and message "Rejection requires a comment of at least 10 characters per §2.5.1"; no row is written.

15.12 AC-CAPA — CAPA Lifecycle (v1.2 NEW)

ID	Criterion
AC-CAPA-01	Given a case has an approved RCA, When the RCA author transitions the case to CAPA_EXECUTION , Then a sla_clock row is created with capa_due_at = entered_at + 72h (or the configured CAPA SLA), and a case_state_log row is created with metadata_json.event_subtype = "CAPA_STARTED".
AC-CAPA-02	Given a case is in CAPA_EXECUTION and 72 hours elapse without checklist completion, When the SLA breach detection runs, Then rule E-9 fires (§7.3), the CAPA Owner, Compliance Officer, and Plant Manager receive push + email, and the case is flagged Overdue CAPA on the Compliance Dashboard.
AC-CAPA-03	Given a case has completed CAPA_EXECUTION , When the case transitions to VERIFICATION , Then the system requires an approval_event for CAPA_VERIFICATION with action ∈ {APPROVE, REJECT} to exit, and the engine rejects any other exit.
AC-CAPA-04	Given a CAPA_VERIFICATION is REJECT , When the rejection is committed, Then the case transitions back to CAPA_EXECUTION ; if this is the second or later rejection, rule E-9 fires (§7.3) and the case is flagged Repeat-Failure CAPA .
AC-05	Given a CAPA has been rejected twice, When the case attempts to exit CAPA_EXECUTION , Then the engine requires a new RCA_SIGNOFF approval event CAPA-

before allowing transition to **VERIFICATION**; an attempt to bypass the fresh RCA is rejected with HTTP 422. 15.13 AC-AI — AI Output Governance (v1.2 NEW)

ID	Criterion
AC-AI-01	Given an AI summary is generated for a case, When the summary is presented to a user, Then an ai_output row is created with output_kind , model_version , generated_at , and the UI shows the explicit label "AI suggestion — verify before acting" per §9.8.5.
AC-AI-02	Given an approver submits an approval_event with action = "APPROVE" and the AI summary was consumed but validated_by_user_id is missing, When the API receives the request, Then the request is rejected with HTTP 422 and message "AI-assisted decision requires validated_by_user_id per §9.8".
AC-AI-03	Given an ai_output row has validation_timestamp set, When an attempt is made to update the row, Then the DB-layer CHECK constraint or INSERTonly role denies the update and the attempt is logged in identity_access_audit (write-only) as a UNAUTHORIZED_WRITE_ATTEMPT .

ID

AC- AI-04 **Given** the Compliance Officer runs the weekly AI-Assisted Decisions Without Validation KPI, **When** the KPI refreshes, **Then** any AI-assisted decision missing `validated_by_user_id` is surfaced with case ID, user, and timestamp for review.

15.14 AC-PI — Production Impact / Business Impact (v1.2 *NEW*)

ID	Criterion
AC- PI-01	Given a triager enters <code>business_impact.estimated_loss_usd</code> above the Financial Escalation Threshold (default USD 3,572 / PKR 1,000,000 equivalent), When the value is persisted, Then rule E-8 fires within 60 seconds (\$7.3), the CFO + COO + Plant Manager receive push + email, and a <code>case_state_log</code> row is created with <code>metadata_json.event_subtype = "FINANCIAL_ESCALATION_FIRED"</code> .
AC- PI-02	Given the Total Production Impact KPI is computed, When the materialized view refreshes, Then <code>vw_total_production_impact</code> aggregates <code>affected_quantity</code> and <code>estimated_loss_usd</code> grouped by <code>rmg_context.buyer_name</code> , <code>rmg_context.style_number</code> , and <code>rmg_context.sub_category</code> , and the values reconcile to within ±5% of the source rows (NFR-PI-01).
AC- PI-03	Given an <code>rmg_context</code> row is written with <code>confidence_score < 0.85</code> (e.g., from a low-confidence QR prefill), When the case loads in the triager UI, Then a confirmation prompt is shown: "RMG context auto-populated with low confidence; confirm or correct" — verified by an automated UI test.

16. Non Functional Requirements

16.1 Purpose

This section consolidates the **non-functional qualities** that the monitoring and governance system must exhibit. NFRs are testable engineering constraints and are referenced from the §15 Acceptance Criteria and the §17 KPI Reference.

16.2 Performance

NFR ID	Requirement	Target	Measurement Method	
NFR-PERF-01	Dashboard initial render (Executive / Compliance)	≤ 2 s at p95 on 4G	Synthetic monitoring on production	NFR-PERF-02 Dashboard initial render (Supervisor mobile)
NFR-PERF-03	Dashboard data refresh latency (Executive KPIs)		Materialized-view refresh log	
NFR-PERF-04	Dashboard data refresh latency (Supervisor L1/L2)	≤ 30 s	Materialized-view refresh log	
NFR-PERF-05	Report generation (PDF / CSV / XLSX) for full month	≤ 30 s for ≤ 10k cases	Load test on staging	
NFR-PERF-06	Status board query response (with filters)	≤ 1 s at p95 for ≤ 100k cases	Load test on staging	
NFR-PERF-07	Sustained incident submission throughput	≥ 200 submissions / minute / factory	Load test simulating mass-incident	
	≤ 3 s at p95 on 4G			
	≤ 60 min	Synthetic monitoring on production		
NFR-PERF-08	SLA breach event soft-fire window	5 min (L2–L4), 1 min (L1)	Engine log	

16.3 Availability

NFR ID	Requirement	Target	Notes
NFR-AVAIL-01	Reporter-side offline resilience	100% of submit / draft / edit flows functional with no network	Per Epic 1 §3.5
NFR-AVAIL-02	Sync recovery after extended offline	Up to 72h of queued submissions persist on-device	Per §8.2
NFR-AVAIL-03	Back-office dashboard availability	99.5% monthly	Excludes scheduled maintenance
NFR-AVAIL-04	Notification dispatcher availability	99.9% monthly for L1 channels	L1 cannot be degraded
NFR-AVAIL-05	Failure tolerance — partial sync	Report accepted; media retrieved	Per AC-OFF-03
NFR-AVAIL-06	Failure tolerance — phone tree fallback	Available when push + SMS both fail	Per AC-NOT-02
NFR-AVAIL-07	Failure tolerance — SLA engine restart	In-flight SLA timers are recovered from persistent sla_clock rows within 5 minutes of restart	Operational test
NFR-AVAIL-08	Failure tolerance — reconciliation job	Hourly; missed runs are detected and re-fired within 30 minutes	Job-monitoring log

16.4 Security

NFR ID	Requirement	Target	Notes
NFR-SEC-01	Data encryption at rest (case data)	AES-256	Per Master PRD
NFR-SEC-02	Data encryption in transit	TLS 1.2+	All client-server and serverinternal
NFR-SEC-03	Reporter-identifying columns encrypted with key held by separate security officer	Enforced at column level	Per §9.7

NFR-SEC-04	Role-based access control (RBAC)	Enforced at API gateway and DB	Per §14 RACI
NFR-SEC-05	Audit-log immutability (case_state_log, identity_access_audit, evidence_export_log)	DB role has INSERT-only; UPDATE/DELETE denied at schema level	Per §12.3
NFR-SEC-06	Dual-control on identity unmask	Compliance + Plant Manager OR Compliance + COO	Per §9.4
NFR-SEC-07	Anti-retaliation cross-incident reporter visibility	Restricted to Compliance Officer; logged on every access	Per §9.6
NFR-SEC-08	Evidence protection (chain of custody, hash recompute on access)	Mandatory on every evidence read	Per §3.4
NFR-SEC-09	Mobile-device local storage encryption	AES-256	Per Epic 1 §3.5

NFR ID	Requirement	Target	Notes
NFR-SEC-10	MDM remote-wipe support	Enforced for all enrolled devices	Per §8.6
NFR-SEC-11	Secrets management (DB credentials, signing keys)	HSM-backed or equivalent; no plaintext in config	Operational standard
NFR-SEC-12	Pen-test cadence	Annual external + quarterly internal	Compliance calendar

16.5 Scalability

NFR ID	Requirement	Target	Notes
NFR-SCALE-01	Multiple factories supported	Up to 10 factories in v1; design must support multi-tenancy data partitioning	Per §7.1 (per-facility SLA)
NFR-SCALE-02	Multiple locations per factory	Up to 20 locations per factory in v1	GPS-based clustering remains accurate
NFR-SCALE-03	Increasing incident volume	Tested up to 1M cases/year/factory	Performance regression test
NFR-SCALE-04	Increasing user base	Tested up to 5,000 reporters/factory	RBAC evaluation latency target
NFR-SCALE-05	Increasing audit-log volume	identity_access_audit partitioned monthly; queries against archived partitions remain < 5 s	Per §12.3
NFR-SCALE-06	Geographic distribution (PK + future multi-region)	DB replication model supports read replicas per region; write region authoritative	Future-state design

16.6 Reliability

NFR ID	Requirement	Target	Notes
NFR-REL-01	Event consistency (state transitions are atomic)	All-or-nothing; partial state is unrepresentable	DB transaction boundaries
NFR-REL-02	Duplicate prevention (offline + near-simultaneous submissions)	Server-side dedup by (device_id, device_submission_uuid)	Per §8.6

NFR-REL-03	Idempotent state transitions	Re-applying the same transition is a no-op, not a duplicate row	Engine contract
NFR-REL-04	Data recovery — RPO	≤ 15 minutes	Backup cadence
NFR-REL-05	Data recovery — RTO	≤ 4 hours	DR runbook
NFR-REL-06	Clock-source authority	Server time (UTC) is authoritative for SLA; device time is informational	Per §4.4
NFR-REL-07	Reconciliation accuracy	RECONCILIATION_DRIFT count is zero on healthy nights	Job-monitoring log
NFR-REL-08	Audit-log durability	11-nines (cloud-provider standard) for the audit partitions	Vendor SLA

16.6.1 Production Impact Data-Accuracy NFRs (v1.2 NEW)

The following NFRs govern the **data accuracy and timeliness** of the new Production Impact entities (§12.1.11 `rmg_context`, §12.1.12 `business_impact`, §12.2 `vw_total_production_impact`). These NFRs are required by the §27 Internal GrillMe Validation Report to ensure the new "Production Impact" fields are not only defined but operationally reliable.

NFR ID	Requirement	Target	Measurement Method
NFR-PI-01	<code>vw_total_production_impact</code> reconciliation accuracy	Aggregated values reconcile to within ±5% of source <code>business_impact</code> rows per period	Daily reconciliation test comparing view vs. raw rows
NFR-PI-02	<code>vw_total_production_impact</code> freshness	Aggregates refresh within ≤ 60 minutes of source write	Materialized-view refresh log
NFR-PI-03	<code>business_impact.estimated_loss_usd</code> write completeness	Every write to <code>business_impact</code> is logged with <code>estimated_by</code> , <code>estimated_at</code> , <code>estimation_stage</code> , <code>fx_rate_snapshot</code>	Automated audit completeness test in CI
NFR	Requirement ID	Target	Measurement Method
NFR-	E-8 rule latency PI-04	Within ≤ 60 seconds of <code>business_impact.estimated_loss_usd</code> crossing the threshold	Notification dispatch log + <code>case_state_log.metadata.json.event_subtype = "FINANCIAL_ESCALATION_FIRED"</code>
NFR-	<code>rmg_context</code> auto-population precision PI-05	≥ 85% of <code>POM_AUTO</code> / <code>QR_PREFILL</code> rows have <code>confidence_score ≥ 0.85</code>	Bi-weekly precision review
NFR-	FX rate snapshot immutability PI-06	<code>fx_rate_snapshot</code> value is set at write time and never recomputed retroactively	DB role permissions (no UPDATE) + integrity test

16.6.2 AI Output Validation NFRs (v1.2 NEW)

NFR ID	Requirement	Target	Measurement Method
NFR-AI-01	AI-assisted decisions missing <code>validated_by_user_id</code>	0 (zero) per period	Weekly KPI "AI-Assisted Decisions Without Validation" (Compliance Dashboard)
NFR-	<code>ai_output</code> row immutability AI-02	No UPDATE or DELETE permitted after <code>validation_timestamp</code> is set	DB role permissions + CI test
NFR-	AI summary freshness AI-03	Summary generated within ≤ 30 seconds of the underlying change (e.g., new RCA draft request)	AI inference timing log state
NFR-AI-04	AI-output disclosure latency	"AI suggestion" label appears in UI within ≤ 100 ms of summary render	UI synthetic monitoring

16.6.3 Audit-Log-Intensive Operation NFRs (v1.2 Final NEW)

The three governance additions in v1.2 Final — Comment History (`case_comment_log`, §12.1.13), Investigation Methodology Auditability (`investigation_methodology_used` + `case_state_log` mirroring, §2.4.3 + §12.1.9), and Configuration Audit Log (`configuration_audit_log`, §12.1.14) — each introduce a write path that is **mandatory, synchronous, and on the critical path of the consuming user action**. These NFRs govern the **performance, reliability, availability**, and **durability** of those write paths so that the governance invariants do not become a denial-of-service vector against the operational system.

NFR ID	Requirement	Target	Measurement Method
NFRAUDCMT-01	Comment post latency (p95)	≤ 200 ms server-side from API receipt to committed row + mirrored R-AU-01 inclusion	API gateway timing + DB commit log
NFRAUDCMT-02	Comment post durability	11-nines durability for <code>case_comment_log</code> rows (same as NFR-REL-08)	Cloud-provider auditpartition SLA + monthly restore drill
NFRAUDCMT-03	Comment insert throughput	≥ 500 inserts/sec sustained per facility without back-pressure on the UI	Load test (k6) replaying Figma-UI click patterns
NFRAUDCMT-04	Comment history UI render	First-page load (50 most-recent comments) ≤ 300 ms p95	Synthetic monitoring from Compliance Dashboard
NFRAUDCMT-05	Comment redaction latency	A <code>redaction_state</code> change MUST be visible to non-Compliance viewers within 60 seconds	Compliance Dashboard synthetic test
NFRAUDCMT-06	Comment retention	Rows retained for life of company + 7 years ; archived partitions remain queryable	Retention-policy compliance job
NFRAUDMETH-01	Methodology capture latency	First <code>investigation_methodology_used</code> value persisted within the same DB transaction as the first <code>investigation_checklist_progress</code> row (no async gap)	CI test asserting transaction boundaries
NFRAUDMETH-02	<code>OTHER</code> rationale enforcement	API rejects with HTTP 422 <code>METHODOLOGY_RATIONALE_TOO_SHORT</code> when <code>char_length(trim(methodology_rationale)) < 50</code> ; DB CHECK constraint mirrors	CI test exercising boundary cases (49, 50, 51 chars)
NFRAUDMETH-03	Methodology mirroring latency	<code>case_state_log</code> row written via DB trigger within 50 ms of <code>investigation_checklist_progress</code> commit (same transaction preferred)	DB trigger timing instrumentation
NFR ID	Requirement	Target	Measurement Method
NFRAUDMETH-04	Methodology change completeness	Every <code>INVESTIGATION_METHODODOLOGY_CHANGED</code> row carries <code>prior_methodology_used</code> and <code>change_reason</code> ≥ 10 chars	Automated audit completeness test in CI
NFRAUDMETH-05	Methodology distribution view freshness	<code>vw_investigation_methodology_30d</code> refreshes ≤ 60 min after source write	Materialized-view refresh log
NFRAUDCFG-01	Configuration write atomicity	100% of Admin-panel writes either commit both config + audit rows or commit neither (zero partial commits)	CI test (AC-CFG-01) + nightly reconciliation job
NFRAUDCFG-02	Configuration audit write latency (p95)	≤ 250 ms server-side from API receipt to fully-committed SERIALIZABLE transaction	API gateway timing + DB commit log
NFRAUDCFG-03	Audit failure user experience	On <code>CFG_AUDIT_FAILURE</code> the API returns HTTP 409 within ≤ 500 ms ; the Admin UI surfaces a non-dismissable error and no partial change is persisted	Synthetic test + UX review
NFRAUDCFG-04	Dual-control enforcement latency	Critical-config changes (E-8 threshold, composite SLA budget, CAPA rejection-loop count, investigation checklist template) require two named approvers before commit; single-actor requests are rejected with HTTP 422	CI test exercising single-actor and dualactor paths
NFRAUDCFG-05	Configuration audit durability	11-nines durability for <code>configuration_audit_log</code> partitions; weekly restore drill exercises a random partition	Vendor SLA + monthly restore drill attestation

NFRAUDCFG-06	<code>vw_configuration_change_ledger</code> freshness	Real-time push on event; ≤ 5 seconds from <code>configuration_audit_log</code> commit to view availability	Stream-pipeline lag dashboard
NFRAUDCFG-07	Break-glass overhead	Time-boxed break-glass procedure completes within ≤ 4 hours of <code>effective_from</code> ; subsequent normal-config write is blocked until break-glass window expires	Break-glass invocation log + follow-up review
NFRAUDCFG-08	Quarterly review completeness	100% of <code>configuration_audit_log</code> rows in the period are reviewed; <code>findings_summary</code> is non-empty	Quarterly Compliance review sign-off record
NFRAUD-X-01	Audit-log writer availability	The combined <code>case_comment_log</code> + <code>configuration_audit_log</code> write path is available ≥ 99.95% monthly (per §16.3 NFR tier for write-critical paths); DB unavailability returns HTTP 503 <code>CFG_AUDIT_DEFERRED</code> / <code>COMMENT_WRITE_DEFERRED</code> and the API retries with exponential backoff	Synthetic monitoring + incident postmortem tracking
NFRAUD-X-02	Audit-log write isolation	Audit-log INSERTs do not block case timeline reads; <code>case_state_log</code> and the dashboards remain responsive during audit-log write spikes	Load test (k6) with concurrent audit-log writes and dashboard reads
NFR-AUD-X-03	Audit-log schema migration safety	Schema migrations on <code>case_comment_log</code> , <code>investigation_checklist_progress</code> , and <code>configuration_audit_log</code> are online (no read or write downtime); migrations are rehearsed in staging before production	Migration runbook + staging rehearsal attestation

"What if the DB is in read-only mode (e.g., during a failover) when an Admin tries to change a notification template?"

NFR-AUD-CFG-03 + the explicit fail-safe rule mean the Admin UI surfaces the failure **clearly** and the operator is **never** shown a "successful" toast for an uncommitted change. The Compliance Officer is notified within 60 seconds via push of the failed admin action.

"What if a regulator asks for the Comment History of a case that was redacted 3 years ago?"	NFR-AUD-CMT-06 retains the row for life of company + 7 years; redaction_state and redaction_reason capture the redaction but the original row text is preserved in the audit export. The regulator receives the redacted view per §9.4 + the original row in the audit channel.
---	--

16.6.3.1 GrillMe Hardening — Audit-Log-Intensive Operation NFRs

Challenge Raised	Resolution
"What if the audit-log write becomes a not required (Comment History); for Configuration Audit Log, strict consistency IS required and is bounded by performance bottleneck and case submissions	The audit-log write is decoupled from the case-write transaction by an outbox pattern where strict consistency is NFR-AUD-CFG-02 (250 ms p95). If the p95 budget is exceeded for 3 consecutive days, the SRE on-call escalates to slow down?" the Compliance Officer + Engineering Lead for joint review.

Challenge Raised	Resolution
"What if the methodology mirroring trigger fires on every checklist tick and floods <code>case_state_log</code> ?"	The trigger fires only when <code>investigation_methodology_used</code> differs from the prior row (initial set, change, lock); routine checklist ticks that do not change the methodology do not generate mirrored events. NFR-AUDMETH-03 + NFR-AUD-X-02 bound the write rate.
"What if a developer accidentally runs a manual <code>UPDATE</code> on <code>configuration_audit_log</code> during incident response?"	The DB role for the application has INSERT-only permission via the security-definer function (§13.6); the <code>postgres</code> superuser is governed by a separate playbook requiring Compliance Officer + DBA dual-sign-off and is itself logged in <code>pg_audit</code> shipped off-host to the SIEM.
Attribute	Requirement
Observability	All monitoring components emit structured logs, metrics, and traces; correlation IDs propagate from mobile submission to dashboard render.
Maintainability	SLA matrix, escalation rules, and notification templates are configuration-driven (not code changes).
Internationalization	All reporter- and supervisor-facing UI and notification text is bilingual (EN + UR); locale-aware date / number formatting.
Accessibility	All dashboards comply with WCAG 2.1 AA. Notifications support text + push; phone-tree voice calls in English with Urdu SMS follow-up.
Configurability	All thresholds, SLAs, escalation rules, and retention periods are governed by §18 Assumption & Configuration Governance. 16.8

GrillMe Hardening — NFRs

Challenge Raised	Resolution
"What if mass-incident throughput (NFR-PERF-07) is breached in production?"	NFR-AVAIL-08 + NFR-REL-07 mandate automatic detection of missed reconciliation runs and self-healing retries. The mass-incident clustering rule (E-6) bounds notification load independently of submission throughput.
"What if a multi-tenant design (NFR-SCALE-01) is not implemented in v1 but requested?"	v1 is single-tenant; the data-partitioning key (<code>facility_id</code>) is mandatory on every monitoring entity from day one, so multi-tenant migration is a configuration change, not a re-architecture.
"What if HSM-backed secrets (NFR-SEC-11) are not available at deployment?"	A documented exception path is permitted for the first 90 days, with explicit risk acceptance from the COO recorded in the SoD exception register.
"What if RPO of 15 minutes (NFR-REL-04) is unattainable on the chosen cloud tier?"	Tier selection is governed by §18. If the chosen tier cannot meet the NFR, the NFR is renegotiated upward (more frequent backup) before the tier is selected — not the other way around.

17. Operational KPI Reference

17.1 Purpose

This section is the **single source of truth** for every operational KPI referenced anywhere in this specification or in the dashboards. Each KPI has a fixed name, calculation method, owner, and review frequency. Adding or modifying a KPI requires a change to this section.

17.2 KPI Catalog

KPI Name	Purpose	Calculation Method	Owner	Review Frequency
SLA Compliance %	Headline timeliness measure	Count of cases that did not breach any active SLA clock in the period, divided by total cases reaching a terminal SLA state in the same period. Excludes cases with legitimate operational-hours pauses.	Plant Manager	Daily (operational), Weekly (governance)
Average Response Time (Triage Latency)	Operational responsiveness of the triage layer	Mean of (<code>TRIAGED.server_timestamp</code> - <code>SUBMITTED.server_timestamp</code>) across cases reaching <code>TRIAGED</code> in the period. Reported per severity.	Plant Manager	Daily
Average Resolution Time	Operational throughput of the resolver layer	Mean of (<code>RESOLVED.server_timestamp</code> - <code>ASSIGNED.server_timestamp</code>) across cases reaching <code>RESOLVED</code> in the period. Reported per severity and per category.	Resolver function lead	Weekly
Open Incident Aging	Backlog and stale-state visibility	Histogram of currently-open cases bucketed by (<code>now</code> - <code>SUBMITTED.server_timestamp</code>): 0–2h, 2–8h, 8–24h, 1–7d, 7–30d, >30d.	Supervisor (operational), Plant Manager (governance)	Real-time (status board)

Escalation Count	Volume of operational escalations	Count of <code>escalation_event</code> rows in the period, broken down by <code>rule_id</code> (E-1 to E-6).	Plant Manager	Daily
Reopened Incident Rate	Quality of closure and adequacy of resolution	Count of <code>REOPENED</code> transitions in the period divided by count of <code>CLOSED</code> transitions in the same period.	Compliance Officer	Monthly
Sync Failure Rate	Mobile + server integration health	Count of sync attempts that ended in <code>SYNC_FAIL</code> or <code>RECONCILIATION_DRIFT</code> in the period, divided by total sync count(<code>case_state_log where metadata_json.ai_assisted = true AND validated_by_user_id IS NULL</code>) over the period.	IT Operations	Daily
AI-Assisted Decisions default Without Validation (v1.2 decision-making context that <i>Final Release</i> lacks a <code>validated_by_user_id NEW</code>)	Enforces the Human-Validated posture of §9.8; surfaces any AI-assisted decision in a <i>Final Release</i> lacks a <code>validated_by_user_id NEW</code>)	Excludes rows where <code>metadata_json.ai_assisted = false</code> (i.e., human-only decisions) and rows where the audit-log filter confirms the absence was benign (e.g., the user explicitly waived AI assistance). Broken down by <code>actor_id</code> , <code>output_kind</code> , and <code>rmg_context.department</code> . Target: 0 per period (NFR-AI-01).	Compliance Officer	Weekly

17.3 KPI Quality Rules

KPI Name	Purpose	Calculation Method	Owner	Review Frequency
		attempts.		
Evidence Completion Rate	Reporting quality and triage readiness	Count of cases in <code>TRIAGED</code> state with at least one non-text evidence artifact (photo / audio / video) divided by total cases reaching <code>TRIAGED</code> in the period.	EHS Officer (for L1/L2), Supervisor (for L3/L4)	Weekly
Anonymous + Confidential Share	Reporter trust signal	Count of anonymous + confidential submissions in the period divided by total submissions in the period.	Compliance Officer	Quarterly
Anti-Retaliation Pattern Review Queue Size	Compliance attention demand	Count of "patterns detected — review recommended" items awaiting Compliance Officer review.	Compliance Officer	Weekly
Identity-Access Audit Anomalies	Privacy and SoD adherence	Count of audit-log entries matching anomaly rules (e.g., same actor viewing > 5 reporter IDs in 24h).	Compliance Officer	Weekly
Reporter Participation %	Adoption signal	Count of distinct reporters with at least one submission in the period divided by total active employees.	Plant Manager	Monthly
Investigation Aging (v1.2 <i>NEW</i>)	Backlog and timeliness of the post-triage investigation layer	Histogram of cases currently in <code>INVESTIGATION</code> state bucketed by (<code>now - INVESTIGATION.server_timestamp</code>): 0–6h, 6–12h, 12–24h, >24h. Mirrors §4.5 Investigation SLA.	Investigation Lead (operational), Compliance Officer (governance)	Real-time (status board) + Weekly (governance review)
CAPA Completion Rate (v1.2 <i>NEW</i>)	Throughput of the correctiveaction layer	Count of cases that completed <code>CAPA_EXECUTION</code> → <code>VERIFICATION</code> without an E-9 firing in the period, divided by total cases that entered <code>CAPA_EXECUTION</code> in the period. Excludes cases in operational-hours pause.	Compliance Officer	Weekly
Total Production Impact (v1.2 <i>NEW</i>)	Quantified business impact of incidents	Sum of <code>business_impact.affected_quantity</code> and <code>business_impact.estimated_loss_usd</code> over the period, broken down by <code>rmg_context.buyer_name</code> , <code>rmg_context.style_number</code> , <code>rmg_context.sub_category</code> , <code>rmg_context.department</code> . Reported per period with WoW deltas.	CFO (governance), Plant Manager (operational)	Weekly (operational), Monthly (governance)

No KPI without an owner. A KPI without a designated owner is not promotable to a dashboard.

No KPI without a calculation method. A KPI whose calculation is not in this table may not be cited in any report.

No KPI without a review frequency. A KPI that is not reviewed is theatre.

No punitive league tables. Per §5.4, owner-level rankings are forbidden. Aggregated per-owner metrics are surfaced to the owner and their manager only.

No orphan KPIs on dashboards. Every dashboard element in §10 must be traceable to a row in §17.2.

17.4 GrillMe Hardening — KPI Framework

Challenge Raised	Resolution
------------------	------------

Challenge Raised

"What if two KPIs give contradictory signals (e.g., SLA Compliance % is 99% but Anonymous Share is dropping)?"

KPIs are interpreted as a **portfolio**, never in isolation. The Weekly KPI Scorecard (R-GV-01) includes a **narrative interpretation** section owned by the COO, not just a number dump.

"What if a KPI definition is changed retroactively, invalidating historical comparisons?"

Every KPI carries a `kpi_definition_version` aligned to the active `sla_matrix_version`. Historical numbers are never re-stated under a new definition.

"What if a KPI is gamed (e.g., triagers mark cases TRIAGED in 1 minute to game Average Response Time)?"

Average Response Time is **median-and-p90-and-p99**, not just mean; gaming the median requires consistent effort across the distribution, which is materially harder. The Compliance Officer reviews triage-fast outliers monthly.

"What if Total Production Impact is gamed by inflating `estimated_loss_usd`?" (v1.2 *sub_category*). The "E-8 inflation review" view (§12.3 GrillMe row) surfaces cases where the same user triggered **EResolution**

NEW)

8 > N times per period (default N=3) for Compliance review. The FX-rate snapshot is preserved in `business_impact` to allow retro-detection.

"What if CAPA Completion Rate is gamed by closing CAPAs without effective verification?" (v1.2 *NEW*)

The KPI denominator **excludes** cases where E-9 fired; i.e., over-sighted completions are penalized. The numerator requires a `CAPA_VERIFICATION = APPROVE` event. Verification rejections reset the completion for that CAPA cycle. The Compliance Officer reviews a "CAPA-bypass attempt" anomaly (a CAPA closed without verification) in the Compliance Dashboard.

"What if Investigation Aging buckets are misaligned to operational rhythms?" (v1.2 *NEW*)

The default buckets (0–6h, 6–12h, 12–24h, >24h) align with the default 24h Investigation SLA. Buckets are `[Configurable]` (§18.3) and can be tuned to match the facility's operational cadence.

18. Assumption & Configuration Governance

18.1 Purpose

This section **disambiguates** three classes of statements in this specification:

- **A. Epic Mandatory Requirements** — derived directly from Epic 1, no business discretion
- **B. Default Recommendations** — reasonable defaults proposed by the spec author, subject to business sign-off
- **C. Configurable Business Parameters** — values that the business is expected to tune over time, never fixed in code

Misreading a **B** as an **A** has historically caused over-engineering; misreading a **C** as an **B** has caused friction when the business wants to change a value without a code change. This section makes the distinction explicit and binds the implementation.

18.2 Class Definitions

Class	Symbol	Treatment in Implementation	Change Mechanism
A. Epic Mandatory Requirement	[Epic]	Hard-coded behavior; deviating requires a PRD change.	Epic / PRD change request
B. Default Recommendation	[Default]	Shipped as the initial value; changeable via §18.4.	Config change with named-owner sign-off
C. Configurable Business Parameter	[Configurable]	Exposed in the configuration UI; business owns the value.	Self-service by the named owner

18.3 Class Assignment of Key Items

Item	Class	Rationale
Three reporting modes (Manual, Anonymous, Confidential)	[Epic]	Mandated by Epic 1 §3.
Bilingual support (EN + UR)	[Epic]	Mandated by Epic 1 §3.6.
14-step submission flow	[Epic]	Mandated by Epic 1 §6.1.
10 photos / 30s video per report	[Epic]	Mandated by Epic 1 §7.
GPS capture on submission	[Epic]	Mandated by Epic 1 §3.4.
Offline-first storage	[Epic]	Mandated by Epic 1 §3.5.
Voice-to-text for description	[Epic]	Mandated by Epic 1 §6.4.
Default SLA matrix (L1=15min triage ... L4=24h triage)	[Default]	Reasonable starting point; business to ratify.
2-hour unassigned-urgent threshold	[Default]	Reasonable; business to ratify.
7-day PENDING_EVIDENCE cap	[Default]	Reasonable; business to ratify.
5-minute SLA grace window (L2–L4)	[Default]	Reasonable; business to ratify.

1-minute SLA grace window (L1)	[Default]	Reasonable; business to ratify.
25% / 50% idle-clock thresholds	[Default]	Reasonable; business to ratify.
SLA duration (per severity / per category / per shift)	[Configurable]	Business-owned; tunable per \$7.
Escalation thresholds (timing, rule conditions)	[Configurable]	Business-owned; tunable per \$7.
Retention period (audit logs, evidence, cases)	[Configurable]	Business-owned; constrained by legal minimums.
Dashboard refresh interval (Executive / Supervisor / Compliance)	[Configurable]	Business / IT-Ops owned.
Notification rules (channels, recipients, quiet hours)	[Configurable]	Per-recipient + business overrides.
Mass-incident cluster trigger (3+ similar in 1h)	[Configurable]	Default of 3+ in 1h; tunable.
Phone-tree fallback contact source (HR system)	[Configurable]	Default; Plant Manager may override.
Reporter-quality score visibility (never shown to reporter)	[Default]	Reasonable governance posture; business to ratify.
No punitive blacklist policy	[Default]	Reasonable; HR to ratify.
Item	Class	Rationale
Dual-control on identity unmask	[Default]	Reasonable; Compliance + ExCo to ratify.
RACI matrix (§14)	[Default]	Authoritative proposal; HR + ExCo to ratify.
Performance NFRs (NFR-PERF-01 ... 08)	[Default]	Reasonable engineering targets; ratified at design review.
Availability NFRs (NFR-AVAIL-01 ... 08)	[Default]	Reasonable engineering targets; ratified at design review.
Security NFRs (NFR-SEC-01 ... 12)	[Default]	Reasonable engineering targets; ratified at design review.
Scalability NFRs (NFR-SCALE-01 ... 06)	[Default]	Reasonable engineering targets; ratified at design review.
Reliability NFRs (NFR-REL-01 ... 08)	[Default]	Reasonable engineering targets; ratified at design review.
Investigation SLA (24h default; \$4.5)	[Default]	Reasonable starting point; Compliance Officer to ratify.
CAPA Execution SLA (72h default; \$4.5)	[Default]	Reasonable starting point; Compliance Officer to ratify.
CAPA Verification SLA (48h default; \$4.5)	[Default]	Reasonable starting point; Compliance Officer to ratify.
Investigation → Closure Composite Budget (5 calendar days default; \$4.5)	[Default]	Reasonable composite; Compliance + Operations to ratify.
Financial Escalation Threshold (USD 3,572 ≈ PKR 1,000,000 default; \$7.3 E-8)	[Configurable]	CFO + COO-owned; exposed in configuration UI.
Investigation Checklist Template (8-item default; \$2.4)	[Default]	Reasonable template; Investigation Lead function to ratify per category.
E-8 inflation review threshold (default N=3 firings per user per period; \$12.3 GrillMe)	[Configurable]	Compliance Officer-owned.
AI-Output Human-Validated default (\$9.8)	[Epic]	Human-in-the-loop posture is non-negotiable; changing requires PRD change.
validated_by_user_id mandatory on AI-assisted decisions (\$9.8)	[Epic]	Audit posture is non-negotiable.
approval_event mandatory rejection comment (≥ 10 chars; \$2.5)	[Default]	Reasonable minimum; Compliance Officer may raise the minimum length.
CAPA Verification rejection-loop count (2 before fresh RCA required; \$2.5.2)	[Configurable]	Compliance Officer + Plant Manager-owned; exposed in UI.
Production Impact NFRs (NFR-PI-01 ... 06; §16.6.1)	[Default]	Reasonable engineering targets; ratified at design review.
AI Output Validation NFRs (NFR-AI-01 ... 04; §16.6.2)	[Default]	Reasonable engineering targets; ratified at design review.
Investigation Aging, CAPA Completion Rate, Total Production Impact KPIs	Reasonable starting definitions; Compliance + CFO + Plant	[Default]

Challenge Raised (\$17.2)	Manager to ratify.
-------------------------------------	--------------------

18.4 Change-Management Workflow for **[Configurable]** Items



18.5 Change-Management Workflow for **[Default]** Items

Same as §18.4, but the proposal must additionally include a **6-week trial** in staging or a single facility, with a written report-back to the original spec author.

18.6 GrillMe Hardening — Assumption Governance

	Resolution
"What if a developer mis-tags a [Default] as [Epic] in code?"	The configuration UI exposes only [Configurable] items; [Default] items are surfaced in a separate "Defaults" tab with a clear "subject to business sign-off" label. Code reviews must include a tag-accuracy check.
"What if a [Configurable] change has unintended downstream effects?"	§18.4 mandates an impact assessment step. The change-management tool generates a dependency report (which dashboards, reports, escalation rules, and SLA clocks reference the value).
"What if business owners change [Default] values without a trial?"	§18.5 makes trials mandatory for [Default] changes; the change-management tool refuses to promote a [Default] change to production without a signed trial report.
"What if someone wants to change an [Epic] value?"	Epic / PRD change request is required; this spec is silent on the workflow (out of scope per §1.4).

18.7 Configuration Audit Log — Governance Binding (v1.2 NEW — Enhancement)

This subsection binds the **Notification Templates** and **Workflow Config** admin-panel entities (introduced in §13.6) to the Assumption & Configuration Governance framework established in §18.1–§18.6. Without this binding, the Configuration Audit Log rule in §13.6 would be a per-feature obligation; with this binding, it becomes a **cross-cutting governance invariant** enforced uniformly for every Admin-panel-controlled entity in the system.

Admin-Panel Entity	Class (per §18.3)	Audit Requirement	Dual-Control Threshold	Reviewer Cadence
Notification Templates (message body, channel bindings, recipient lists, suppression windows, language toggles; §13.2)	[Configurable]	Mandatory <code>configuration_audit_log</code> row (§12.1.14, §13.6); atomic with the change	Not required for routine template edits; required when the template change touches an L1 or L2 severity channel	Compliance Officer quarterly (§13.6 Rule 8)
Workflow Config — Assignment Rules (§5.1)	[Configurable]	Mandatory <code>configuration_audit_log</code> row; atomic with the change	Required when the rule change alters the default owner for any L1/L2 category	Compliance Officer + Plant Manager quarterly
Workflow Config — Escalation Rules (§7.3, E-1 ... E-9)	[Configurable]	Mandatory <code>configuration_audit_log</code> row; atomic with the change	Required for any change to E-8 Financial Escalation Threshold, E-9 CAPA Repeat-Failure threshold , or any rule timing parameter	Compliance Officer + Plant Manager; dualcontrol enforced (§13.6 Rule 5)

Workflow Config — SLA Matrix (§4.2, §4.5)	[Configurable]	Mandatory <code>configuration_audit_log</code> row; atomic with the change	Required for any change to the Composite SLA Budget , the Investigation SLA (24h default), the CAPA Execution SLA (72h default), or the CAPA Verification SLA (48h default)	Compliance Officer + Plant Manager; dualcontrol enforced (§13.6 Rule 5)
Workflow Config — Stage	[Epic] (engine-	Mandatory <code>configuration_audit_log</code> row; any change to a guard requires an	Not applicable — guards are hard-coded; changes require a PRD	Compliance Officer
Transition Guards (§2.2)	enforced)	Epic / PRD change request	amendment	on PRD approval

Governance Invariant. For every Admin-panel entity enumerated above, the absence of a corresponding `configuration_audit_log` row is a **Severity-1 (L1) compliance incident** in its own right and triggers a `compliance_violation_event` with `metadata_json.event_subtype = "MISSING_CONFIGURATION_AUDIT"`. This is enforced at the DB layer via a **foreign-key-style integrity check** that runs nightly in the Compliance batch job and surfaces on the Compliance Dashboard as a non-overridable alert.

Cross-Reference. The Configuration Audit Log clause binds §13.6 (notification operational rules), §18.7 (this subsection — assumption-governance wrapper), and §12.1.14 (data-model implementation) into a single governance control. Any future Admin-panel surface (e.g., new rule types, new template kinds, new SLA matrix axes) **MUST** be added to the table above and **MUST** inherit the same audit obligations; no Admin surface is exempt.

19. Requirement Traceability Matrix

19.1 Purpose

This matrix links every **Epic 1 requirement** to the **governance requirement** in this specification, to the **monitoring capability** that operationalizes it, and to the **implementation entity** in the §12 data model that persists it. Traceability is maintained **only with FactoryShield Reporter — Epic 1** (Reporting an Incident); no other source document is in scope.

19.2 Traceability Matrix

Epic 1 Section	Epic Requirement (paraphrased)	Governance Requirement (this spec)	Monitoring Capability
§3 (Modes)	Three reporting modes: Manual, Anonymous, Confidential	§9 Anonymous/Confidential Auditability; §14 RACI Activity 1	Reporter-mode-aware UI; identity masking; identity escrow
§3.2 (Anonymity guarantee)	Anonymous reports must not store reporter identity	§9.2 Anonymous Mode — Design	Anonymity test (AC-ANONno reporter_id in DB; hashed device/IP)

Epic 1 Section	Epic Requirement (paraphrased)	Governance Requirement (this spec)	Monitoring Capability
§3.4 (Geolocation)	Auto-capture GPS lat/long	§3.1 Evidence Visibility; §10.3 Supervisor heatmap	GPS plausibility flag; geocustering
FactoryShield_Monitoring_Governance_Spec_v1.2.md	Local persistence of drafts +		2020-06-29
§3.5 (Offline storage) Challenge Raised	submissions; media stored locally until sync	§8 Offline Reporting & Sync Failure Monitoring; AC-OFF-01, 02, 03	Pending-queue metrics; parti sync handling; reconciliation
§3.6 (Multilingual)	Bilingual EN + UR support	§13.5 Accessibility; AC-NOT-06	Bilingual notification templa locale-aware UI
§6 (14-step form)	Form fields, voice-to-text, severity hint, validation rules	§3.1 Evidence Visibility; §6.4 Reporter Quality Score	Form-completeness compon of quality score; voice transcr stored
§7 (Submission + Server processing)	Submission to server; alerts to supervisors	§4 Response Time & Delay Tracking; §13 Notification Strategy; §2 Lifecycle	SLA clock starts at SUBMITTE notifications fired; status boa updated
§7 (Upload limits)	Max 10 photos, 30s video	§3.4 Evidence Integrity; AC-EVD-01	Hash on upload; chain-ofcustody log
§7 (Postsubmission behavior)	Server-generated case ID; status updates	§2 Lifecycle; AC-INC-01	System-generated ID; state transitions; audit
§1 (iFar-Silexa scope)	Single-plant pilot in v1	§1.3 Audience; §7.1 Why Configurable; NFR-SCALE-01	Single-tenant v1; multi-tenar ready partitioning
§3.5 (Encryption at rest)	Mobile local data is encrypted	NFR-SEC-09; AC-OFF-05	MDM remote-wipe; encrypte local store
§3 (User roles)	Reporter / Supervisor / EHS / Compliance / Plant Manager	§14 RACI Matrix; NFR-SEC-04	Role-based access control; di control on unmask
RMG-1 (v1.2 NEW — RMG Production Context) (Figma prototype)	Cases are populated with buyer_name, style_number, production_order_id, sub_category, department to drive category-specific SLAs, owner suggestion, and impact reporting	§25 RMG Context Entities & Business Impact Governance; §14 Activities 13–17 post-triage ownership; §17.2 KPI "Total Production Impact"	RMG context attached at submission/triage; vw_total_production_imp aggregate
RMG-2 (v1.2 NEW — Business Impact) (Figma prototype)	Each case carries quantitative impact: affected_quantity, estimated_loss_usd ; losses above threshold trigger Financial Escalation	§25; §7.3 rule E-8 ; §17.2 KPI "Total Production Impact"	Server-side threshold check c every business_impact writ CFO + COO + Plant Manage notification
RMG-3 (v1.2 NEW — Investigation Lifecycle) (Figma prototype)	Investigation checklist, RCA review, CAPA execution, verification, with multi-stage approvals	§2.4 Post-Triage Operational Stages; §2.5 Approval Governance; §4.5 Investigation & CAPA SLAs; §26 Investigation & CAPA Governance	Checklist progress audit-logc CAPA verification rejection-lc 5-day composite budget
AI-GOV-1 (v1.2 NEW — Human-in-the-Loop AI) (Figma prototype)	AI summaries are Human-Validated; validated_by_user_id is mandatory for AI-assisted decisions	§9.8 AI Output Governance; §16.6.2 NFR-AI-*; §17 KPI "AI-Assisted Decisions Without Validation"	API-layer CHECK; DB-layer ro permissions; weekly Complia review

t

AUDIT-

COMMENT-1— Comment History Audit) (Figma	Internal collaboration, @-mentions, and system-generated annotations on a case MUST be captured as append-only, INSERT-only rows; bundled into the Case Audit Trail regulator export R-AU-01	\$12.1.13 case_comment_log; \$16.6.3 NFR-AUD-CMT-*	DB role INSERT-only; application-level mandatory INSERT path; bundled into R-AU-01 export
---	--	--	---

U))

AUDIT- METHOD-1	capture	\$2.4.3 Investigation Methodology Auditability; \$12.1.9 investigation_checklist_progress.investigation_methodology_used; OTHER); DB-level CHECK	API-layer CHECK (≥ 50 chars Every INVESTIGATION case MUST
--------------------	---------	--	---

Epic 1 Section	Epic Requirement (paraphrased)	Governance Requirement (this spec)	Monitoring Capability
— Investigation Methodology Auditability) (Figma UI)	investigation_methodology_used; OTHER requires a mandatory rationale ≥ 50 chars; methodology changes are mirrored into case_state_log	\$16.6.3 NFR-AUD-METH-*	constraint; DB-level trigger mirrors into case_state_lo
AUDIT-CFG-1 — Configuration Audit Log) (Figma UI Admin panel)	Any create/update/delete on Notification Templates or Workflow Config MUST generate an immutable row in configuration_audit_log; audit row write is atomic with config write (fail-safe SERIALIZABLE transaction); dual-control on critical configs	\$13.6 Notification Template & Workflow Config — Configuration Audit Log; \$12.1.14 configuration_audit_log; \$18.7 Configuration Audit Log — Governance Binding; \$16.6.3 NFR-AUD-CFG-*	PostgreSQL SERIALIZABLE transaction wrapping config write + audit INSERT; security definer trigger function; CI test (AC-CFG-01) verifies atomicity
AI- FEEDBACK- — AI Insight Accuracy / Feedback Widget + Auto-Audit Feedback Loop) (Figma UI Compliance Dashboard)	Compliance Dashboard element #8 surfaces AI-Assisted Decisions Without Validation (KPI \$17.2), AI Suggestion Rejection Rate, and the AI Insight Feedback Stream; every negative AI-Insight user feedback MUST trigger an automatic case_comment_log row with comment_kind = "AI_SUMMARY_INLINE_REVIEW" (HTTP 422 on write failure)	\$10.4 Compliance Dashboard element #8; \$10.4.1 AI Insight Accuracy / Feedback Widget Binding Specification; \$12.1.13 case_comment_log.comment_kind = "AI_SUMMARY_INLINE_REVIEW"; \$17.2 KPI "AI-Assisted Decisions Without Validation"; \$9.8 AI Output Governance	API-layer enforcement of the auto-write obligation; DB-layer INSERT-only on case_comment_log; KPI recomputation hourly; R-AUregulator export enriched with the negative-feedback stream

19.3 Governance Requirement → Epic Cross-Reference (Reverse View)

Governance Requirement	Referenced In Epic 1	Referenced In Other Sections
Offline sync handling	\$3.5	\$8, AC-OFF-*, NFR-AVAIL-01/02/05
Anonymous-mode audit	\$3, \$3.2	\$9, AC-ANON-*, NFR-SEC-03/07
SLA tracking	\$3, \$7	\$4, \$7, AC-SLA-*, \$17 KPI "SLA Compliance %"
Evidence integrity	\$6, \$7	\$3, AC-EVD-*, NFR-SEC-08
Lifecycle states	\$3.5, \$7	\$2, AC-INC-*, \$12.1.1 case_state_log
Notifications	\$7	\$13, AC-NOT-*
Role-based access	\$3	\$14, NFR-SEC-04, AC-DASH-05
Multilingual support	\$3.6	\$13.5, AC-NOT-06

19.4 GrillMe Hardening — Traceability

Challenge Raised	Resolution
"What if an Epic requirement is added in a future revision that has no governance coverage in this spec?"	A traceability coverage check is run at every PRD change. Any Epic requirement without a row in \$19.2 triggers a spec update obligation before the Epic change can be released.
"What if a governance capability exists in this spec that is not traceable to an Epic requirement (i.e., a 'gold-plated' addition)?"	Such capabilities are explicitly listed in \$19.5 — Governance-Only Capabilities for transparency, and are flagged as [Governance-Only] . They are not removable by a future Epic change without an explicit decision.
"What if the data-model entity changes (e.g., a column rename) and traceability breaks?"	Every rename or migration must update \$12 and \$19 in the same change set. CI checks enforce referential integrity between the two sections.

19.5 Governance-Only Capabilities (Not Derived from Epic 1)

The following capabilities in this specification are governance additions, **not** required by Epic 1. They are listed here for transparency and to prevent silent removal during Epic revisions.

Capability	Spec Section	Why Added
Operational KPI catalog	\$17	Required to make monitoring meaningful; Epic 1 does not define operational KPIs.

RACI matrix	\$14	Required for ownership clarity; Epic 1 does not define role accountability.
Capability	Spec Section	Why Added
Non-functional requirements (NFRs)	\$16	Required for engineering quality; Epic 1 does not define NFRs.
Acceptance criteria (AC-*)	\$15	Required for engineering test design; Epic 1 does not define ACs.
Assumption & configuration governance	\$18	Required to distinguish hard / soft / configurable items; Epic 1 does not make this distinction.
Open questions register (Appendix A)	Appendix A	Carried forward from v1.0; pending business sign-off.
Identity-access audit log (separate from case log)	\$9.5	Required for SoD and anti-retaliation; Epic 1 does not specify the audit partition.
Mass-incident clustering	\$4.4	Required for notification DOS protection; Epic 1 does not specify clustering.
Phone-tree fallback for L1	\$13.5	Required for SMS-gateway failure; Epic 1 does not specify voice fallback.
Reconciliation job (partial sync detection)	\$8.5	Required for offline resilience governance; Epic 1 does not specify server-side reconciliation.
<code>case_comment_log</code> (Comment History audit trail) (v1.2 Final NEW)	\$12.1.13	Required by Figma UI to capture internal collaboration as an append-only, INSERT-only audit trail; bundled into RAU-01. Epic 1 does not specify a comment audit entity.
<code>investigation_methodology_used</code> (mandatory auditable field on <code>investigation_checklist_progress</code>) (v1.2 Final NEW)	\$2.4.3, \$12.1.9	Required by Figma UI to make the <i>how</i> of an RCA auditable, not only the <i>what</i> . Epic 1 does not specify methodology classification.
<code>configuration_audit_log</code> (Notification Template & Workflow Config governance) (v1.2 Final NEW)	\$13.6, \$12.1.14, \$18.7	Required by Figma UI Admin panel to make Admin-side configuration changes non-bypassably auditable. Epic 1 does not specify Admin-panel audit.
Compliance Dashboard element #8 — AI Insight Accuracy / Feedback widget + AI-Assisted Decisions Without Validation KPI + automatic negativefeedback <code>case_comment_log</code> write obligation (v1.2 Final Release NEW)	\$10.4 (element #8), \$10.4.1, \$17.2 (KPI), \$12.1.13 (auto-write binding clause)	Required by Figma UI Compliance Dashboard to surface AI-output governance posture and route all negative user feedback into the immutable Comment History audit trail. Epic 1 does not specify a widget-level AI feedback loop.

Appendix A — Open Questions for Business Sign-Off

The following items were identified during the GrillMe review and require explicit business input before this spec is considered "frozen":

#	Question	Default Assumption
OQ-1	Is the "no punitive blacklist" stance on reporter quality (§6.4) acceptable to HR?	Yes — default applied.
OQ-2	Should the Compliance Officer see all reporter identities, or only those under active antiretaliation review?	Compliance sees all by default, masked in normal views; antiretaliation mode unmask.
OQ-3	What is the maximum dwell time for <code>PENDING_EVIDENCE</code> before auto-escalation?	7 calendar days (configurable per §7).
OQ-4	Are mass-incident clusters to be visible to executives in real time, or only in post-event reports?	Real-time, on the Executive Dashboard as a single banner.
OQ-5	Should anonymous-report SLA targets be <i>more lenient</i> than manual-report SLAs to compensate for the loss of clarifying back-and-forth?	Default: same SLA. Business to confirm.
OQ-6	What is the policy for reporters who repeatedly file reports later determined to be nonincidents (e.g., 10 in a day, all L4)?	Default: no blacklist, but a "report-writing guidance" prompt is shown on the <i>next</i> submission.

OQ-7	For the phone-tree fallback (E-2), what is the source of truth for after-hours contact numbers?	HR system, synced nightly; manual override by Plant Manager permitted.
------	---	--

Appendix B — Spec-to-Epic Traceability

Spec Section	Epic 1 Reference
§2 Lifecycle	§3.5 (offline storage), §7 (post-submission behavior)
§3 Evidence	§6 (form fields), §7 (upload limits)
§4 Timing	§3 (timing rationale), §7
§5 Responsibility	§7 (server-side processing)
Spec Section	Epic 1 Reference
§8 Offline	§3.5 (offline-first storage)
§9 Anonymity	§3 (three reporting modes), §3.2 (anonymity guarantee)
§13 Notifications	§7 (server-side processing and alerts)
§14 RACI Matrix	§3 (User roles) — derived, see §19.5
§15 Acceptance Criteria	All sections — engineering test design
§16 NFRs	§3.5 (encryption at rest), implicit quality requirements
§17 KPI Reference	Operational layer — derived, see §19.5
§18 Assumption & Configuration Governance	All sections — clarifies Epic vs. Default vs. Configurable
§19 Traceability Matrix	Authoritative cross-reference (this spec → Epic 1)

Appendix C — v1.1 Final GrillMe Hardening Review

This appendix documents the **second-pass Socratic review** performed on the v1.1 expanded specification. The objective was to challenge ownership completeness, hidden operational risks, unmonitored incident states, SLA loopholes, audit gaps, security gaps, offline failure scenarios, notification failures, and data-consistency issues.

Each challenge is paired with the **specific section that resolves it**, demonstrating that the v1.1 specification is closed-loop rather than aspirational.

C.1 Ownership Completeness

Challenge Raised	Resolution in Spec
Is every governance step in the §14 RACI matrix assigned exactly one A (Accountable)?	§14.2 RACI Discipline Rule enforces "exactly one A per row" with quarterly Compliance review.
What if a role is vacant (night-shift Resolver, EHS on leave)?	§14.5: each row has a named backup; the activity A defaults to the next escalation level (E-2 fallback chain) if both are unavailable.
What if a small plant has no separate EHS Officer?	§14.5: role-consolidation rules permit one individual holding multiple columns, documented in the Plant Governance Charter.
What if the Reporter is the only person who saw the incident and is also the natural Resolver?	§14.5: <code>self_report</code> flag excludes the Reporter from the Resolver roster for that case.
Does the RACI remain valid after an HR re-org?	§14.5: quarterly RACI review is triggered by any role-architecture change.

C.2 Hidden Operational Risks

Challenge Raised	Resolution in Spec
What if a "CLOSED" case is actually still open in the field (e.g., recurring leak)?	§2.3 GrillMe: a <code>REOPENED</code> transition is permitted from <code>CLOSED</code> only, with mandatory justification; KPI "Reopened Incident Rate" surfaces the pattern.

What if Plant Manager is on leave and L1 escalations have no human receiver?	§7.4: E-2 has a 4-step fallback chain (on-duty EHS → backup EHS → Plant Manager → COO); AC-ESC-01 codifies this.
What if Compliance Officer's unmask action is challenged in court as improper?	§9.4 dual-control + §9.5 immutable audit log + §14 RACI Activity 10 audit review create a defensible chain.
What if the SLA matrix is silently changed to mask a breach?	§7.2 + §12.1.6: SLA matrix is versioned; the version active at submission is bound to the case forever. Reevaluating a closed case under a new matrix is analytical-only.
What if a power user files 100 reports/day to flood the system?	§6.4: reporter-quality score surfaces a "complete your report" hint; §17.3 forbids punitive league tables; KPI framework detects the pattern without victimizing the user.

C.3 Unmonitored Incident States

Challenge Raised	Resolution in Spec
Is every state in §2.1 covered by at least one monitoring capability?	Each state is referenced in §6 (Status Board), §13 (Notification Rules), or §17 (KPI catalog). PENDING_EVIDENCE , REJECTED , WITHDRAWN , and REOPENED are explicitly handled in §2.3 and §6.
Is DRAFT intentionally invisible?	§2.1: yes — drafts are invisible to management by design (anti-retaliation per Epic 1 §1).
Is SUBMITTED_LOCAL monitored despite being ondevice?	§8.2 / §8.3: pending-queue metrics and per-device sync-health are part of the monitoring surface.
Is the transition between IN_PROGRESS and PENDING_EVIDENCE monitored for gaming?	§4.4: PENDING_EVIDENCE frequency per owner is tracked (§5.4); 7-day cap prevents indefinite pause.

C.4 SLA Loopholes

Challenge Raised	Resolution in Spec
Could an owner "pause" the SLA indefinitely by toggling PENDING_EVIDENCE ?	§4.1 + §4.4: PENDING_EVIDENCE dwell is capped at 7 days; per-owner frequency is tracked; idle clock is <i>paused</i> not <i>reset</i> .
Could a triager game Average Response Time by rushing triage?	§17.4: KPI is reported as median + p90 + p99, not just mean; Compliance Officer reviews triage-fast outliers monthly.
Could a coordinator mask a breach by reassigning to a slow worker?	§4.1 + AC-SLA-03: reassignment adds +50% of remaining time capped at the original resolution_due_at — the breach clock never extends beyond the original target.
Could a manager mute a notification to avoid a breach alert?	§7.4: escalation rules cannot be muted at user level; only Compliance Officer can pause with documented reason, and the pause is itself logged.
Could a 1-minute SLA miss be weaponized as a breach?	§4.4 + AC-SLA-01: 5-minute grace window (1-minute for L1) absorbs transient blips without losing the integrity of the measure.

C.5 Audit Gaps **Challenge Raised**

	Resolution in Spec
Could a DB administrator edit the audit log directly?	§12.3: DB role has INSERT-only on case_state_log , identity_access_audit , and evidence_export_log ; UPDATE/DELETE denied at schema level.
Could a Compliance Officer with DB access bypass the unmask audit?	§9.7: reporter-identifying columns are encrypted with a key held by a separate security officer; DB access alone does not reveal plaintext.
Could a malicious Compliance Officer unmask without a co-signer?	§9.4 + AC-ANON-05: dual-control is mandatory; the immutable audit log is replicated to a separate storage tier that Compliance cannot write to.

Could a case be "disappeared" by force-closing?	§2.2 + §3.5: state transitions are append-only; rejected cases are archived, not deleted; the case ID is preserved across reopen.
Could identity-access anomalies go unnoticed?	§10.4 Dashboard element #3 + §17.2 KPI "Identity-Access Audit Anomalies" + §9.5 weekly Compliance review.

C.6 Security Gaps

Challenge Raised	Resolution in Spec
Is encryption at rest enforced for both server and mobile?	NFR-SEC-01 (AES-256 at rest) + NFR-SEC-09 (mobile local encryption) + NFR-SEC-02 (TLS 1.2+ in transit).
Could a stolen device expose unsubmitted drafts?	AC-OFF-05: MDM remote-wipe erases local data within 5 minutes; data is encrypted at rest on the device.
Could RBAC be bypassed by direct API access?	NFR-SEC-04: RBAC enforced at API gateway and DB layer (defense in depth).
Could a backdoor account be created?	NFR-SEC-11: secrets management is HSM-backed with no plaintext in config; account creation is itself logged.
Could pen-testing gaps allow unnoticed vulnerabilities?	NFR-SEC-12: annual external + quarterly internal pen-tests.

C.7 Offline Failure Scenarios

Challenge Raised	Resolution in Spec
What if the report syncs but the media fails (partial sync)?	§8.5 + AC-OFF-03: report is accepted with <code>media_partial = true</code> ; reconciliation job runs hourly; autoretry for 72h.
What if media is large (e.g., 30s video) and network is slow?	§8.2: queue persists on device up to 72h; partial failures are retried independently of the report record.
What if a device is offline for 3+ days?	§8.3: per-device <code>last_sync_at</code> triggers amber at 24h, red at 48h; user-prompt at 7 days; IT-Ops review at 30 days.
What if a device is lost with 10 unsynced reports?	§8.6 + AC-OFF-05: encryption at rest + MDM remote-wipe.
What if two devices submit near-identical reports offline?	§8.6: server-side dedup by (<code>device_id</code> , <code>device_submission_uuid</code>); content similarity is also checked.
What if the MNO is down for the whole region?	§8.4: MNO-aware stale-state alerts distinguish "no network" (expected) from "sync failing" (alarm). C.8

Notification Failures

Challenge Raised	Resolution in Spec
What if the push channel is unacknowledged for an L1?	§13.5 + AC-NOT-02: SMS fires at 60s unack; phone-tree voice at 120s unack.
What if the SMS gateway is down?	§13.5: phone-tree fallback uses on-prem SIP gateway, no internet dependency.
What if the recipient is on leave?	§13.5: notifications auto-route to coverage proxy; original recipient receives digest on return.
What if a flood of L1s becomes a notification DOS?	§4.4: mass-incident clustering collapses notifications to one per cluster.
Challenge Raised	Resolution in Spec
What if the recipient cannot read English?	§13.5 + AC-NOT-06: substantive content in EN + UR; voice calls in English with Urdu SMS follow-up.
What if a user mutes notifications?	§13.5: L1 notifications cannot be muted; they must reach at least one verified channel.

C.9 Data Consistency Issues

Challenge Raised	Resolution in Spec
What if the server clock drifts?	§4.4: all SLA times computed from server timestamps; device time is informational.
What if a state transition is partially committed?	NFR-REL-01: state transitions are atomic; partial state is unrepresentable.

What if the same transition is replayed?	NFR-REL-03: transitions are idempotent; re-applying is a no-op.
What if two devices report the same incident?	§6.5 + NFR-REL-02: server-side dedup by device_id + device_submission_uuid; content similarity check.
What if the SLA engine is restarted mid-day?	NFR-AVAIL-07: in-flight SLA timers are recovered from persistent sla_clock rows within 5 minutes.
What if the reconciliation job is missed?	NFR-AVAIL-08: missed runs are detected and re-fired within 30 minutes.
What if identity_access_audit grows unboundedly?	§12.3: monthly partitioning; archived partitions remain queryable.
reWhat if a case is reopened years later?	§12.3: sla_clock is bound to sla_matrix_version at submission; reopen is a new event that does not derive SLAs.

C.10 Resolution Coverage Map

The table below summarizes where each GrillMe challenge category is resolved in the v1.1 specification.

Challenge Category	Primary Resolutions	Supporting Resolutions
Ownership completeness	§14 (RACI), §5 (Responsibility)	§10 (Dashboards), §17 (KPIs)
Hidden operational risks	§7 (Escalation), §9 (Identity Escrow)	§12 (Data Model), §6 (Status Monitoring)
Unmonitored incident states	§6 (Status), §13 (Notifications), §17 (KPIs)	§2 (Lifecycle), §8 (Offline)
SLA loopholes	§4 (Timing), §17 (KPIs)	§7 (SLA Config), §12 (Data Model)
Audit gaps	§9 (Identity Audit), §12 (Data Model)	§3 (Evidence), §14 (RACI Activity 10)
Security gaps	NFR-SEC-* (all 12)	§9 (Anonymity), §3 (Evidence)
Offline failure scenarios	§8 (Offline), AC-OFF-*	§6 (Status), §13 (Notifications)
Notification failures	§13 (Notifications), AC-NOT-*	§4 (Timing), §7 (Escalation)
Data consistency	NFR-REL-* (all 8), §12 (Data Model)	§4 (Clock authority), §7 (SLA matrix versioning)

C.11 v1.1 Submission Readiness Statement

The v1.1 specification has been reviewed against the categories above. For every challenge category, at least one resolution exists in the spec, and every resolution is itself a testable Acceptance Criterion (AC-INC-, AC-SLA-, AC-ESC-, AC-OFF-, AC-EVD-, AC-ANON-, AC-DASH-, AC-NOT-) or a measurable NFR (NFR-PERF-, NFR-AVAIL-, NFR-SEC-, NFR-SCALE-, NFR-REL-*). The specification is therefore **closed-loop** (every requirement has a measurable outcome), **traceable** (§19 maps every governance requirement back to Epic 1), and **governable** (§17 KPI catalog + §14 RACI matrix + §18 Configuration Governance ensure nothing is unowned). It is fit for **stakeholder submission, engineering implementation, and compliance review**.

End of v1.1 Specification Body — preserved verbatim below as the canonical base for the v1.2 consolidation.

v1.2 Patch — Epic 1 Monitoring Coverage Gaps

Editorial Note (v1.2 consolidation). The text below is the **original v1.2 patch** as authored against the v1.1 file. In this consolidated v1.2 file, the patch is the authoritative source for §20–§24 (Guest Mode & QR, Report-on-Behalf, Dispute, Funnel, KPI/Traceability Addendum). **No content of this patch has been rewritten or removed.** Editorial cross-references have been added in inline markers where v1.2 introduces adjacent new sections (§25–§27).

Document ID: FS-IMG-SPEC-001-PATCH **Version:** 1.2 (patch to v1.1) **Status:** Patch-Ready — now consolidated into v1.2 **Classification:** Internal — Operational Governance **Owner:** Product & Operational Governance Office **Scope:** Append-only monitoring coverage for Epic 1 capabilities that were not addressed in the v1.1 base specification. **No existing section of v1.1 has been rewritten or removed.** All new sections are appendices continuing the §-numbering convention of v1.1 and have been merged into the consolidated v1.2 base document.

Change Log:

Version	Date	Summary of Change
1.2	2026-	Append-only coverage add: §20 Guest Mode & QR Entry Point Monitoring (US-1, US-6); §21 Report-on-Behalf Monitoring (US-8); §22 Rejection Dispute Monitoring (US-7); §23 Reporter Submission Funnel Monitoring (US-1/2/3/6/7); §24 KPI & Traceability Addendum. Every

(patch) 06-29

addition traces to a specific Epic 1 User Story.

Traceability to Epic 1 User Stories:

Epic 1 User Story	Patch Section(s)
US-1 (Login + Guest Mode + QR entry points)	\$20, \$23
US-2 (14-step submission flow)	\$23
US-3 (Voice / text / evidence)	\$23
US-6 (QR-assisted location prefill, QR source metadata)	\$20, \$23
US-7 (Reporter can dispute a rejection)	\$22
US-8 (Report-on-behalf)	\$21

GrillMe Notice (v1.2 patch). This patch has been subjected to a **third** Socratic review pass focused on the four Epic 1 capabilities omitted from v1.1. The review challenged privacy (guest mode), conflict-of-interest (on-behalf), SLA loopholes (dispute timing), and PII leakage in funnel telemetry. Findings are woven directly into the new sections as hardened resolutions, never segregated to an appendix.

20. Guest Mode & QR Entry Point Monitoring

Source: Epic 1 US-1 (Login, Guest Mode, QR as three access entry points) and US-6 (QR-assisted location prefill, QR source metadata).

Gap Addressed: The v1.1 base spec monitors only login-based (Manual, Anonymous, Confidential) reports. **Guest sessions and QR codes are completely unmonitored.** A guest-mode reporter who never completes a submission is invisible, and a defective QR code at a factory line is a safety blind spot.

20.1 Guest Session Lifecycle States

State	Definition	Monitoring Concern
GUEST_STARTED	Guest session opened; no identity captured	Entry-point volume
GUEST_IDENTIFIED	Guest has been issued a temporary <code>guest_session_id</code> (UUID, not linked to any user row)	Funnel gate
GUEST_LINKED_TO_CASE	Guest session has been attached to a submitted case	Conversion
GUEST_ABANDONED	Session ended (timeout 30 min) without a linked case	Abandonment KPI
GUEST_EXPIRED	Session reached its TTL or was force-revoked	Audit

Privacy Rule (GrillMe). Guest mode **does not** persist any reporter-identifying artefact. The `guest_session_id` is a random UUID, generated on-device, and is not bound to a device serial, IP, or employee record. It is solely a correlation key for funnel analysis and is purged 30 days after `GUEST_ABANDONED` or `GUEST_LINKED_TO_CASE`.

20.2 Guest Mode KPIs

KPI	Calculation	Owner	Review Frequency
Active Guest Sessions	<code>count(guest_session_log where state in (GUEST_STARTED, GUEST_IDENTIFIED))</code> sampled every 5 min	Plant Manager	Real-time (Supervisor Dashboard)
Guest Abandonment Rate	<code>count(GUEST_ABANDONED) / count(GUEST_STARTED)</code> over the period	Plant Manager	Daily
Guest → Submission Conversion %	<code>count(GUEST_LINKED_TO_CASE) / count(GUEST_STARTED)</code>	Plant Manager	Weekly

20.3 QR Code Health (per Factory)

Epic 1 US-6 defines QR codes as a source of **location prefill** and **QR source metadata**. A defective or expired QR is a safety degradation: a worker scans a broken QR and either gives up or files a manual report with no GPS prefill.

QR State	Definition	Monitoring Concern
QR_ACTIVE	Code is enabled in the QR registry; scans produce valid prefill	Healthy
QR_EXPIRED	Code has reached its <code>valid_until</code> timestamp	Must be rotated
QR_DISABLED	Code has been administratively disabled (e.g., line decommissioned)	Auditable, not deletable

QR_INVALID_SCAN

Scan returned no registry match (e.g., printed code, forged, or read error)

Possible tampering OR printing degradation

20.3.1 qr_health_event Data Model

Field	Type	Notes
id	UUID	PK
factory_id	UUID	FK
qr_code_id	UUID	FK → qr_registry.id
event_type	enum	QR_SCAN_OK, QR_SCAN_EXPIRED, QR_SCAN_DISABLED, QR_SCAN_INVALID, QR_ROTATED
scanned_at	timestamp	Server time
session_kind	enum	LOGIN, GUEST, ANONYMOUS — which entry point consumed the QR
prefill_applied	bool	Did the QR populate location + factory metadata
device_id_hash	string	One-way hash, rotated; not linked to user

20.3.2 guest_session_log Data Model

Field	Type	Notes
id	UUID	PK = guest_session_id
factory_id	UUID	Optional; set when QR prefill is applied
started_at	timestamp	Server time
last_event_at	timestamp	For timeout calculation
terminal_state	enum	GUEST_LINKED_TO_CASE, GUEST_ABANDONED, GUEST_EXPIRED
linked_case_id	UUID	Nullable; FK → cases.id
purge_after	timestamp	terminal_state.timestamp + 30 days

20.4 QR Conversion Funnel

Funnel Checkpoint	Definition	KPI
QR_SCANNED	A QR scan is registered	Volume
QR_PREFILL_APPLIED	Scan produced valid prefill consumed by the form	Conversion Rate
QR_SUBMITTED	Report filed using QR prefill	End-to-end conversion

KPI — QR Scan-to-Submission Conversion Rate: `count(QR_SUBMITTED) / count(QR_SCANNED)` over the period.

20.5 Alerts

Alert	Condition	Recipients	Channel
QR_LOW_CONVERSION	QR Scan-to-Submission Conversion Rate < 60% over a 7-day window for any factory	Plant Manager	Push + Email
GUEST_MODE_DISABLED_MID_SHIFT	Administrative toggle flips <code>Guest Mode = OFF</code> between 06:00 and 22:00 local time on a working day	Compliance Officer	Push + Email
QR_INVALID_SCAN_BURST	> 20 <code>QR_SCAN_INVALID</code> events in a 1-hour window from the same factory	IT-Ops	Email
QR_EXPIRED_NO_ROTATION	A <code>QR_EXPIRED</code> code is not replaced within 24h of expiry	Plant Manager	Push

GrillMe Hardening. The 60% threshold is **[Default]** per §18.3 and is exposed in the configuration UI for Plant Manager tuning. The 20-scan burst threshold is **[Configurable]** to absorb seasonal printing-degradation events (e.g., monsoon humidity smudging codes).

20.6 GrillMe Hardening — Guest Mode & QR

Challenge Raised	Resolution
"Can a guest session be re-used to spam the system?"	<code>guest_session_id</code> is single-use for case linkage; replay attempts are deduplicated server-side. The session is also rate-limited to 5 form-open attempts before <code>GUEST_EXPIRED</code> is forced.

"What if a QR code is printed on a sticker and a worker scans a photocopy at home?"	QR_SCAN_INVALID is recorded with <code>prefill_applied = false</code> ; the form falls back to manual location entry. The metric is included in the burst alert.
"What if a guest reporter is actually a logged-in employee trying to bypass the audit trail?"	The guest session does not suppress the option to log in. If the device is logged in, the app steers the user to the Manual flow; Guest Mode is presented only when no session exists.
"Can guest-mode PII be inferred by linking <code>guest_session_id</code> to QR scan + GPS + timestamp?"	No <code>guest_session_id</code> is ever joined to a <code>users</code> row, an <code>identity_access_audit</code> row, or a <code>cases.reporter_id</code> . The Privacy Rule in §20.1 is enforced by DB role permissions (no FK to <code>users</code>).

Challenge Raised	Resolution
------------------	------------

"What if Guest Mode is disabled at 14:00 while The `GUEST_MODE_DISABLED_MID_SHIFT` alert fires immediately; disabling Guest Mode does **not** silently workers are mid-shift?" strand in-flight sessions — in-flight guests receive a one-time banner instructing them to log in to complete. 20.7 Acceptance Criteria — Guest Mode & QR

ID	Criterion
ACQR-01	Given a worker scans a <code>QR_ACTIVE</code> code at a factory location, When the scan is processed, Then a <code>qr_health_event</code> row is created with <code>event_type = QR_SCAN_OK</code> , <code>prefill_applied = true</code> , the location + factory metadata is prefilled into the form, and the scan is counted toward the QR Scan-toSubmission Conversion Rate KPI.
ACQR-02	Given the QR Scan-to-Submission Conversion Rate for any factory falls below 60% over a 7-day window, When the daily KPI refresh runs, Then the <code>QR_LOW_CONVERSION</code> alert is fired to the Plant Manager via push + email within 5 minutes, and the alert is logged in <code>escalation_event</code> with <code>rule_id = "E-GUEST-QR-1"</code> .
ACQR-03	Given Guest Mode is administratively toggled OFF between 06:00 and 22:00 local time on a working day, When the toggle is committed, Then the <code>GUEST_MODE_DISABLED_MID_SHIFT</code> alert is sent to the Compliance Officer within 60 seconds, in-flight guest sessions are notified via an in-app banner, and the toggle event is recorded in the immutable configuration-change log.

21. Report-on-Behalf Monitoring

Source: Epic 1 US-8 — an authorized user files a report for another worker or verbal source.

Gap Addressed: The v1.1 base spec has **zero** monitoring, audit trail, or RACI for the report-on-behalf flow. A supervisor filing on behalf of a verbal-source witness is a regulator-relevant activity that must be observable, attributable, and protected against conflict of interest.

21.1 On-Behalf Semantics

Element	Treatment
<code>creator_id</code>	The authorized user who actually filed the report (always stored, always visible to Compliance + Plant Manager).
<code>affected_worker_id</code>	The worker on whose behalf the report is filed (nullable if the source is purely verbal and unidentified).
<code>reported_by</code>	The reporting channel as seen by management: a fixed value <code>ON_BEHALF</code> (distinct from <code>SELF</code> , <code>ANONYMOUS</code> , <code>CONFIDENTIAL</code>).
<code>source_verbal</code>	bool — true when the source is verbal and no on-record witness exists.

21.2 Conflict-of-Interest Detection

A on-behalf report where the **creator and the affected worker share a production line** is a structural conflict of interest: the same person is both filing the report and being impacted by the underlying conditions.

Rule SELF_LINE_REPORT: If `creator.production_line_id == affected_worker.production_line_id` AND `affected_worker_id IS NOT NULL`, the system flags the case with `SELF_LINE_REPORT = true`.

Field	Type	Notes
<code>creator_id</code>	UUID	FK → <code>users.id</code> (always stored)
<code>affected_worker_id</code>	UUID	FK → <code>users.id</code> , nullable
<code>source_verbal</code>	bool	
<code>self_line_report</code>	bool	Computed at submit; visible to Compliance Officer + Plant Manager
<code>relationship_note</code>	text	Free-text justification supplied by creator at submission (mandatory when <code>self_line_report = true</code>)

21.3 On-Behalf Counts (KPI)

KPI	Calculation	Owner	Review Frequency
On-Behalf vs Self-Reported Ratio	<code>count(cases where reported_by = ON_BEHALF) / count(cases)</code> over the period	Compliance Officer	Monthly
SELF_LINE_REPORT Flag Rate	<code>count(cases where self_line_report = true) / count(cases where reported_by = ON_BEHALF)</code> over the period	Compliance Officer	Monthly
Verbal-Source Share	<code>count(cases where source_verbal = true) / count(cases where reported_by = ON_BEHALF)</code> over the period	Compliance Officer	Quarterly

21.4 Visibility Rules

Role	Sees <code>creator_id</code> ?	Sees <code>affected_worker_id</code> ?	Sees <code>self_line_report</code> flag?
Compliance Officer	Yes	Yes	Yes
Role	Sees <code>creator_id</code> ?	Sees <code>affected_worker_id</code> ?	Sees <code>self_line_report</code> flag?
Plant Manager	Yes	Yes	Yes
Supervisor	No (masked as "Reporter A") per §9.3	Only if the affected worker is on the supervisor's own team	No
EHS Officer	No	Yes (if L1/L2)	No
Resolver	No	Yes (if assigned the case)	No

Confidentiality Interaction (GrillMe). The `reported_by = ON_BEHALF` field is **always** visible to all back-office roles that can see the case, but `creator_id` follows the **confidential-report** visibility rules of §9.3. In other words: the fact that a report was filed on-behalf is **never** confidential; the identity of the creator follows the same masking as any other reporter.

21.5 RACI Addendum — Report-on-Behalf

Note (GrillMe). This row is an **addendum** to §14.3 RACI Matrix and is scheduled to be merged into the §14.3 main matrix at the next quarterly review (§1.6). Until that merge, this addendum is the authoritative reference for the on-behalf activity.

#	Lifecycle Activity	Reporter	Supervisor	Resolver	Plant Manager	Compliance Officer	EHS Officer	IT Operations	Executive Mgmt
11	File Report-on-Behalf (US-8)	R/A (as creator)	C (if the affected worker is on the supervisor's team)	—	I	I	—	—	—
12	Review SELF_LINE_REPORT Flags	—	—	—	C	R/A	—	—	—

Notes on the addendum:

- Activity 11:** The creator is **R/A** for filing the report. The supervisor is **C** only when the affected worker is on their team — otherwise the supervisor has no governance relationship to the report at filing time.
- Activity 12:** **SELF_LINE_REPORT** flag review is owned end-to-end by Compliance. Plant Manager is **C** (informed + consulted for action) but not **R** — Compliance retains independence in the review.
- The Reporter column for Activity 11 refers to the **creator**, not the affected worker; the affected worker is the **subject**, not the actor.

21.6 on_behalf_log Data Model

Append-only record of every on-behalf report. This log is distinct from `case_state_log` so that on-behalf activity can be reviewed independently for conflict-of-interest patterns.

Field	Type	Notes
<code>id</code>	UUID	PK
<code>case_id</code>	UUID	FK → <code>cases.id</code>
<code>creator_id</code>	UUID	FK → <code>users.id</code> (always stored; visibility per §21.4)
<code>affected_worker_id</code>	UUID	FK → <code>users.id</code> , nullable
<code>source_verbal</code>	bool	
<code>self_line_report</code>	bool	Computed at submit
<code>relationship_note</code>	text	Mandatory when <code>self_line_report = true</code>
<code>creator_production_line_id</code>	UUID	Denormalized for fast SELF_LINE_REPORT evaluation
<code>submitted_at</code>	timestamp	Server time
<code>ip_session_hash</code>	string	One-way hash; for tamper-evidence, not identity

21.7 GrillMe Hardening — On-Behalf

Challenge Raised	Resolution
"What if the creator and the affected worker are the same person (self-on-behalf)?"	Self-on-behalf is prohibited by business rule . The form rejects the submission with a clear error: "You cannot file on your own behalf; use the standard submission flow." This rule is enforced server-side, not just client-side.
"What if the creator is the affected worker's direct line supervisor?"	The system still records the report. The <code>SELF_LINE_REPORT</code> flag is true (same production line). Compliance Officer reviews the case in the context of the supervisor-employee relationship. This is intentional — a worker must be able to escalate via their supervisor.
"Can a creator retaliate against a noncooperating worker by filing a false onbehalf report?"	The <code>relationship_note</code> is mandatory when <code>self_line_report = true</code> , creating a contemporaneous justification. The Anti-Retaliation Pattern Review (§9.6) is the systemic check; the on-behalf log is the per-case check.
"What if the affected worker later files a conflicting report?"	The system surfaces the case pair to the Compliance Officer in the Identity-Access Audit Anomalies view. Conflicting reports are not auto-merged; they are reviewed.

Challenge Raised	Resolution
"What about a guest-mode creator filing <code>creator_id</code> ."	Guest mode cannot be used for on-behalf filing. The form requires an authenticated session to capture the on-behalf?"

21.8 Acceptance Criteria — Report-on-Behalf

ID	Criterion
ACOBO-01	Given an authorized user files a report with <code>affected_worker_id</code> set to themselves, When the submission is attempted, Then the server rejects the request with HTTP 422 and a "self-on-behalf prohibited" message; no <code>on_behalf_log</code> row is created.
ACOBO-02	Given an authorized user files a report on-behalf of a worker on the same production line, When the submission is committed, Then a <code>on_behalf_log</code> row is created with <code>self_line_report = true</code> , the <code>relationship_note</code> is mandatory and validated as non-empty, the case is flagged in the Compliance Dashboard under "Open SELF_LINE_REPORT cases", and the Compliance Officer receives a push notification within 5 minutes.
ACOBO-03	Given a Supervisor opens a case filed on-behalf, When the case view loads, Then the <code>creator_id</code> is masked as "Reporter A" and the <code>self_line_report</code> flag is hidden, while a Compliance Officer opening the same case sees both unmasked — visibility rules of §21.4 enforced at the API layer and verified by an automated privacy test.

22. Rejection Dispute Monitoring

Source: Epic 1 US-7 — Reporter can dispute a rejection.

Gap Addressed: The v1.1 base spec defines the `REJECTED` state (§2.1) but has **no SLA, no owner, and no monitoring** for the dispute process. A rejected report that is disputed and then ignored is both a safety risk and a legal exposure.

22.1 Dispute Sub-States

A disputed `REJECTED` case enters a parallel sub-state machine:

```
REJECTED —[Reporter disputes]—> DISPUTE_RAISED
DISPUTE_RAISED —[Compliance Officer opens review]—> DISPUTE_UNDER_REVIEW
DISPUTE_UNDER_REVIEW —[Compliance Officer upholds rejection]—> DISPUTE_UPHELD
DISPUTE_UNDER_REVIEW —[Compliance Officer reverses rejection]—> DISPUTE_DISMISSED
                                ↘ [re-opens original case → REOPENED]
```

Sub-State	Definition	Owner	SLA
<code>DISPUTE_RAISED</code>	Reporter has lodged a dispute; awaiting reviewer pickup	Compliance Officer	24h to start review
<code>DISPUTE_UNDER_REVIEW</code>	Reviewer is actively investigating the dispute	Compliance Officer	72h total to resolve (from <code>DISPUTE_RAISED</code>)
<code>DISPUTE_UPHELD</code>	Original rejection is confirmed correct	Compliance Officer	Terminal
<code>DISPUTE_DISMISSED</code>	Rejection is reversed; the original case is reopened	Compliance Officer	Terminal (reopens the case)

SLA Discipline (GrillMe). The 24h pickup SLA and the 72h resolution SLA are **[Default]** values per §18.3. They are exposed in the configuration UI for Compliance Officer tuning. The 72h total SLA is **inclusive** of the 24h pickup window — not additive. Reassignment of the dispute reviewer (e.g., for absence) does **not** extend the 72h cap.

22.2 Escalation Rule E-7 (NEW)

This section adds **E-7** to the default escalation table in §7.3. E-7 is a new rule introduced by the v1.2 patch.

Rule	Condition	Action
------	-----------	--------

E-7 **DISPUTE_RAISED** > 24h with no transition to **DISPUTE_UNDER_REVIEW** Notify Compliance Officer + Plant Manager (push + email)

GrillMe Hardening. E-7 fires **only** for the 24h pickup breach. The 72h resolution cap is enforced by a separate **sla_clock** row bound to the **dispute_review_due_at** timestamp; the breach is reported on the Compliance Dashboard but does not generate a duplicate notification, per §13.4 anti-spam rules.

22.3 RACI Addendum — Dispute Handling

Note (GrillMe). This row is an **addendum** to §14.3 and is scheduled to be merged into the main matrix at the next quarterly review (§1.6).

#	Lifecycle Activity	Reporter	Supervisor	Resolver	Plant Manager	Compliance Officer	EHS Officer	IT Operations	Executive Mgmt
13	Raise Dispute on Rejection (US-7)	R/A		—			—	—	—
14	Review Dispute (DISPUTE_RAISED → DISPUTE_UPHELD / DISMISSED)		C (original triager)	—	(accountable)	R/A	C (L1/L2)	—	—

Notes on the addendum:

- Activity 13:** The Reporter (the original filer) is **R/A** for raising the dispute. The original triager is **C** in Activity 14 because they hold context on the original rejection.
- Activity 14:** The **Plant Manager is Accountable, not the Compliance Officer**, even though the Compliance Officer is Responsible for the day-to-day review. This reflects the governance principle that the **outcome** (a defensible dispute resolution) is owned by Plant Manager; the **review activity** is owned by Compliance.

22.4 Compliance Dashboard Addition

The v1.1 Compliance Dashboard (§10.4) is extended with the following elements. To respect the §10.1 "no more than 7 visual elements" rule, the new elements **replace** element #6 (Reassignment rate by owner) only when the Compliance Officer has activated "Dispute Mode" in their dashboard preferences. Otherwise the v1.1 elements are unchanged.

#	Element (Dispute Mode)	Source	Notes
8	Open Disputes Count	§22.1	Stacked by sub-state; red if any dispute > 24h
9	Dispute Outcome Rate (30d)	§22.5 KPI	DISMISSED / (UPHELD + DISMISSED)
10	E-7 Firings (7d)	§22.2	Count + last-fired timestamp

22.5 KPIs

KPI	Calculation	Owner	Review Frequency
Open Disputes Count	<code>count(disputes where terminal_state IS NULL)</code> at sample time	Compliance Officer	Real-time (Compliance Dashboard)
Dispute Pickup SLA Compliance %	<code>count(disputes where first action timestamp - raised_at ≤ 24h) / count(disputes raised in period)</code>	Compliance Officer	Weekly
Dispute Outcome Rate	<code>count(DISPUTE_DISMISSED) / count(DISPUTE_UPHELD + DISPUTE_DISMISSED)</code> over the period	Compliance Officer	Monthly

22.6 GrillMe Hardening — Dispute

Challenge Raised	Resolution
"What if the original Reporter cannot be contacted for clarification during the dispute?"	The dispute review is documentary; the system does not require Reporter contact. The original report content + dispute reason are sufficient basis for the review.
"What if a Compliance Officer upholds a rejection that is later shown to be wrong (e.g., a regulator reverses it)?"	The dispute log preserves DISPUTE_UPHELD permanently; the case can be reopened via the §2.3 REOPENED transition with a mandatory justification. The pattern is surfaced in the Reopened Incident Rate KPI.
"What if a Reporter disputes the same rejection twice?"	A rejection can be disputed once . A second dispute attempt returns a "dispute already resolved" message and links to the original dispute outcome.
"What if the 72h resolution SLA is missed over a weekend?"	The SLA is calendar hours , not business hours, for L1/L2 disputes. For L3/L4 disputes, the operationalhours mode (§4.4) applies.

"What if a Plant Manager tries to suppress a dispute notification?"	Escalation rule E-7 cannot be muted at user level (§7.4). Plant Manager suppression attempts are logged in the <code>escalation_event</code> audit log.
---	---

22.7 Acceptance Criteria — Dispute

ID	Criterion
AC-DIS-01	Given a case is in <code>REJECTED</code> state and the original Reporter submits a dispute, When the dispute is recorded, Then a <code>dispute</code> row is created with <code>terminal_state</code> = <code>DISPUTE_RAISED</code> , <code>dispute_review_due_at</code> = <code>raised_at</code> + 72h, and the <code>sla_clock</code> for the dispute is bound to the <code>sla_matrix_version</code> active at dispute submission.
AC-DIS-02	Given a dispute is in <code>DISPUTE_RAISED</code> state, When 24 hours elapse without a transition to <code>DISPUTE_UNDER_REVIEW</code> , Then escalation rule E-7 fires, push + email is sent to the Compliance Officer + Plant Manager within 5 minutes, and an <code>escalation_event</code> row is created with <code>rule_id</code> = "E-7".
AC-DIS-03	Given a Compliance Officer resolves a dispute as <code>DISPUTE_DISMISSED</code> , When the resolution is committed, Then the original case transitions to <code>REOPENED</code> with mandatory justification, the original <code>case_id</code> is preserved, the new SLA matrix version is not re-applied (per §2.3), and the Reopened Incident Rate KPI is incremented.

23. Reporter Submission Funnel Monitoring

Source: Epic 1 US-1 (three entry points), US-2 (14-step form), US-3 (voice, text, evidence), US-6 (QR prefill), US-7 (rejection path). **Cross-cutting.**

Gap Addressed: Epic 1 is built around the Reporter persona completing a 14-step form. The v1.1 base spec monitors everything **after** submission but **nothing during** submission. A report never completed is completely invisible to management — and that invisibility is itself a safety signal (worker gave up, form too long, step too confusing).

23.1 Privacy Rule (Binding, GrillMe-Hardened)

PRIVACY RULE. Funnel events carry **only** a `session_id` (UUID). The `session_id` is **not** linked to a `users` row, a `device_id`, an `ip_address`, a `reporter_id`, or any other identifier. The funnel is designed to answer "where do reporters drop off?" — never "who dropped off?". An employee exercising the right to abandon a draft has an absolute right to do so without surveillance.

This rule is enforced at the **DB role level** (no FK to `users`, no nullable column for identity on `funnel_event`).

23.2 Funnel Checkpoints

Checkpoint	Fired When	Step-Number in Epic 1
<code>SESSION_START</code>	A session (any entry point) is opened	n/a
<code>FLOW_ENTERED</code>	Reporter enters the 14-step form	n/a
<code>STEP_CATEGORY</code>	Step 1 (incident category) completed	1
<code>STEP_LOCATION</code>	Step 2 (location, may be QR-prefilled)	2
<code>STEP_SEVERITY</code>	Step 3 (severity hint)	3
<code>STEP_DESCRIPTION</code>	Steps 4–6 (description; voice or text)	4–6
<code>STEP_EVIDENCE</code>	Steps 7–13 (evidence: photos, audio, video)	7–13
<code>SUBMIT_ATTEMPTED</code>	Submit button tapped	14
<code>SUBMIT_SUCCESS</code>	Server returns case ID	post-14
<code>FLOW_ABANDONED</code>	Session terminates (timeout, app close, back-out) before <code>SUBMIT_SUCCESS</code>	n/a

23.3 Funnel Event Data Model

Field	Type	Notes
<code>id</code>	UUID	PK
<code>session_id</code>	UUID	Random, unlinkable to any user row
<code>checkpoint</code>	enum	One of the 10 values in §23.2
<code>entry_point</code>	enum	<code>LOGIN</code> , <code>GUEST</code> , <code>ANONYMOUS</code> — which of the three access entry points the session used
<code>qr_prefill_applied</code>	bool	True if <code>STEP_LOCATION</code> was QR-prefilled (US-6)

severity_hint	enum	L1–L4, set at STEP_SEVERITY; nullable for sessions that did not reach that step
voice_used	bool	True if any voice-to-text was captured at STEP_DESCRIPTION
evidence_count	int	Number of evidence artifacts attached by STEP_EVIDENCE; 0 if not reached
device_timestamp	timestamp	Informational
server_timestamp	timestamp	Authoritative
metadata_json	JSONB	Extensible; must not contain any PII per §23.1

GrillMe Hardening. The severity_hint, voice_used, evidence_count, and qr_prefill_applied fields are **aggregate form-state flags** — they describe the content of the form at the moment of the checkpoint, not the person. They are explicitly permitted under the Privacy Rule because they cannot be reverseengineered into a reporter identity.

23.4 Funnel KPIs

KPI	Calculation	Owner	Review Frequency
Submission Completion Rate	count(SUBMIT_SUCCESS) / count(SESSION_START) over the period	Plant Manager	Weekly
Step Drop-off Rate (per step)	count(funnel_event where checkpoint = STEP_X) – count(funnel_event where checkpoint = STEP_X+1) (per step, per period)	Product Owner	Bi-weekly
Voice vs Text Adoption	count(funnel_event where checkpoint = STEP_DESCRIPTION and voice_used = true) / count(funnel_event where checkpoint = STEP_DESCRIPTION)	Product Owner	Monthly
Evidence Attachment Rate	count(funnel_event where checkpoint = STEP_EVIDENCE and evidence_count > 0) / count(funnel_event where checkpoint = STEP_EVIDENCE)	EHS Officer	Monthly
QR Entry Share	count(funnel_event where entry_point = LOGIN and qr_prefill_applied = true) + count(funnel_event where entry_point = GUEST and qr_prefill_applied = true) divided by count(SESSION_START)	Plant Manager	Monthly

KPI	Calculation	Owner	Review Frequency
Anonymous Funnel Completion %	count(funnel_event where entry_point = ANONYMOUS and checkpoint = SUBMIT_SUCCESS) / count(funnel_event where entry_point = ANONYMOUS and checkpoint = SESSION_START)	Compliance Officer	Monthly

23.5 Funnel Drop-off Alerts

Alert	Condition	Recipients	Channel
FUNNEL_DROP_STEP_EVIDENCE	> 40% of sessions that reach STEP_DESCRIPTION fail to reach STEP_EVIDENCE over a 7-day window	Product Owner	Email
FUNNEL_DROP_SUBMIT	SUBMIT_ATTEMPTED → SUBMIT_SUCCESS drop > 10% over a 7-day window (suggests server-side submission failure)	IT-Ops + Plant Manager	Push + Email
VOICE_ADOPTION_LOW	option < 20% at any factory over a 30-day window	Product Owner	Email

23.6 GrillMe Hardening — Funnel

Challenge Raised	Resolution
"What if a worker abandons a draft and the funnel data is then used to identify them?"	The Privacy Rule in §23.1 is enforced by schema-level constraints : funnel_event has no nullable column for any reporter identifier. Even a developer with DB access cannot link a session_id to a users row.
"What if a worker uses the app on a shared device — does the session mix with someone else's?"	Sessions are not user-scoped. The session_id is fresh per app launch, regardless of who is using the device. There is no concept of "the same user's funnel" — by design.
"What if funnel data is correlated with Wi-Fi logs to identify a device?"	The funnel_event table stores no network metadata (no MAC, no IP, no SSID). The Privacy Rule explicitly forbids adding such columns without a spec amendment.

"What if a sudden drop in <code>SUBMIT_SUCCESS</code> is actually a server outage?"	The <code>FUNNEL_DROP_SUBMIT</code> alert is dual-routed to IT-Ops (technical) and Plant Manager (operational) so the cause is investigated from both angles. The alert is suppressed if NFR-AVAIL-03 (dashboard availability) is itself in breach.
"What about the right to be forgotten — can a worker request funnel data deletion?"	The funnel data is anonymous by construction; there is no PII to delete. The right-to-be-forgotten workflow (per §9.7) does not apply to <code>funnel_event</code> . The Privacy Rule is documented in the user-facing privacy notice.

23.7 Acceptance Criteria — Funnel

ID	Criterion
AC-FUN-	Given a Reporter (any entry point) starts a session and reaches <code>STEP_CATEGORY</code> , When the Reporter abandons the session before <code>SUBMIT_SUCCESS</code> , Then a <code>funnel_event</code> row with <code>checkpoint = FLOW_ABANDONED</code> is recorded carrying only <code>session_id</code> and aggregate form-state flags — no <code>users</code> join, no <code>01_device_id</code> , no <code>ip_address</code> , verified by an automated privacy test.
AC-FUN-02	Given the Submission Completion Rate for any factory falls below 50% over a 7-day window, When the daily KPI refresh runs, Then a <code>FUNNEL_LOW_COMPLETION</code> advisory (informational only) is sent to the Product Owner, and the metric is added to the Weekly KPI Scorecard.
AC-FUN-03	Given a Reporter using QR prefill reaches <code>STEP_LOCATION</code> , When the QR prefill is applied, Then <code>qr_prefill_applied = true</code> is recorded on the <code>funnel_event</code> for <code>STEP_LOCATION</code> , and the QR Entry Share KPI is incremented for that factory.

24. KPI & Traceability Addendum

This section extends the §17.2 KPI Catalog and the §19.2 Traceability Matrix with rows introduced by the v1.2 patch. It is an **addendum**, not a replacement; the existing v1.1 rows remain authoritative.

24.1 KPI Catalog Additions

KPI Name	Purpose	Calculation Method	Owner	Review Frequency	Introduced In
Active Guest Sessions	Real-time guest-mode adoption	\$20.2	Plant Manager	Real-time	\$20
Guest Abandonment Rate	Guest funnel leak	\$20.2	Plant Manager	Daily	\$20
Guest → Submission Conversion %	Guest funnel health	\$20.2	Plant Manager	Weekly	\$20
QR Scan-to-Submission Conversion Rate	QR effectiveness per factory	\$20.4	Plant Manager	Daily	\$20
On-Behalf vs Self-Reported Ratio	On-behalf adoption	\$21.3	Compliance Officer	Monthly	\$21
SELF_LINE_REPORT Flag Rate	Conflict-of-interest prevalence	\$21.3	Compliance Officer	Monthly	\$21
Verbal-Source Share	Source-channel mix	\$21.3	Compliance Officer	Quarterly	\$21
Open Disputes Count	Dispute pipeline depth	\$22.5	Compliance Officer	Real-time	\$22
Dispute Pickup SLA Compliance %	Dispute responsiveness	\$22.5	Compliance Officer	Weekly	\$22
KPI Name	Purpose	Calculation Method	Owner	Review Frequency	Introduced In
Dispute Outcome Rate	Quality of original triage	\$22.5	Compliance Officer	Monthly	\$22
Submission Completion Rate	Reporter funnel completion	\$23.4	Plant Manager	Weekly	\$23
Step Drop-off Rate (per step)	Form-design signal	\$23.4	Product Owner	Bi-weekly	\$23
Voice vs Text Adoption	Voice feature uptake	\$23.4	Product Owner	Monthly	\$23
Evidence Attachment Rate	Evidence adoption	\$23.4	EHS Officer	Monthly	\$23
QR Entry Share	QR funnel share	\$23.4	Plant Manager	Monthly	\$23
Anonymous Funnel Completion %	Anonymous-mode funnel	\$23.4	Compliance Officer	Monthly	\$23

KPI Quality Rule. All KPIs in this addendum are subject to the §17.3 quality rules: no KPI without an owner, calculation method, or review frequency. The Compliance Officer reviews this addendum at the next quarterly review (§1.6) for promotion into the main §17.2 catalog.

24.2 Traceability Matrix Additions

Epic 1 User Story	Epic Requirement (paraphrased)	Governance Requirement (this spec)	Monitoring Capability	Implementation Entity
US-1 (entry points)	Three access entry points: Login, Guest Mode, QR	\$20 Guest Mode & QR Entry Point Monitoring; \$23 Reporter Submission Funnel Monitoring	Guest session lifecycle, QR health events, funnel checkpoints	<code>guest_session_log</code> , <code>qr_health_event</code> , <code>funnel_event</code>
US-6 (QR prefill)	QR-assisted location prefill, QR source metadata	\$20.3 QR Code Health; \$20.4 QR Conversion Funnel	<code>qr_health_event</code> , <code>qr_prefill_applied</code> flag	<code>qr_health_event</code> , <code>funnel_event.qr_prefill_applied</code>
US-7 (dispute)	Reporter can dispute a rejection	\$22 Rejection Dispute Monitoring	E-7 escalation, dispute sub-state machine, Compliance Dashboard additions	<code>dispute</code> (implied by \$22.1), <code>sla_clock</code> (dispute), <code>escalation_event</code>
US-8 (onbehalf)	Authorized user files report for another worker or verbal source	\$21 Report-on-Behalf Monitoring	<code>SELF_LINE_REPORT</code> flag, onbehalf counts, RACI addendum rows 11–12	<code>on_behalf_log</code>
US-1/2/3/6/7 <code>funnel_event</code>	Reporter completes a 14-step submission form (cross-cutting)	\$23 Reporter Submission Funnel Monitoring	rule	10-checkpoint funnel with privacy

24.3 Assumption Class Assignment

New Item	Class	Rationale
60% QR Scan-to-Submission Conversion threshold	[Default]	Reasonable starting point; business to ratify.
20-scan QR_INVALID burst threshold	[Configurable]	Plant Manager may tune per factory.
24h dispute pickup SLA	[Default]	Reasonable; Compliance to ratify.
72h dispute resolution SLA	[Default]	Reasonable; Compliance to ratify.
30-day guest session purge	[Configurable]	Compliance + Legal sign-off.
5 form-open attempts per guest session	[Default]	Reasonable abuse-prevention bound.
40% step-evidence drop-off alert threshold	[Configurable]	Product Owner to tune.
50% Submission Completion Rate advisory threshold	[Default]	Reasonable; Product to ratify.
Privacy Rule: <code>funnel_event</code> has no user FK	[Epic]	Privacy posture is non-negotiable.

24.4 RACI Addendum Schedule (GrillMe Hardening)

The three RACI addendum rows introduced in this patch — Activity 11 (File Report-on-Behalf, \$21.5), Activity 12 (Review `SELF_LINE_REPORT` Flags, \$21.5), Activity 13 (Raise Dispute, \$22.3), Activity 14 (Review Dispute, \$22.3) — are scheduled for **merge into §14.3** at the **next quarterly review** per §1.6. Until that merge, this section is the authoritative reference. The Compliance Officer is responsible for the merge; the Plant Manager signs off.

24.5 GrillMe Hardening — Patch-Level

Challenge Raised	Resolution
"What if the v1.2 patch introduces a KPI that no dashboard element displays?"	§17.3 "No orphan KPIs on dashboards" applies to all new KPIs; the dashboards in §10 are extended in §22.4 (Compliance) and §24.6 (below) to absorb the new KPIs. The next quarterly review verifies no orphan remains.
"What if a v1.2 patch entity (<code>on_behalf_log</code> , <code>funnel_event</code> , <code>qr_health_event</code> , <code>guest_session_log</code>) is migrated to a different schema in v1.3?"	§19.4 GrillMe rule applies: every rename must update §12 and §19 in the same change set. The patch entities are listed in §24.7 for CI referential-integrity checks.
Challenge Raised	Resolution
"What if the Privacy Rule for <code>funnel_event</code> is later relaxed?"	The rule is [Epic] per §24.3; relaxing it requires an Epic / PRD change request, not a governance-only decision. The classification is itself the control.
"What if a future Epic 1 revision changes the 14-step form, making §23.2 checkpoints stale?"	§23.2 is a mapping table (checkpoint → step-number); a step-count change requires updating the mapping, not the schema. The 10 checkpoint names are stable.

24.6 Supervisor Dashboard Addition (Funnel)

To respect §10.1 "no more than 7 visual elements", the Supervisor Dashboard (§10.3) **does not** grow. Instead, the new funnel KPIs are surfaced via a **drill-down** from the existing "Last 24h incident heatmap" element (#7) — clicking the heatmap opens a "Funnel Health" overlay with the three highest-priority funnel KPIs (Submission Completion Rate, Step Drop-off Rate, QR Entry Share). This preserves the cognitive-load discipline of v1.1.

24.7 New Data Model Entities — Index

Entity	Section	Privacy Class	Append-Only?
qr_health_event	§20.3.1	Aggregated + hashed device id	Yes
guest_session_log	§20.3.2	Anonymous by construction (no FK)	Yes
on_behalf_log	§21.6	Creator masked per §9.3	Yes
funnel_event	§23.3	Anonymous by construction (no FK)	Yes
dispute (implied by §22.1 sub-state machine)	§22.1	Linked to <code>case_id</code> ; follows case visibility	Yes
sla_clock (dispute variant, §22.1)	§22.1	Standard SLA semantics	Yes

Append-Only Discipline. All new entities follow the same append-only / INSERT-only DB-role pattern as `case_state_log` (§12.3) and `identity_access_audit` (§12.3). The CI referential-integrity check in §19.4 is extended to cover these entities.

24.8 Patch Submission Readiness Statement

The v1.2 patch has been reviewed against the same categories as v1.1 (Appendix C) and the four patch-specific categories (privacy, conflict-of-interest, SLA loopholes, PII leakage). Every new capability resolves to at least one testable Acceptance Criterion (AC-QR-, AC-OBO-, AC-DIS-, AC-FUN-) and at least one new KPI. The patch is therefore **closed-loop** at the patch surface, **traceable** to the relevant Epic 1 User Story (US-1, US-6, US-7, US-8), and **non-disruptive** to v1.1 (no existing section rewritten or removed). It is fit for **stakeholder submission, engineering implementation, and compliance review**, and is scheduled to be merged into the main specification at the next quarterly review per §1.6.

End of v1.2 Final Release — FactoryShield Incident Monitoring & Operational Governance Specification

FactoryShield_Monitoring_Governance_Spec_v1.2_Final_Release.md 2026-06-29

28. v1.2 Final Release — Submission Readiness Statement

The v1.2 Final Release of this specification closes the three remaining enterprise governance gaps identified during the Figma UI walkthrough and the Compliance Audit dry-run: **(a)** Comment History audit trail (`case_comment_log`, §12.1.13); **(b)** Investigation Methodology auditability (§2.4.3 + extended `investigation_checklist_progress` column + DB-trigger mirroring); and **(c)** Configuration Audit Log for the Admin panel (§13.6 + §12.1.14 + §18.7). It also finalizes the Compliance Dashboard's **AI Insight Accuracy / Feedback** widget (§10.4 element #8 + §10.4.1) and adds the **AI-Assisted Decisions Without Validation** KPI (§17.2). Every addition is bound by:

- A **binding governance clause** explicitly stating the obligation, the enforcement layer (API + DB), and the failure mode.
- A **non-bypassable data-model entity** with INSERT-only DB role permissions and atomic-write guarantees where applicable.
- **§16.6.3 Audit-Log-Intensive Operation NFRs** governing performance, reliability, availability, and durability of the new write paths.
- A **§19.2 Traceability Matrix** row linking the new entity to its governance requirement and its monitoring capability.
- A **§19.5 Governance-Only Capabilities** entry declaring the addition as **[Governance-Only]** so it cannot be silently removed during future Epic revisions.
- **GrillMe Hardening** rows that pre-emptively answer the standard adversarial challenges (rollback safety, throughput bottlenecks, dual-control, retention, schema migration safety, developer bypass).

The v1.2 Final Release specification is **closed-loop** (every new obligation resolves to at least one testable Acceptance Criterion and at least one new NFR), **traceable** to a specific Figma UI surface and to the §19.2 Traceability Matrix, **non-disruptive** to v1.1 and v1.2 (no existing SLA value, KPI definition, RACI cell, GrillMe hardening table, or NFR has been rewritten or removed), and **enterprise-grade** for stakeholder submission, engineering implementation, compliance review, and regulator audit. It is approved for:

- **Implementation** by the Engineering team, with the §16.6.3 NFRs and the §10.4.1 widget binding clauses as the binding engineering quality bar.
- **Compliance Audit** by the Compliance Officer, with §13.6 + §12.1.14 + §18.7 + NFR-AUD-CFG-08 + §10.4.1 (automatic negative-feedback `case_comment_log` write) + §17.2 (AI-Assisted Decisions Without Validation KPI) as the auditable controls.
- **Regulator Submission** via R-AU-01 (Case Audit Trail with Comment History), R-AU-04 (SLA Configuration Change Log), R-AU-06 (Configuration Change Ledger), R-AU-05 (AI-Assisted Decision Audit, now including the negative-feedback stream from §10.4.1).
- **Quarterly Review** per §1.6 with the v1.2 Final Release additions tracked under §19.5 Governance-Only Capabilities.

28.1 v1.2 Final Release — Polish-Pass Inventory (NEW)

The v1.2 Final Release polish pass added (without removing or rewriting any prior content):

Addition	Section	Purpose
Compliance Dashboard element #8 — AI Insight Accuracy / Feedback	§10.4 + §10.4.1	First-class Compliance Officer surface for AI-output quality, with binding automatic-feedbackloop obligation to <code>case_comment_log</code>

KPI: AI-Assisted Decisions Without Validation	\$17.2	Enforces §9.8 Human-Validated default; calculation <code>count(case_state_log where metadata_json.ai_assisted = true AND validated_by_user_id IS NULL); target zero</code> (NFR-AI-01)
Version stamp	Title block, Document ID, Change Log, footer file-	Promoted to Version 1.2 Final Release name